

Tunisian Republic
Ministry of Higher Education and Scientific Research
Private Higher School of Engineering and Technology
TEK-UP

Final Year Project Report
Submitted in partial fulfilment of the requirements for the
National Engineering Degree in Applied and Technological Sciences
Speciality: Web, Mobile and Multimedia Development

Prepared by
Nadim JEBALI



Design and Development of an Intelligent Multi-Vendor Marketplace: Cheebo

Professional Supervisor: Mr. Mohammed Aziz Chibani
NeuralBey

Academic Supervisor: Ms. Sawssen Jalel
Lecturer

I authorise the student to submit his internship report for a defence.

Professional Supervisor, Mr. Mohammed Aziz Chibani

Signature and stamp

I authorise the student to submit his internship report for a defence.

Academic Supervisor, Ms. Sawssen Jalel

Signature

Dedication

To my parents, for their unwavering love, patience and encouragement during every step of this project.

To my friends and colleagues at NeuralBey and TEK-UP who offered guidance, feedback and inspiration.

Acknowledgements

I would like to express my sincere gratitude to all those who contributed to the completion of this project.

First, my deepest thanks to my professional supervisor, Mr. Mohammed Aziz Chibani (NeuralBey), for his continuous guidance, domain expertise, and support throughout the development and evaluation phases.

I am also grateful to Ms. Sawssen Jalel for her academic supervision and valuable feedback which helped shape the report.

Special thanks to my colleagues and friends for testing features, providing constructive critiques, and motivating me during challenging moments.

Finally, I thank my family for their encouragement and patience during this work.

Abstract

This report presents Cheebo, a multi-vendor e-commerce marketplace developed as a final-year project at TEK-UP in partnership with NeuralBey. The platform lets independent sellers open and customise their own storefronts, manage product catalogues, and fulfil orders, while customers browse across vendors from a single interface and administrators moderate the marketplace. Its distinguishing feature is the integration of Artificial Intelligence for operational tasks: automated product and store verification, a natural-language database assistant for administrators, and AI-driven storefront re-design, all orchestrated as n8n workflows behind webhooks. The system is built as a TypeScript monorepo — a NestJS REST API backed by Prisma and MariaDB, and a React single-page application — and is engineered to professional standards, with an automated test suite of 445 tests and a complete CI/CD pipeline that containerises the services with Docker, provisions infrastructure with Terraform, and deploys to a live DigitalOcean environment on every push. The result is a deployed, tested, and reproducible marketplace that demonstrates both full-stack application development and modern DevOps and AI-integration practice.

Keywords: marketplace, multi-vendor, NestJS, React, Prisma, Artificial Intelligence, Docker, CI/CD, Terraform.

Contents

Dedication	2
Acknowledgements	3
Abstract	4
List of Abbreviations	13
General Introduction	14
1 General Project Context	15
1.1 Presentation of the Host Organisation	15
1.1.1 NeuralBey — Company Overview	15
1.1.2 Domain, Team and Mission	15
1.2 Project Context	16
1.2.1 Project Origin and Motivation	16
1.2.2 Multi-Vendor Marketplace Concept	16
1.2.3 Target Users	17
1.3 Study of Existing Solutions	17
1.3.1 Existing Tunisian E-Commerce Platforms	17
1.3.2 Limitations of Current Solutions	17
1.3.3 Competitive Analysis	18
1.4 Proposed Solution	18
1.4.1 Cheebo Overview	18
1.4.2 Key Differentiators	19
1.4.3 Project Scope	19
1.5 Work Methodology	20
1.5.1 Classical vs Agile Approaches	20
1.5.2 Chosen Approach: Iterative and Incremental Development	21
1.5.3 The Iterative and Incremental Lifecycle	21
1.5.4 Project Roles	22
1.5.5 Iteration Rhythm and Supervisor Validation	23
1.5.6 Work Artefacts and Milestones	23
1.5.7 Tools Used	24
Chapter Conclusion	25

2	Requirements Analysis and Specification	26
2.1	Identification of Actors	26
2.1.1	Customer	26
2.1.2	Seller	26
2.1.3	Administrator	27
2.2	Functional Requirements	27
2.2.1	User Registration and Authentication	27
2.2.2	Store Management	27
2.2.3	Product Management	29
2.2.4	Order System	29
2.2.5	Admin Dashboard	29
2.2.6	AI Verification	30
2.2.7	Featured Content Curation	30
2.3	Non-Functional Requirements	30
2.4	Use Case Diagrams	32
2.4.1	Global Use Case Diagram	32
2.4.2	Detailed Use Cases — Customer	34
2.4.3	Detailed Use Cases — Seller	35
2.4.4	Detailed Use Cases — Administrator	36
2.5	Sequence Diagrams	37
2.5.1	Registration, Email Verification and Login	37
2.5.2	Order Placement	38
2.5.3	Product Verification (AI + Administrator)	39
2.6	Modelling Language	40
2.7	Project Backlog	41
2.7.1	Project Roles	41
2.7.2	MoSCoW Priority Legend	41
2.7.3	Product Backlog	41
	Chapter Conclusion	46
3	Design and Architecture	47
3.1	Global Architecture	47
3.1.1	3-Tier Architecture Overview	47
3.1.2	n8n as an Automation Layer	48
3.2	Detailed Technical Architecture	49
3.2.1	NestJS Modular Architecture	49
3.2.2	React SPA Architecture	52
3.2.3	Docker Compose Services Diagram	52
3.3	Database Design	54
3.3.1	Entity-Relationship Diagram	54

3.3.2	Prisma Schema Overview	55
3.3.3	Explanation of Key Relationships	56
3.4	API Design	57
3.4.1	REST API Design Principles	57
3.4.2	Endpoint Structure	58
3.4.3	Authentication Flow (Better-Auth)	60
3.5	n8n Workflow Design	60
3.5.1	AI Verification Workflow	60
3.5.2	Database Chat Assistant Workflow	61
3.5.3	AI Storefront Redesign Workflow	61
3.6	Class Diagram	63
	Chapter Conclusion	66
4	Development and Implementation	67
4.1	Development Environment	67
4.1.1	Hardware and Software	67
4.1.2	VSCode and Extensions	68
4.1.3	pnpm Monorepo Structure	69
4.2	Backend (NestJS)	69
4.2.1	Project Structure	69
4.2.2	Key Modules	70
4.2.3	Authentication Guards and Role-Based Access Control	71
4.2.4	File Upload System (Multer)	72
4.2.5	Email System (Nodemailer)	72
4.2.6	Payment Processing (Stripe)	72
4.2.7	Rate Limiting	73
4.2.8	Stale-Checkout Reconciliation	74
4.3	Frontend (React + Vite)	74
4.3.1	Project Structure	74
4.3.2	Routing and Layouts	75
4.3.3	State Management (TanStack Query + Zustand)	75
4.3.4	Admin Dashboard Panels	76
4.3.5	Store and Product Management Interface	76
4.4	AI Integration with n8n	77
4.4.1	AI Product/Store Verification Pipeline	77
4.4.2	Database Chat Assistant	78
4.4.3	n8n Workflow — AI Storefront Redesign	78
4.4.4	Google Gemini / Groq Integration	79
4.4.5	n8n Workflow Implementation	79
4.5	Interface Screenshots	80

4.5.1	Customer Experience	80
4.5.2	Seller Dashboard	84
4.5.3	Administrator Tools	89
4.5.4	AI Assistant	96
4.6	Tests and Validation	97
4.6.1	Testing Stack and Tooling	97
4.6.2	Test Pyramid for Cheebo	98
4.6.3	Backend Unit Tests	99
4.6.4	Backend Integration Tests	102
4.6.5	Frontend Tests (Vitest)	103
4.6.6	Continuous Integration	105
4.6.7	What is Not Covered	105
	Chapter Conclusion	106
5	Infrastructure and Deployment	107
5.1	Containerisation with Docker	107
5.1.1	Dockerfiles (Frontend and Backend)	107
5.1.2	Docker Compose Configuration	108
5.1.3	TLS Termination with Caddy	108
5.1.4	Multi-Service Networking	109
5.2	Infrastructure as Code with Terraform	109
5.2.1	DigitalOcean Provider	110
5.2.2	VPC, Droplet and Firewall Resources	110
5.2.3	DNS Management with DigitalOcean	110
5.2.4	Remote State Management with DigitalOcean Spaces	111
5.3	CI/CD Pipeline with GitHub Actions	111
5.3.1	Workflow Overview	111
5.3.2	Build Stage (Docker Build and Push to Docker Hub)	112
5.3.3	Deployment Stage (SSH and Docker Compose)	113
5.3.4	Automated n8n Provisioning	113
5.3.5	Environment Secrets Management	113
5.4	Production Environment	114
5.4.1	DigitalOcean Droplet Specifications	114
5.4.2	Production Service Architecture	114
5.4.3	n8n Deployment Alongside the Application	115
	Chapter Conclusion	116
	General Conclusion	117
	Bibliography and Webography	120
	A Complete Prisma Schema	122

B	API Endpoints Reference	128
C	n8n Workflow JSON Exports	131
D	Dockerfiles	141
E	Docker Compose File and Caddyfile	143
F	GitHub Actions Workflow	147

List of Figures

1.1	Iterative and incremental lifecycle: increments grouped into three milestones, each validated by the supervisor	22
2.1	Global use case diagram (detailed)	33
2.2	Customer use cases	34
2.3	Seller use cases	35
2.4	Administrator use cases	36
2.5	Sequence: registration, email verification and login	38
2.6	Sequence: order placement	39
2.7	Sequence: product verification (AI and administrator)	40
3.1	Global system architecture (three tiers + n8n automation layer)	48
3.2	NestJS modular architecture: groups of feature modules and their dependencies	51
3.3	Docker Compose services on the production host	54
3.4	Entity-Relationship diagram of the Cheebo database	55
3.5	n8n workflow — AI verification	61
3.6	n8n workflow — Database chat assistant	61
3.7	n8n workflow — AI storefront redesign	62
3.8	AI storefront redesign — interaction sequence	63
3.9	UML class diagram of the main domain entities	65
4.1	Cheebo monorepo structure	69
4.2	Deny-by-default access control implementation	71
4.3	Admin dashboard	76
4.4	Store and product management interface	77
4.5	Landing page	80
4.6	Stores listing page	81
4.7	Product browse page	82
4.8	Product detail page	83
4.9	Global search dialog	83
4.10	Checkout page	84
4.11	Store dashboard	85

4.12	WYSIWYG storefront editor	86
4.13	AI Redesign dialog	86
4.14	Store-wide sale configuration panel	87
4.15	Product management	88
4.16	Analytics page	89
4.17	Admin dashboard overview	90
4.18	Seller applications panel	91
4.19	AI verification panel	92
4.20	Users panel	93
4.21	Stores moderation panel	94
4.22	Categories panel	95
4.23	Featured content curation panel	96
4.24	AI chat assistant	97
4.25	Test pyramid — 445 tests total across backend (Jest, 337) and frontend (Vitest, 108)	99
5.1	Docker Compose network architecture	109
5.2	Terraform resources	111
5.3	GitHub Actions CI/CD pipeline	112
5.4	Production architecture	115

List of Tables

1.1	Comparative analysis of competing platforms	18
2.1	Non-functional requirements	31
2.2	MoSCoW priority and complexity legend	41
2.3	Product backlog — user stories with MoSCoW priority and complexity	42
3.1	Main REST API endpoints, grouped by module	59
4.1	Development toolchain used throughout the project	68
4.2	Testing stack used in Cheebo	98
4.3	Backend unit test suites — domain services (write paths)	100
4.4	Backend unit test suites — read paths, cross-cutting concerns and guards	101
4.5	Backend controller integration tests	102
4.6	Frontend test suites (Vitest + React Testing Library) — 108 tests . . .	104
B.1	Cheebo REST API endpoint reference	130

List of Abbreviations

AI	Artificial Intelligence
API	Application Programming Interface
CD	Continuous Deployment
CI	Continuous Integration
CORS	Cross-Origin Resource Sharing
CRUD	Create, Read, Update, Delete
DB	Database
DNS	Domain Name System
DTO	Data Transfer Object
DWMM	Web, Mobile and Multimedia Development
HTTP	HyperText Transfer Protocol
HTTPS	HyperText Transfer Protocol Secure
JSON	JavaScript Object Notation
JWT	JSON Web Token
LLM	Large Language Model
MIME	Multipurpose Internet Mail Extensions
MVP	Minimum Viable Product
ORM	Object-Relational Mapping
PFE	Final Year Project (<i>Projet de Fin d'Études</i>)
RBAC	Role-Based Access Control
REST	Representational State Transfer
SMTP	Simple Mail Transfer Protocol
SPA	Single Page Application
SQL	Structured Query Language
SSE	Server-Sent Events
SSH	Secure Shell
TLS	Transport Layer Security
UML	Unified Modeling Language
VPC	Virtual Private Cloud

General Introduction

This introduction explains the context for the Cheebo project, why the system was created, who the intended users are, and how the work was organised from conception through delivery.

Cheebo is a multi-vendor marketplace developed as a final year engineering project in partnership with TEK-UP and NeuralBey. The platform is designed to give Tunisian sellers a modern, secure online storefront while offering customers an intelligent shopping experience and administrators a reliable way to manage vendors, products, and verification workflows.

The project combines academic goals and real-world needs: it must satisfy the PFE requirements for software engineering, while also providing a practical solution that addresses the host organisation's expectations for a modern web application. The following chapters present the host organisation, the business context, the requirements analysis, the system architecture, implementation details, and the deployment strategy.

Chapter 1 General Project Context

This chapter sets the scene — why this project exists, who it is for, and how its development was organised. It introduces the host organisation, the business motivation behind Cheebo, the competitive landscape in which it operates, the proposed solution, and the working methodology adopted throughout the internship.

1.1 Presentation of the Host Organisation

1.1.1 NeuralBey — Company Overview

NeuralBey is a Tunisian technology company that delivers end-to-end engineering services across a broad spectrum of modern computing fields. The company positions itself as a partner that translates client visions into working systems, summarised by its own statement: *“From web and mobile apps to AI systems, IoT, embedded engineering, and 3D solutions — we build the technology that powers your vision.”*

This breadth allows NeuralBey to handle a project from initial concept through deployment without external dependencies, and to combine disciplines that are usually siloed — for example, integrating artificial intelligence into conventional web platforms, or interfacing embedded devices with cloud services. The company’s portfolio reflects this versatility:

- **Web and mobile applications** for consumer products and enterprise tooling;
- **AI systems**, including model integration, automation pipelines and intelligent assistants;
- **IoT and embedded engineering**, where NeuralBey designs firmware and connected devices;
- **3D solutions** for product visualisation, AR/VR and digital twins.

1.1.2 Domain, Team and Mission

NeuralBey operates as a multidisciplinary studio. Each project is staffed by engineers selected from the relevant domain (frontend, backend, AI, hardware, 3D), and a professional supervisor accompanies the work from scoping through delivery. The team’s working culture emphasises code review, iterative delivery and frequent stakeholder

feedback — practices that aligned naturally with the academic requirements of a final year project.

The present project was carried out under the professional supervision of **Mr. Mohammed Aziz Chibani**, who provided architectural guidance, regular reviews, and technology recommendations throughout the internship. Academic oversight was provided in parallel by **Ms. Sawssen Jalel**, ensuring the work also satisfied the methodological and documentation standards of the engineering diploma.

1.2 Project Context

1.2.1 Project Origin and Motivation

The Cheebo project originated from an internal need identified at NeuralBey: the Tunisian online retail landscape lacks a modern, multi-vendor platform that is both seller-friendly and equipped with the automation features expected of contemporary marketplaces. Existing local solutions are typically single-vendor stores or classified-ad sites, and they offer limited tooling for moderation, content quality and discovery.

NeuralBey saw an opportunity for a product combining three differentiating capabilities:

- (i) a true multi-vendor model with self-service onboarding for sellers;
- (ii) AI-assisted moderation of stores and products to reduce manual review load;
- (iii) a deployment story that demonstrates contemporary DevOps practices end-to-end.

The PFE topic was therefore scoped jointly with the professional supervisor, with the explicit goal of producing a system that could serve both as a portfolio piece for the company and as a foundation for further internal development beyond the internship.

1.2.2 Multi-Vendor Marketplace Concept

A *multi-vendor marketplace* is a platform on which independent sellers operate their own stores within a shared environment governed by a central operator. It differs from two adjacent models:

- a **single-vendor store**, where the platform itself owns the inventory and the brand;
- a **classified-ad site**, where the platform only lists offers and plays no role in transactions or quality control.

A marketplace must reconcile three concerns simultaneously: **seller autonomy** (each seller manages catalogue, branding and inventory), **buyer trust** (the platform

guarantees a baseline of product authenticity and fulfilment) and **operator governance** (administrators onboard sellers, moderate content, suspend stores and curate featured selections). These three perspectives drive the architecture of Cheebo: every feature is designed to balance autonomy for sellers, trust for buyers, and control for administrators. The integration of AI verification is a direct response to the buyer-trust requirement at the scale a marketplace demands.

1.2.3 Target Users

Three actor categories were identified at the scoping stage:

- **Customer** — an end-user who browses the catalogue, places orders and tracks deliveries. Expects a fast, mobile-friendly experience with reliable search and clear product information.
- **Seller** — a small or medium merchant who creates a store, manages a product catalogue and fulfils orders. Expects low onboarding friction, clear analytics, and protection against unfair competition from low-quality listings.
- **Administrator** — the platform operator (NeuralBey staff) who reviews seller applications, moderates flagged content, curates featured stores, and intervenes when a store violates the marketplace rules.

1.3 Study of Existing Solutions

1.3.1 Existing Tunisian E-Commerce Platforms

Three categories of competing platforms were studied:

- **Pan-African marketplaces (Jumia).** Jumia Tunisia is the most visible regional marketplace. It supports multiple vendors at scale and offers a polished customer experience, but seller onboarding is heavyweight and the platform is not tailored to small Tunisian merchants.
- **Classified-ad sites (Tayara, Affariyet).** Tayara dominates the local classified-ad market. It offers excellent discovery for sellers, but performs no escrow, no order management, no integrated payment and no quality moderation.
- **Single-vendor stores (MyTek, Wiki, etc.).** These are vertically integrated retailers that operate their own catalogue. They cannot be used by independent sellers.

1.3.2 Limitations of Current Solutions

From the study above, four gaps emerged:

- L1. No AI-assisted moderation.** On existing platforms, store and product verification are entirely manual — slow, inconsistent, and impractical at scale.
- L2. Heavyweight seller onboarding.** Pan-regional players require contractual paperwork unsuitable for small merchants.
- L3. Limited operator tooling.** Classified-ad sites have weak admin dashboards; single-vendor stores have none for external sellers.
- L4. Outdated technical foundations.** Several platforms still rely on monolithic stacks without modern CI/CD or infrastructure-as-code, making evolution costly.

1.3.3 Competitive Analysis

Table 1.1 summarises the comparison along the five criteria that drove the design of Cheebo. A check mark (✓) indicates the criterion is fully supported, a cross (✗) indicates it is absent, and a tilde (~) indicates partial support.

Table 1.1: Comparative analysis of competing platforms

Criterion	Jumia	Tayara	Cheebo
Multi-vendor model	✓	~	✓
AI verification	✗	✗	✓
Admin dashboard	~	✗	✓
CI/CD pipeline (open)	✗	✗	✓
Lightweight onboarding	✗	✓	✓

1.4 Proposed Solution

1.4.1 Cheebo Overview

Cheebo is a multi-vendor marketplace designed around three pillars: a self-service seller experience, AI-assisted content verification, and a modern, fully containerised deployment. The platform is built as a single-page **React 19** application backed by a modular **NestJS** API, with **MariaDB** as the relational store and **n8n** acting as an orchestration layer for AI tasks. Authentication is handled by **Better-Auth** with email verification, and **Prisma** is used as the ORM. The full system is packaged with Docker Compose, provisioned on DigitalOcean via Terraform, and delivered through a GitHub Actions CI/CD pipeline.

Sellers create a store in minutes, populate it with products and tags, and benefit from automatic AI verification that surfaces a trust badge to potential buyers. Administrators review borderline cases through a dedicated dashboard, suspend stores when needed, and override automated decisions, and query the database through an in-app

AI chat assistant for operational insights. Customers browse a unified catalogue and place orders across multiple sellers in a single checkout.

1.4.2 Key Differentiators

Seven differentiators set Cheebo apart from the platforms surveyed in the previous section:

- D1. AI verification of stores and products** via an n8n workflow that calls a hosted LLM and writes back the `aiReviewed` flag plus a textual `aiReviewNote` rationale.
- D2. Lightweight seller onboarding** through a seller application form reviewed by administrators, with a free tier offering a single store at zero cost.
- D3. Integrated administration tooling** (review, suspend, curate, cascade-delete) implemented as first-class features rather than database admin scripts.
- D4. Conversational data access** via a database-aware chatbot built on n8n, allowing administrators to query the platform in natural language.
- D5. AI-assisted storefront redesign** — sellers can regenerate their entire store visual identity from a natural-language prompt, powered by an n8n workflow and the Groq `llama-3.3-70b-versatile` model.
- D6. Store-wide sale promotions** that propagate a percentage discount automatically across all product cards, store listings, and search results, and apply the discounted price at checkout without any per-product editing.
- D7. Modern DevOps foundations** — pnpm monorepo, Docker Compose, Terraform on DigitalOcean, and GitHub Actions CI/CD — demonstrating production-grade engineering practices end-to-end.

1.4.3 Project Scope

The scope was agreed with the professional supervisor and is split between in-scope and out-of-scope items so that the deliverables remain clear and bounded.

In scope: account creation and email verification; seller application workflow with admin review; store and product CRUD with image upload; tag-based product recommendations with a top-seller fallback; order placement, items and history; admin moderation panels (store suspension, cascade-delete); AI verification and chat assistant via n8n; store-wide percentage sales with automatic badge propagation across products and search results; AI-assisted storefront redesign via an n8n/Groq workflow; premium tier unlocking additional stores; and infrastructure-as-code deployment.

Out of scope (deferred to future iterations): integrated payment processing (e.g. Konnect or Stripe); a native mobile application; advanced fraud detection; on-premise LLM

hosting; multi-currency support; and a full-text search engine such as Elasticsearch or Typesense.

1.5 Work Methodology

1.5.1 Classical vs Agile Approaches

Every software project requires a methodological framework to organise work, manage priorities, and guarantee the delivery of a quality product. Two major families of methods have historically competed: the **classical** (predictive) approach and the **agile** (adaptive) approach. Their fundamental difference lies in how they handle change and value delivery.

Classical approach — Waterfall. The Waterfall method divides the project into strictly sequential phases: requirements, design, development, testing, and delivery. Each phase must be fully validated before the next begins. This model suits projects whose requirements are stable and known in advance, but it shows its limits as soon as the context evolves:

- Requirements are frozen at launch; any late change is costly.
- The client sees a working product only at the very end of the project.
- Defects and risks are detected in the test phase, too late to address without significant impact.
- Documentation tends to be voluminous and quickly out of sync with the actual code.

Agile approach — Core principles. Agility was born from the *Agile Manifesto* (2001) [2], which champions collaboration, adaptability, and the continuous delivery of value. Rather than planning the entire project upfront, work is organised into **short iterations**, each producing a functional and tested increment. This approach offers several concrete advantages:

- Requirements are refined continuously from client and stakeholder feedback.
- Value is delivered from the first iterations; the product is usable well before the end of the project.
- Risks are identified and addressed early.
- Daily communication fosters responsiveness and team alignment.

1.5.2 Chosen Approach: Iterative and Incremental Development

The full team-oriented frameworks — chief among them **Scrum** [1] — were considered but deliberately *not* adopted in their prescribed form. Scrum’s value comes from its events (Sprint Planning, the Daily Scrum, the Sprint Review, and the Retrospective) and from three distinct accountabilities (Product Owner, Scrum Master, and a multi-person Development Team). This PFE was carried out by a **single developer**, with the company supervisor acting as the stakeholder; running daily stand-ups with oneself or formal sprint ceremonies for a team of one would have been process for its own sake rather than a source of value.

Instead, the project followed an **Iterative and Incremental Development** (IID) lifecycle [3], which keeps the Agile principles that genuinely fit a solo context while dropping the team-coordination machinery that does not:

- **Incremental delivery:** the system was grown in successive working increments (authentication, then the catalogue, then orders and payments, then deployment), each adding tested, demonstrable functionality rather than a big-bang release at the end.
- **Adaptive requirements:** the scope evolved throughout the internship; building in increments let new understanding and supervisor feedback reshape later work without invalidating what was already delivered.
- **Milestone cadence:** work was organised around a small number of feature *milestones* rather than fixed-length, time-boxed sprints — a lighter rhythm better matched to a single developer’s flow.
- **Validation at milestone boundaries:** the supervisor reviewed and validated each milestone increment, providing the stakeholder feedback loop that a Sprint Review would supply in a team setting.

1.5.3 The Iterative and Incremental Lifecycle

Iterative and incremental development builds a system as a series of increments. Each increment passes through the same short cycle — *plan a slice of functionality, implement it, test it, and validate it* — and adds working capability on top of what already exists, so the product is functional and demonstrable long before the project ends. Successive increments are grouped into the project’s three feature milestones.

Figure 1.1 illustrates the lifecycle: each increment loops through the build cycle and feeds a working version into the growing product, with the supervisor validating the result at each milestone boundary before the next milestone begins.

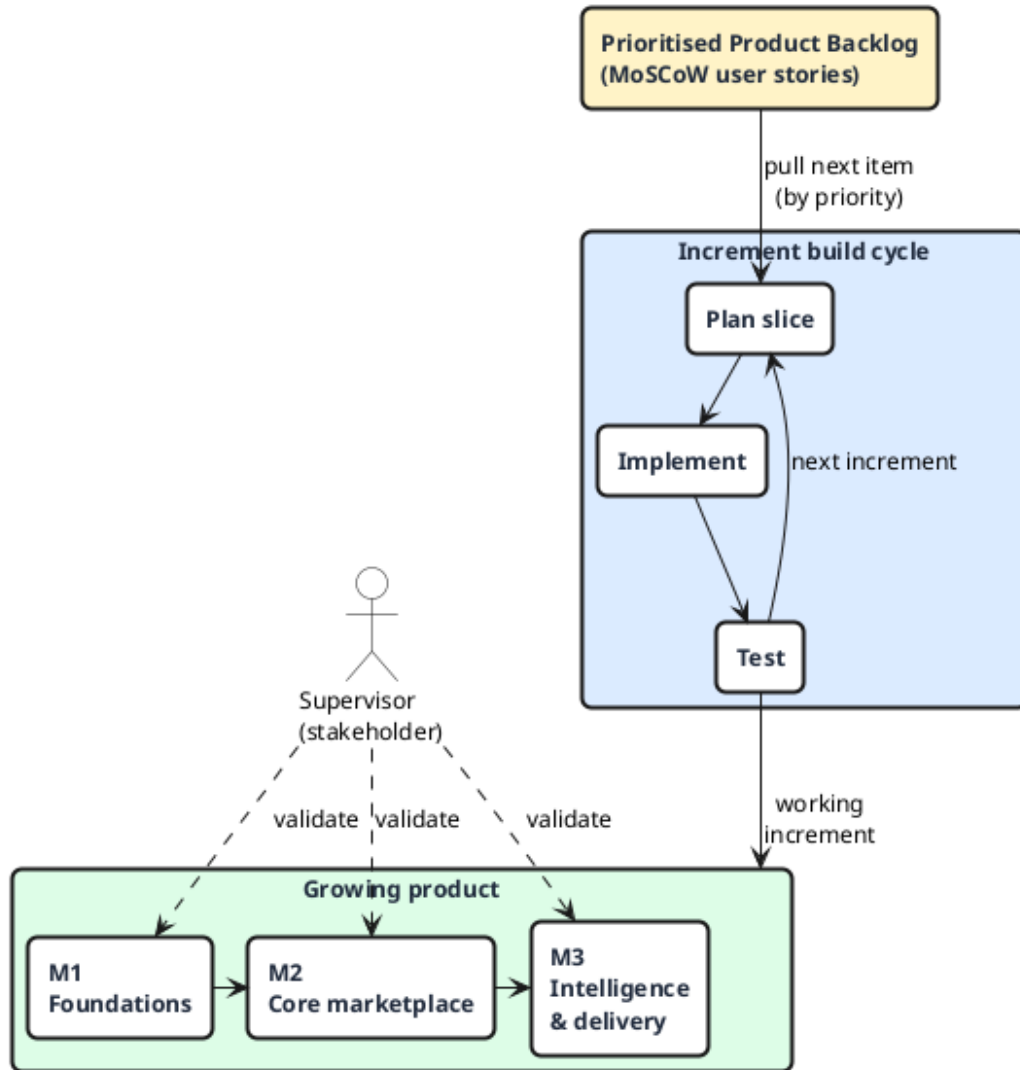


Figure 1.1: Iterative and incremental lifecycle: increments grouped into three milestones, each validated by the supervisor

1.5.4 Project Roles

Because the project was carried out by a single developer, it involved two roles rather than the three accountabilities of a team framework:

- **Supervisor / stakeholder: Mr. Mohammed Aziz Chibani** (NeuralBey) owned the product vision, prioritised the requirements, and reviewed and validated each milestone increment, also providing architectural guidance throughout.
- **Developer: Nadim Jebali** (the student) was responsible for the entire technical realisation — analysis, design, implementation, testing, and deployment — and for maintaining the prioritised backlog.

1.5.5 Iteration Rhythm and Supervisor Validation

Rather than fixed-length sprints and the associated ceremonies, the project ran as a continuous flow of feature increments organised by the following rhythm:

- **Increment selection:** the next increment was pulled from the prioritised backlog according to MoSCoW priority and dependencies, rather than committed to a time-boxed sprint.
- **Build cycle:** each increment was implemented and tested before the next was started, keeping the product in a working, demonstrable state throughout.
- **Milestone validation:** at each milestone boundary the supervisor reviewed the accumulated increment and gave feedback that fed into subsequent work — the stakeholder loop that a Sprint Review provides in a team setting.

The process also improved over its lifetime through ordinary reflection: `pnpm` was adopted for monorepo management, manual deployments were replaced by a GitHub Actions pipeline, and `n8n` was introduced for the AI workflows.

1.5.6 Work Artefacts and Milestones

Two artefacts ensured transparency of the work:

- **Product Backlog:** a prioritised list of all expected product functionalities, maintained as user stories with MoSCoW priorities and complexity estimates (see Chapter 2).
- **Increment:** a working, demonstrable version of the product produced as each backlog item was completed and folded into the running application.

Increments were grouped into three feature milestones spanning the six-month internship:

- **Foundations:** repository setup, authentication with Better-Auth, base data model, and the seller-application flow.
- **Core marketplace:** stores, products, orders, admin panels, and tag-based recommendations.
- **Intelligence and delivery:** the AI verification pipeline, the in-app AI chat assistant, Dockerisation, Terraform provisioning, and the CI/CD pipeline.

1.5.7 Tools Used

The following tools were used throughout the project, covering source control, development, containerisation, infrastructure provisioning, workflow automation, and API testing.



A web-based platform for version control and collaborative software development built on Git. It was used for source control, code review via pull requests, and continuous integration and deployment through GitHub Actions workflows.



An all-in-one productivity workspace combining notes, databases, and kanban boards. It served as the project's backlog management tool, task board, and a living record of user stories and acceptance criteria.



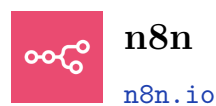
A lightweight but powerful source-code editor developed by Microsoft. It was the primary IDE throughout the project, extended with plugins for TypeScript, Prisma schema editing, ESLint linting, and Git integration.



An open platform for developing, shipping, and running applications inside isolated containers. It was used to containerise all services — MariaDB, the NestJS backend, the React frontend, and the n8n workflow engine — ensuring parity between development and production environments.



An open-source infrastructure-as-code tool by HashiCorp that allows cloud resources to be defined in declarative configuration files. It was used to provision and manage the DigitalOcean droplet, DNS records, and firewall rules in a reproducible way.



A fair-code workflow automation platform with a visual node-based editor. It was used to orchestrate the AI-assisted product and store verification pipeline as well as the in-app AI chat assistant, connecting the backend to large language model APIs.



A collaborative API development platform for designing, testing, and documenting HTTP endpoints. It was used during back-end development to manually exercise and validate every REST endpoint before integration with the frontend.



A fast, disk-efficient package manager for Node.js that uses hard links and a content-addressable store. It managed all JavaScript dependencies across the monorepo workspace, ensuring consistent installs in both development and CI.

Key Takeaways

- Cheebo originates from an internal NeuralBey brief: build a modern, Tunisia-oriented multi-vendor marketplace with AI-assisted moderation.
- Three actors — customer, seller, administrator — drive every architectural decision throughout the report.
- Compared with Jumia and Tayara, Cheebo differentiates on *AI verification*, *lightweight seller onboarding*, *first-class admin tooling*, and *modern DevOps* (Docker, Terraform, GitHub Actions).
- Development followed an iterative, incremental process — increments pulled from a prioritised backlog and validated by NeuralBey at milestone boundaries — structured around three milestones: foundations, core marketplace, and intelligence-and-delivery.

Chapter Conclusion

This chapter established the foundations of the Cheebo project. It introduced NeuralBey, the host organisation, and explained the business motivation behind building a modern Tunisian multi-vendor marketplace. A study of existing platforms revealed four gaps — absent AI moderation, heavyweight onboarding, weak admin tooling, and outdated technical foundations — that Cheebo directly addresses. The proposed solution, its key differentiators, and its bounded scope were presented. Finally, the iterative and incremental methodology was described in detail — its rationale for a single-developer PFE, its roles, its milestone-based rhythm, and its work artefacts — and the three-milestone plan that organised the six-month development was outlined. The following chapter formalises the requirements derived from this context.

Chapter 2 Requirements Analysis and Specification

This chapter identifies the three system actors, formalises the functional and non-functional requirements of Cheebo, and illustrates them with UML use-case and sequence diagrams. The requirements were consolidated during the foundations milestone in collaboration with the professional supervisor and serve as the contract that the rest of the report builds upon.

2.1 Identification of Actors

The platform recognises three actor categories. They are distinct *roles* stored on the **User** table rather than distinct user records — a single account can be promoted from *customer* to *seller* once a seller application is approved, and an administrator account is created automatically on first boot.

2.1.1 Customer

The Customer is the default role assigned upon registration. A Customer can browse the catalogue, search products, view individual stores, manage a cart, place an order across multiple sellers in a single checkout, and review their personal order history. The Customer is also the entry point for the seller pipeline: any Customer can submit a seller application and, once approved, gain the Seller role on the same account. Anonymous (non-authenticated) visitors share the read-only abilities of the Customer but cannot maintain a cart or place an order.

2.1.2 Seller

The Seller is a Customer whose seller application has been approved by an administrator. A Seller can create and edit one store under the free tier (or several under the premium tier), populate that store with products, upload product images, attach product tags, view per-store analytics, and consult the order history specific to their store. Sellers also choose a visual template for their store from the templates exposed by the frontend. They cannot, however, review or moderate the work of other sellers.

2.1.3 Administrator

The Administrator is created automatically by the backend at first boot and is not exposed through the registration form. The Administrator reviews seller applications, browses every store and every product on the platform, suspends or deletes stores (with cascading deletion of dependent records), overrides automated AI verification decisions, curates featured stores and products on the landing page, manages categories and sub-categories, and consults the platform through a database-aware AI chat assistant.

2.2 Functional Requirements

The functional requirements are grouped into seven domains. Each domain corresponds to a NestJS module on the backend and to a matching set of pages on the React frontend; the mapping is made explicit in Chapter 3.

2.2.1 User Registration and Authentication

- FR-A1.** The system shall allow a visitor to create an account with an email address and password.
- FR-A2.** The system shall send a verification email containing a one-time link upon successful registration.
- FR-A3.** The system shall prevent unverified accounts from creating a store or placing an order.
- FR-A4.** The system shall authenticate returning users via Better-Auth sessions and issue an HTTP-only cookie.
- FR-A5.** The system shall allow the user to log out and invalidate the corresponding session.
- FR-A6.** The system shall enforce role-based access control on every non-public route through guards and the `@Roles()` decorator.

2.2.2 Store Management

- FR-S1.** A Seller shall be able to create a store with a name, description, logo and template.
- FR-S2.** A Seller shall be able to edit their store profile at any time.
- FR-S3.** A free-tier Seller shall be limited to a single store.
- FR-S4.** A premium-tier Seller shall be able to operate multiple stores from the same account.

- FR-S5.** Each store shall expose a public storefront URL identified by a human-readable slug derived from the store name (e.g. `/stores/pawsome-pet-foods`), rather than by its numeric primary key.
- FR-S6.** Slug uniqueness shall be enforced at the database level and collisions resolved by an automatic numeric suffix (`-2`, `-3`, ...). The slug shall be regenerated when the store name changes.
- FR-S7.** The store status (active, pending, suspended) shall be persisted in a `StoreStatusLog` audit trail.
- FR-S8.** The Seller shall be able to customise the storefront across seven independent sections — *Theme*, *Announcement Bar*, *Banner*, *Header*, *Product Grid*, *Side-bar* and *Footer* — through a WYSIWYG visual editor built with Craft.js, where clicking any section on the live canvas immediately opens its settings panel.
- FR-S9.** Four pre-built presets shall be available as starting points for customisation: *Default* and *Minimal* are available to all sellers, while *Modern* and *Classic* are restricted to premium accounts. Applying a preset overwrites the current draft with the preset's section defaults.
- FR-S10.** The Seller shall be able to upload a custom banner image, stored under `/uploads/stores/` and referenced from the customisation JSON.
- FR-S11.** The customisation editor shall support undo/redo on every section change and shall warn the seller before discarding unsaved changes.
- FR-S12.** Customisation features shall be tiered. Free accounts may use a curated subset — a six-colour palette for the primary colour, two fonts (*Inter* and the system default), the *soft* corner radius, checkbox-style filters, square product images, and section visibility toggles. Premium accounts unlock the full set: free-form hex colours, all four fonts, all radii, banner image upload with heading and overlay controls, sidebar inner panel and text colours, non-checkbox filter styles, product grid background, non-square aspect ratios, and footer social links. When a premium subscription expires, the seller's existing customisation values are preserved at the database level and remain visible to visitors; the seller is only prevented from *modifying* those premium fields going forward.
- FR-S13.** A Seller shall be able to activate a store-wide sale by enabling a percentage discount (1–90%), an optional custom label (e.g. *"Summer Sale"*), and an optional expiry date. While the sale is active, every product in the store shall display its discounted price alongside a red sale badge on product cards, the

store card, and search results. The discounted price shall also be used as the unit price when the product is added to an order.

- FR-S14.** A Seller shall be able to trigger an AI-assisted full storefront redesign by submitting a short natural-language prompt. The system shall forward the request to an n8n workflow powered by the Groq `llama-3.3-70b-versatile` model, which generates a complete `StoreCustomization` object covering all seven sections. The result shall be applied to the live Craft.js editor immediately, allowing the seller to review or further refine the design before saving.

2.2.3 Product Management

- FR-P1.** A Seller shall be able to create, edit and delete products belonging to their own store(s).
- FR-P2.** Each product shall accept one or more images of supported MIME types, with a configurable maximum file size.
- FR-P3.** Each product shall support an arbitrary number of tags used by the recommendation engine.
- FR-P4.** Each product shall carry two review flags: `aiReviewed`, set automatically by the AI verification pipeline, and `adminReviewed`, set when an Administrator manually overrides the AI verdict.
- FR-P5.** Products shall be browsable by category and sub-category.

2.2.4 Order System

- FR-O1.** A Customer shall be able to add and remove items in a cart persisted on the client side.
- FR-O2.** Checkout shall create a single `Order` entity even when the cart spans multiple stores, with one `OrderItem` per product line.
- FR-O3.** Order placement shall trigger a confirmation email through Nodemailer.
- FR-O4.** Each Customer shall be able to consult their personal order history.
- FR-O5.** Each Seller shall be able to consult the orders that include at least one product from their store.

2.2.5 Admin Dashboard

- FR-D1.** The Administrator shall access a dashboard listing pending seller applications, recent activity and platform-wide statistics.

- FR-D2.** The Administrator shall be able to approve or reject seller applications, granting the Seller role on approval.
- FR-D3.** The Administrator shall be able to suspend, reactivate or delete any store, with cascading deletion of its products and orders.
- FR-D4.** The Administrator shall be able to override the `adminReviewed` verdict of any product or store.

2.2.6 AI Verification

- FR-V1.** Once its images have been uploaded, every store and product shall be submitted to an n8n workflow (`cheebo-ai-verify`) that screens each image, together with the listing text, using a hosted multimodal large-language model.
- FR-V2.** The workflow shall return a decision (*approve* or *flag*) with a textual rationale — flagging the entity if *any* of its images is inappropriate — written back to the entity through a callback endpoint.
- FR-V3.** Flagged entities shall be listed in the moderation queue for administrative review.

2.2.7 Featured Content Curation

- FR-C1.** The Administrator shall be able to mark any store or product as *featured*.
- FR-C2.** Featured entities shall be promoted on the landing page.
- FR-C3.** In the absence of featured products for a given tag, the recommendation engine shall fall back to top-selling products of that tag.

2.3 Non-Functional Requirements

The non-functional requirements, summarised in Table 2.1, were prioritised by the professional supervisor during the requirements review and define the qualities the deliverable must exhibit beyond pure functionality.

Table 2.1: Non-functional requirements

Criterion	Description
Performance	The catalogue and store pages must render in under one second on a desktop connection of 10 Mbit/s; API endpoints under the median use case must respond in under 300 ms.
Security	All passwords are hashed by Better-Auth; sessions are stored in HTTP-only, <code>SameSite=Lax</code> cookies; HTTP security headers are set with Helmet; uploads are MIME- and size-validated; every protected route is gated by an <code>AuthGuard</code> and the <code>@Roles()</code> decorator, and mutations additionally enforce object-level ownership in the service layer (a seller may only modify their own store, products and orders). Required secrets are validated at start-up (fail-fast), and the application connects to the database as a least-privilege user rather than root.
Scalability	The backend is stateless and horizontally scalable behind a load balancer; uploads are written to a Docker volume that can be migrated to object storage with no code change.
Availability	The production stack runs under Docker Compose with restart policies; CI/CD deployment is zero-downtime through rolling container replacement.
Usability	The frontend follows the accessible component patterns of Radix UI, is fully responsive, and complies with the WCAG 2.1 AA contrast guidelines for primary text. Public URLs are slug-based and human-readable, improving share-ability and search-engine indexing.
Maintainability	The codebase is split into clearly-bounded NestJS modules, the schema is versioned through Prisma migrations, and the infrastructure is reproducible through Terraform. Storefront theming is driven entirely by CSS variables on a single scoped wrapper, so a per-store re-skin requires no component-level changes.
Observability	Application logs are emitted to <code>stdout</code> and aggregated by Docker; the chat assistant offers a queryable view of the database for operational diagnostics.
Internationalisation	The interface is currently English-only; copy is centralised to enable future translation without code changes.

2.4 Use Case Diagrams

The use cases below were derived directly from the functional requirements in the previous section. They are presented from the most abstract (global) to the most granular (per actor), so that the reader can zoom from the platform-level overview into each role’s specific interactions.

2.4.1 Global Use Case Diagram

Figure 2.1 groups the principal use cases of Cheebo around the three actors. Two dotted dependencies illustrate the cross-actor flows on which the rest of the chapter relies: a seller application *triggers* an administrative review (**«triggers»**), and product creation is automatically *verified by AI* (**«verified by AI»**).

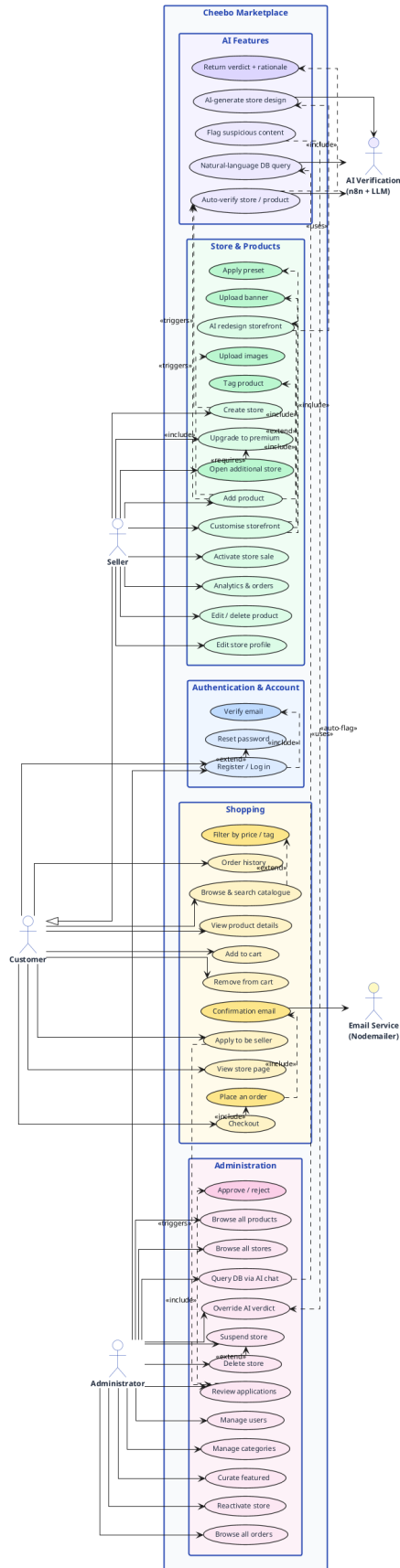


Figure 2.1: Global use case diagram (detailed)

2.4.2 Detailed Use Cases — Customer

The Customer view in Figure 2.2 expands the shopping path from registration to order placement. Registration «includes» email verification, and checkout «includes» both order placement and an authenticated session.

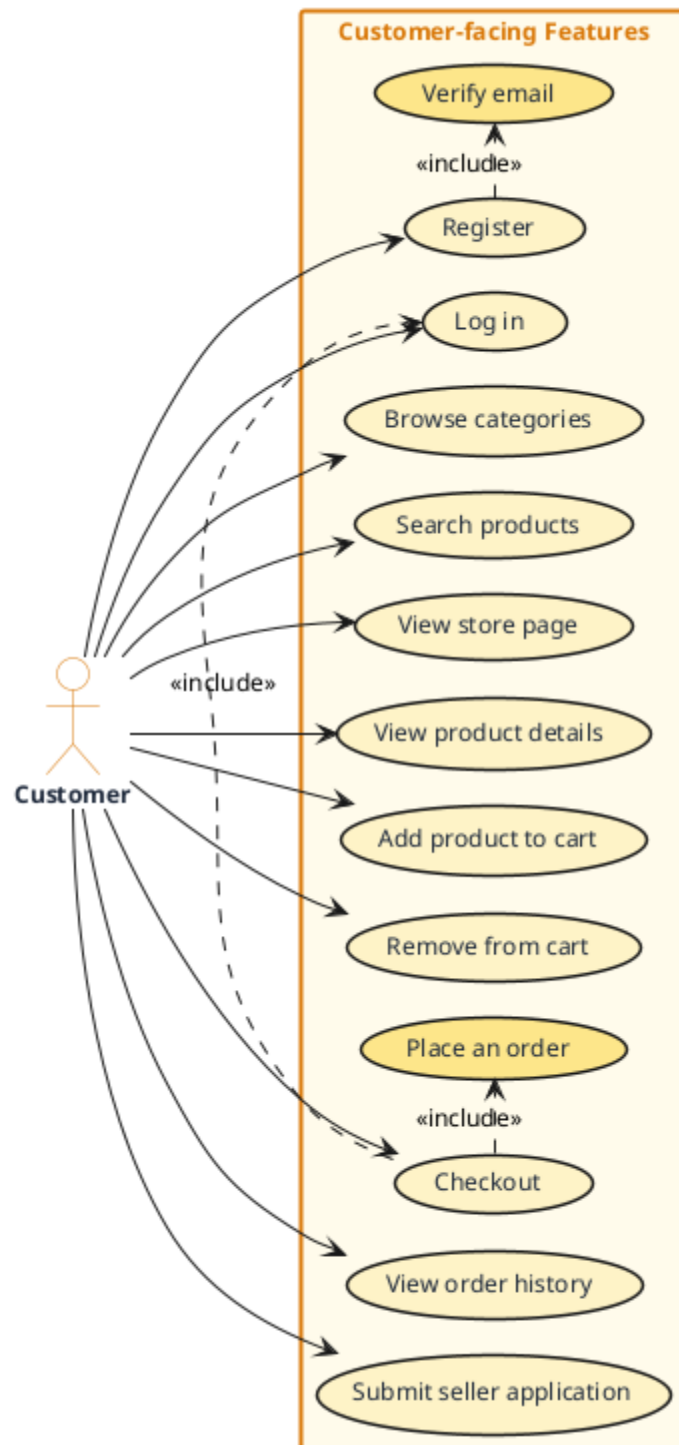


Figure 2.2: Customer use cases

2.4.3 Detailed Use Cases — Seller

Figure 2.3 shows that store creation depends on a prior approved seller application, and that opening additional stores depends on having activated the premium tier — the two gating conditions that govern the seller funnel.

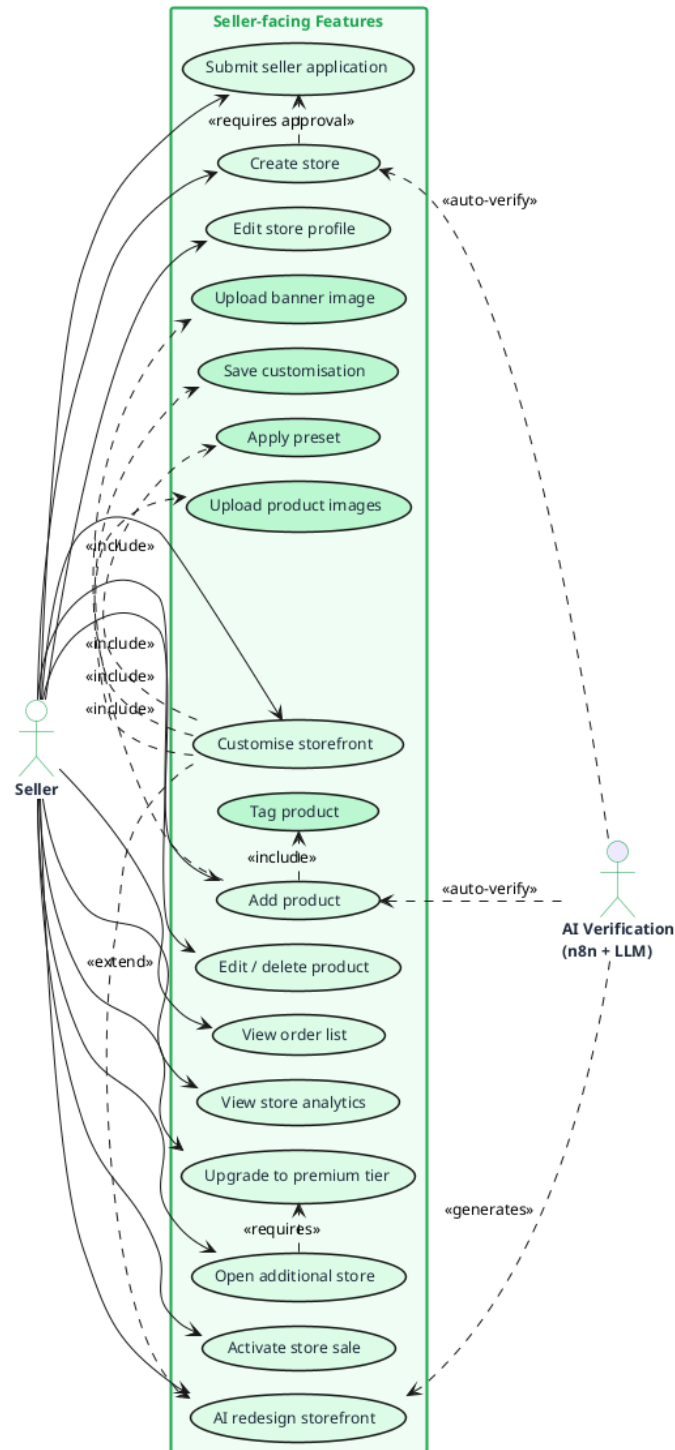


Figure 2.3: Seller use cases

2.4.4 Detailed Use Cases — Administrator

Figure 2.4 highlights the AI verification subsystem as a secondary actor that injects *auto-flag* events into the administration queue. The Administrator remains the final authority on every override, suspension and deletion.

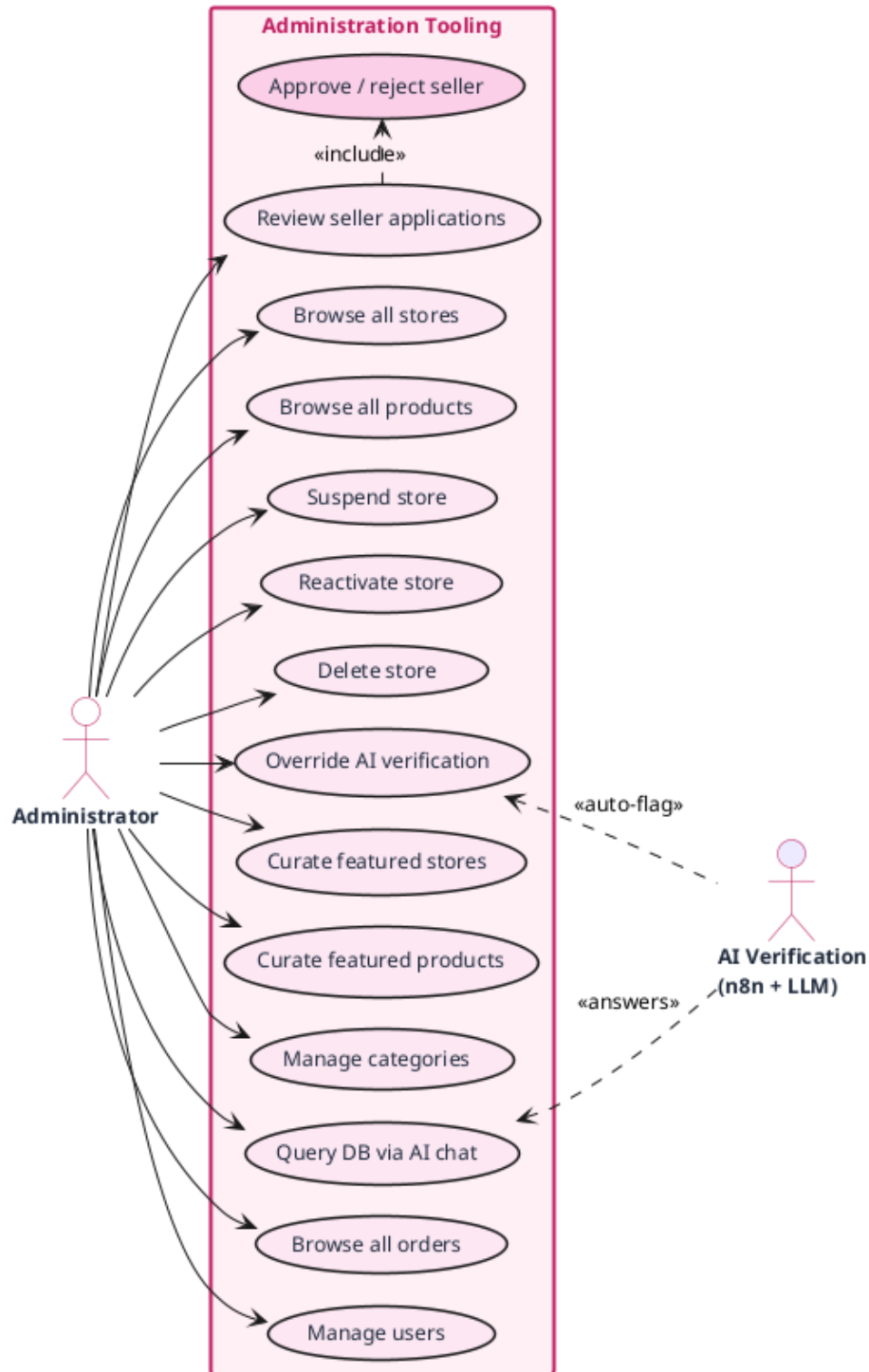


Figure 2.4: Administrator use cases

2.5 Sequence Diagrams

Three flows are particularly load-bearing for the architecture of the system: authentication, order placement, and AI-driven product verification. Each is described below with a UML sequence diagram generated from PlantUML sources stored under `diagrams/` in the project repository.

2.5.1 Registration, Email Verification and Login

Figure 2.5 traces the authentication flow. Registration creates a `User` row with `emailVerified=false` and triggers a Nodemailer message containing a one-time token; the user activates the account by clicking the link, which flips the flag and allows them to log in. Both Better-Auth and the NestJS layer participate, with sessions materialised as HTTP-only cookies returned by the API.

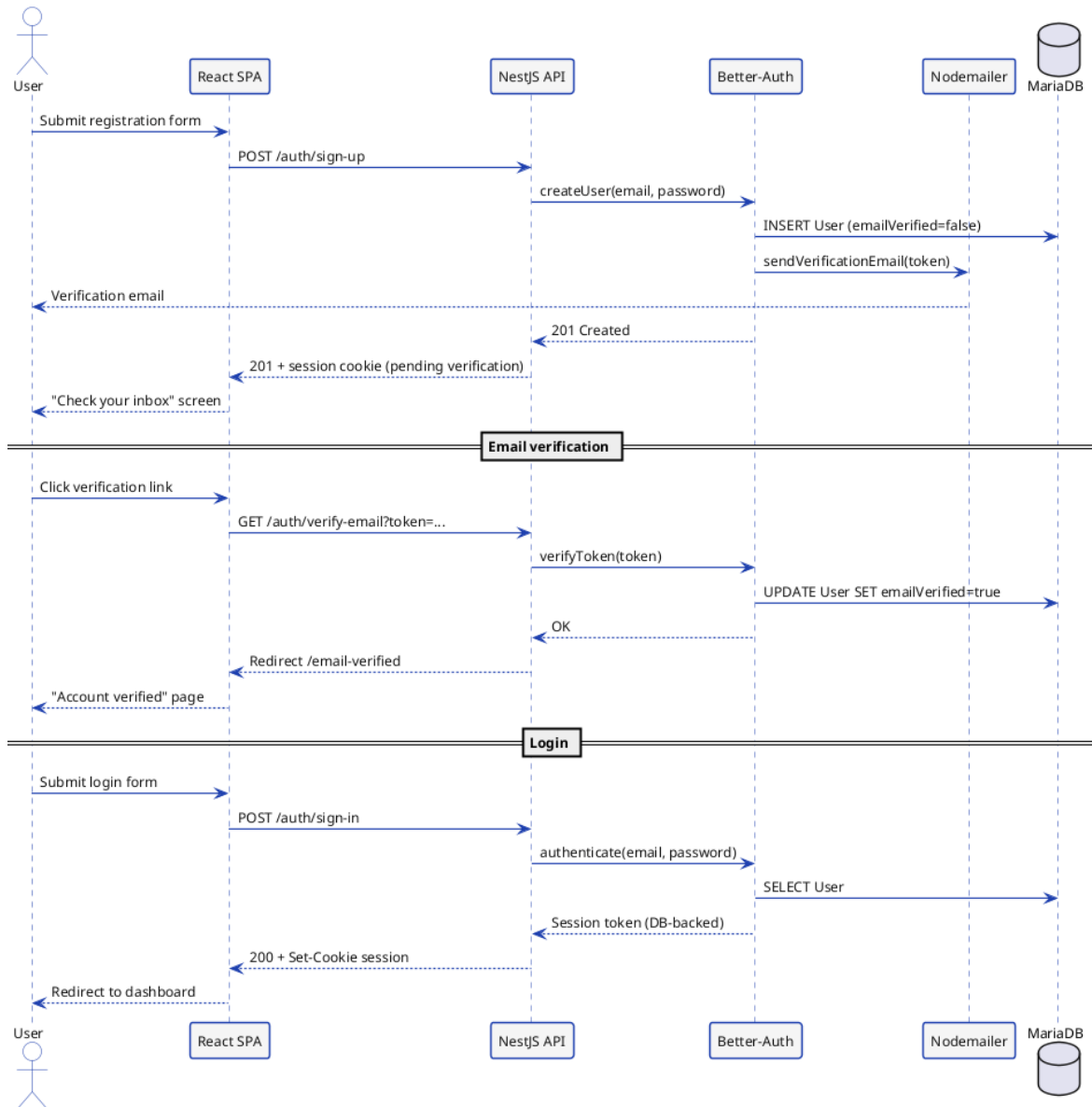


Figure 2.5: Sequence: registration, email verification and login

2.5.2 Order Placement

Figure 2.6 describes the checkout path. The cart is held client-side in a Zustand store and posted to the API as a single payload. The **AuthGuard** validates the session before the Order module persists the **Order** row and delegates the creation of line items to the OrderItems module; a confirmation email is sent before the response returns to the SPA, which then clears the cart store and redirects to the success page.

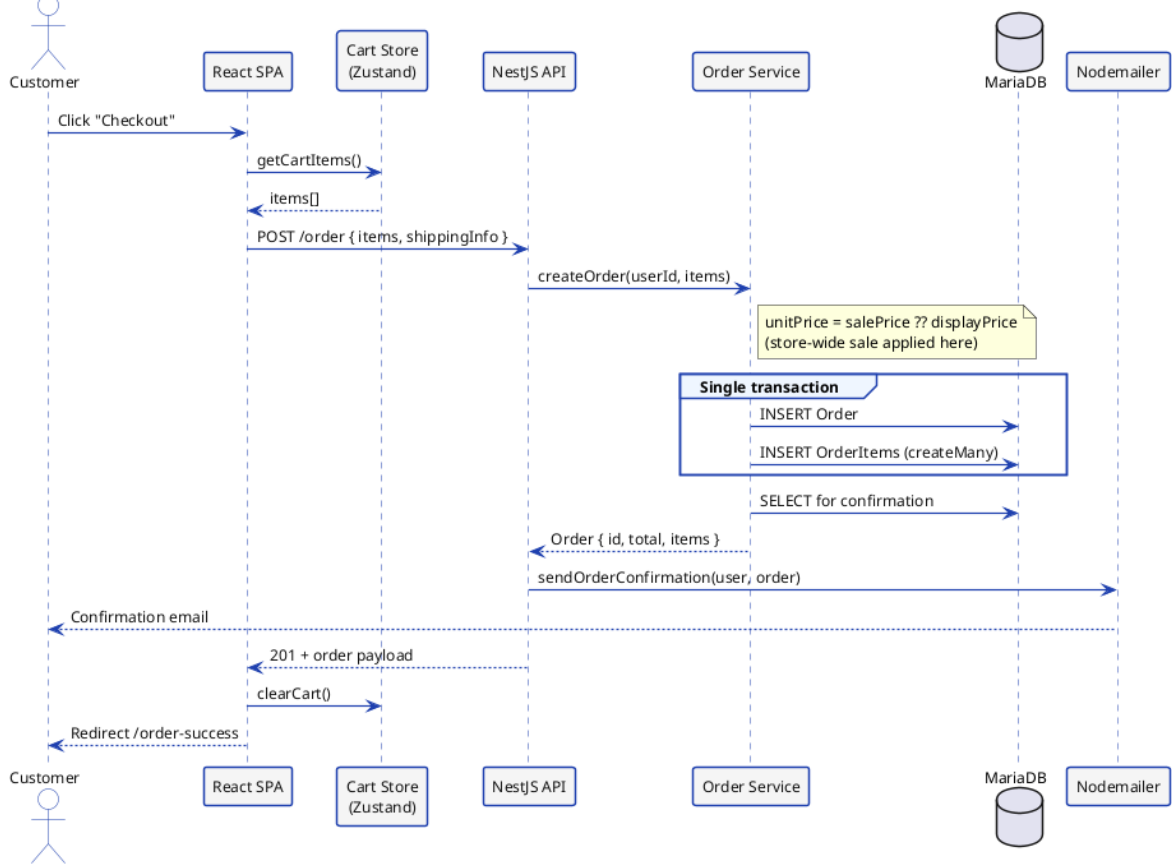


Figure 2.6: Sequence: order placement

2.5.3 Product Verification (AI + Administrator)

Figure 2.7 shows the dual-track verification process. Verification is triggered only *after* the seller has uploaded the listing's images — through a dedicated **submit-verification** endpoint — so the screening always operates on files that exist on disk. The backend then fires the **cheebo-ai-verify** webhook on n8n, which downloads each image and submits it, with the listing text, to the Gemini vision model; the entity is flagged if *any* image violates the marketplace rules. The decision flows back through a call-back endpoint (**PATCH /{type}/{id}/ai-review**) and updates the **aiReviewed** flag and **verificationStatus**. The **alt** block at the bottom of the diagram captures the two outcomes: automatic approval (badge shown to the customer) and flagging (entry in the moderation queue, manual override by the Administrator).

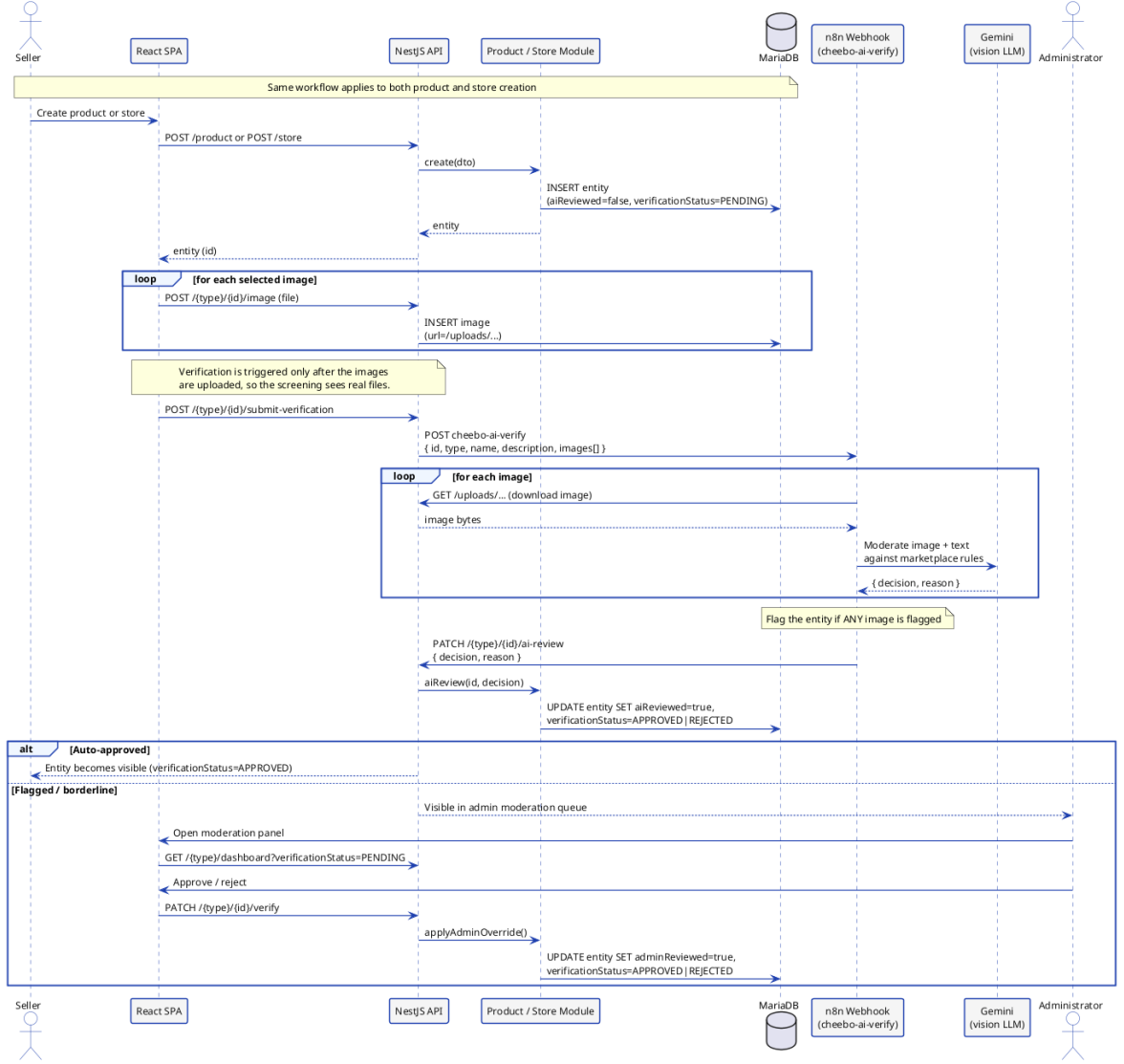


Figure 2.7: Sequence: product verification (AI and administrator)

2.6 Modelling Language

This project adopts the **Unified Modelling Language (UML)** to formalise both the static structure and the dynamic behaviour of the system. UML provides a standardised set of diagrams that represent software systems in a language-independent and tool-independent way. Three diagram types are used throughout this report:

- **Use Case diagrams** — describe the interactions between actors (Customer, Seller, Administrator) and the system, identifying the boundaries of the platform’s functionality.
- **Sequence diagrams** — model the temporal exchanges of messages between system components for the three load-bearing flows: authentication, order placement, and AI-driven product verification.

- **Class diagrams** — represent the main domain entities, their attributes, and their associations, providing the structural blueprint from which the Prisma schema is derived.

All diagrams are authored in PlantUML (.puml files) and rendered to PNG via the PlantUML CLI, keeping the diagram sources version-controlled alongside the application code under `diagrams/`.

2.7 Project Backlog

2.7.1 Project Roles

- **Supervisor / stakeholder:** Mr. Mohammed Aziz Chibani (NeuralBey)
- **Developer:** Nadim Jebali

2.7.2 MoSCoW Priority Legend

Each user story carries a **MoSCoW** priority and a **complexity** estimate, defined in Table 2.2.

Table 2.2: MoSCoW priority and complexity legend

MoSCoW Priority		
Must	<i>Must have</i>	Essential feature, required for the MVP.
Should	<i>Should have</i>	Important but not blocking.
Could	<i>Could have</i>	Desirable, included if time permits.
Won't	<i>Won't have</i>	Out of scope for this version.
Complexity		
1	Simple	Straightforward implementation, minimal effort.
2	Moderate	Average complexity, moderate effort.
3	Complex	Significant effort, elaborate logic.
5	Very complex	High effort, advanced technical challenge.

2.7.3 Product Backlog

Table 2.3 presents the product backlog structured as user stories following the template: “As a <role>, I want <action> so that <benefit>”. The columns **P** and **Cx** indicate respectively the MoSCoW priority and the estimated complexity.

Table 2.3: Product backlog — user stories with MoSCoW priority and complexity

Feature	ID	User Story	Priority	Cx
F1 Authentication	US01	As a visitor, I want to create an account with my email address so that I can access the platform.	Must	2
	US02	As a visitor, I want to receive a verification email so that I can activate my account securely.	Must	2
	US03	As a user, I want to sign in with my credentials so that I can access my personalised dashboard.	Must	1
	US04	As a user, I want to sign out so that I can protect my account on a shared device.	Must	1
F2 Store Management	US05	As a seller, I want to create a store with a name, description and logo so that customers can find and recognise my brand.	Must	2
	US06	As a seller, I want my store URL to use a human-readable slug so that it is easy to share.	Must	2
	US07	As a seller, I want to customise my storefront across seven sections (theme, announcement bar, banner, header, product grid, sidebar, footer) through a WYSIWYG visual editor so that I can see changes immediately and style my store to reflect my brand.	Should	5
	US08	As a seller, I want to apply a preset to my store so that I can get a professional look quickly.	Should	2
	US09	As a premium seller, I want to operate multiple stores so that I can segment my product offerings.	Should	2

Continued on next page

Feature	ID	User Story	Priority	Cx
	US34	As a seller, I want to activate a store-wide sale with a percentage discount so that all my products display discounted prices and a sale badge automatically across the storefront and search results.	Should	2
F3 Product Management	US10	As a seller, I want to create, edit and delete products so that I can keep my catalogue up to date.	Must	2
	US11	As a seller, I want to upload multiple product images so that customers can see my products clearly.	Must	2
	US12	As a seller, I want to assign tags to my products so that the recommendation engine can surface them.	Should	1
	US13	As a customer, I want to browse products by category so that I can discover relevant items.	Must	1
F4 Order System	US14	As a customer, I want to add products to a cart so that I can purchase multiple items at once.	Must	2
	US15	As a customer, I want to check out across multiple stores in a single order so that I do not need separate transactions.	Must	3
	US16	As a customer, I want to receive a confirmation email after placing an order so that I have a record of my purchase.	Must	1
	US17	As a seller, I want to view orders containing my products so that I can prepare and fulfil them.	Must	2
F5 Administration	US18	As an admin, I want to review seller applications so that I can approve legitimate merchants.	Must	2
	US19	As an admin, I want to suspend or delete any store so that I can enforce marketplace rules.	Must	2

Continued on next page

Feature	ID	User Story	Priority	Cx
	US20	As an admin, I want to curate featured stores and products so that the landing page promotes quality content.	Should	1
	US21	As an admin, I want to manage categories and sub-categories so that the catalogue stays organised.	Must	1
F6 AI Verification	US22	As the system, I want to automatically verify every new store and product via an LLM so that low-quality content is flagged without manual effort.	Should	3
	US23	As an admin, I want to override any AI verdict so that I remain the final authority on moderation decisions.	Must	1
	US24	As a customer, I want to see an AI-verified badge on trusted products so that I can shop with confidence.	Should	1
	US35	As a seller, I want to regenerate my entire storefront design using a natural-language prompt sent to an AI agent so that I can obtain a professionally styled store without manual customisation.	Could	3
F7 Premium Tier	US25	As a seller, I want to subscribe to a premium plan so that I can unlock advanced storefront features.	Should	3
	US26	As a premium seller, I want access to all customisation controls so that I can fully personalise my store appearance.	Should	3
	US27	As the system, I want to preserve a seller's existing premium customisation after subscription expiry so that their store continues to look as designed.	Could	2
F8 CI/CD & Deployment	US28	As a developer, I want every service to run in a Docker container so that the environment is identical across development and production.	Must	2

Continued on next page

Feature	ID	User Story	Priority	Cx
	US29	As a developer, I want the backend and front-end images to be automatically built and pushed to Docker Hub on every push to main so that deployments are always up to date.	Must	2
	US30	As a developer, I want the production droplet to be provisioned automatically via Terraform so that the infrastructure is reproducible and version-controlled.	Should	3
	US31	As a developer, I want the application to be deployed to DigitalOcean via SSH on every push to main so that updates reach production without manual intervention.	Must	3
	US32	As a developer, I want all secrets and environment variables to be managed through GitHub Actions secrets so that no credentials are stored in the repository.	Must	1
	US33	As a developer, I want the domain DNS A records to be updated automatically to the new droplet IP via the DigitalOcean Terraform provider so that the application is always reachable at <code>nadimjebali.engineer</code> .	Should	2

Key Takeaways

- Three actors — Customer, Seller, Administrator — are modelled as roles on a single **User** table; an account can be promoted across roles without re-registering.
- Functional requirements are grouped into seven domains (authentication, store, product, order, admin dashboard, AI verification, featured curation), each mapped one-to-one with a backend NestJS module.
- The non-functional contract privileges *security*, *performance* and *maintainability* as first-order qualities, with concrete targets stated in Table 2.1.
- The Product Backlog comprises 35 user stories across 8 features, prioritised with MoSCoW and estimated for complexity.

Chapter Conclusion

This chapter formalised the requirements of the Cheebo platform. The three system actors were identified and their responsibilities delimited. Functional requirements were grouped into seven domains — authentication, store management, product management, orders, administration, AI verification, and featured content curation — and expressed both as structured requirement statements and as a user-story Product Backlog with MoSCoW priorities and complexity estimates. Non-functional constraints were captured in a consolidated table. UML use-case and sequence diagrams illustrated the system boundaries and the three load-bearing flows. The following chapter builds on these specifications to present the system design and architecture.

Chapter 3 Design and Architecture

This chapter translates the requirements identified in Chapter 2 into a concrete system design. It opens with a global three-tier view, then drills down into the NestJS module layout, the React SPA structure, the Docker Compose topology, the database schema, the REST API contract, the three n8n workflows that carry the platform’s AI features, and finally the UML class model that unifies all the design decisions.

3.1 Global Architecture

3.1.1 3-Tier Architecture Overview

Cheebo follows a classic **three-tier architecture** that separates the user interface (presentation), the business logic (application), and the persistent data (data) into three independent layers. This separation is the structural foundation on which every other design decision in this chapter builds: it lets each tier evolve at its own pace, scales the backend horizontally without touching the frontend, and keeps the database schema decoupled from the public REST contract.

Figure 3.1 shows the three tiers and the auxiliary components that orbit them. End users reach the platform exclusively over HTTPS, terminated by a **Caddy** reverse proxy that obtains and renews its TLS certificate automatically from Let’s Encrypt. Caddy forwards the decrypted traffic to an internal **Nginx** container, which serves the static React bundle and forwards every `/api/*` request to the NestJS API container over the Docker bridge network. The NestJS application implements the entire business logic — authentication, catalogue management, order processing, moderation — and persists state to a single **MariaDB 11** [18] instance through the **Prisma** ORM [9]. File uploads are handled by **Multer** and stored on a Docker volume; transactional emails are dispatched through **Nodemailer** over SMTP.

Sitting alongside the backend rather than inside it, **n8n** hosts the three AI workflows (verification, database chat, AI redesign). The backend reaches n8n via internal HTTP webhooks; n8n in turn calls the LLM providers (Groq and Gemini) over the public internet. This separation isolates AI orchestration — prompt templates, model selection, retry logic — from the core business logic, so it can be modified through the n8n editor without redeploying the API.

Figure 3.1 summarises the topology. End users on the left reach Nginx, which serves

the SPA and forwards API traffic to the NestJS backend; the backend in turn talks to MariaDB, Nodemailer and Multer, and exchanges webhooks with n8n on the right, which itself calls the LLM providers.

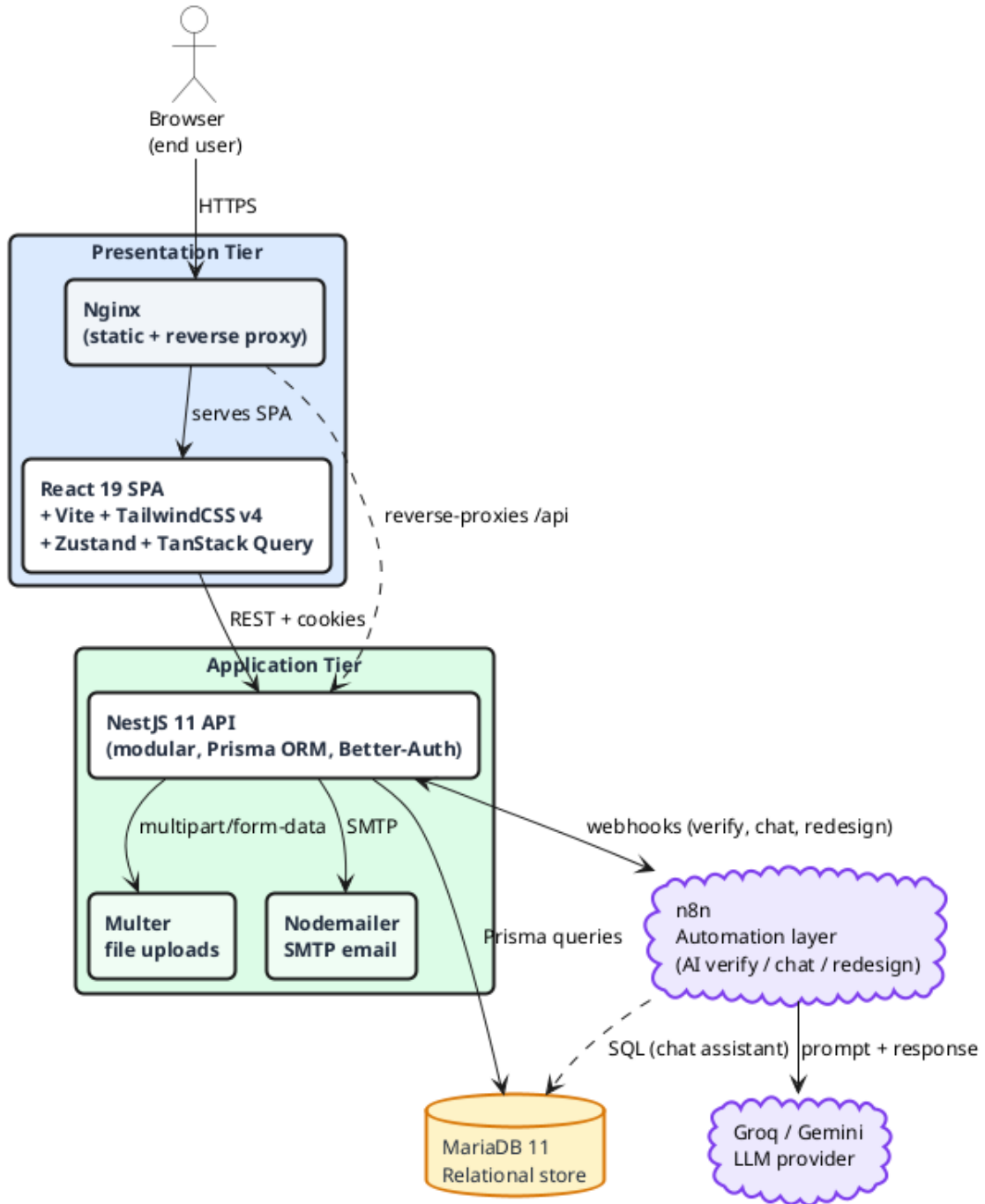


Figure 3.1: Global system architecture (three tiers + n8n automation layer)

3.1.2 n8n as an Automation Layer

n8n [22] was introduced as a deliberate architectural choice rather than an ad-hoc tool. Three properties made it the right fit for Cheebo’s AI features:

1. **Workflow-as-data.** Every AI feature is expressed as a JSON workflow that can be exported, version-controlled in the repository (`n8n-workflows/`), and re-imported on any n8n instance. The workflow becomes a first-class artefact of the system, reviewed alongside the application code.
2. **Provider abstraction.** The NestJS backend never imports an LLM SDK. Switching from Gemini to Groq, or adding a new provider for a specific node, is a configuration change inside the n8n editor with no NestJS recompilation. This decoupling also keeps API keys out of the backend container.
3. **Native webhook orientation.** n8n exposes any workflow as a webhook endpoint (`/webhook/<name>`) and supports synchronous *Respond to Webhook* for request/response flows and asynchronous patterns for fire-and-forget jobs. This matches exactly the three integration patterns Cheebo needs: asynchronous (verification fires on entity creation and writes back later), synchronous (AI redesign returns the `StoreCustomization` to the seller's editor in the same call), and conversational (the database chat assistant streams messages between the admin and the LLM).

The trade-off accepted in exchange for these benefits is one additional container in the production stack and one additional persistence volume (`n8n_data`) to back up. Both are justified by the maintainability gains.

3.2 Detailed Technical Architecture

3.2.1 NestJS Modular Architecture

The backend is structured as a set of **feature modules** [6], each encapsulating its own controller, service, DTOs, and Prisma queries. Every module declares its own `@Module()` decorator and exports the providers consumed by sibling modules; this strict separation is what allows the dependency graph in Figure 3.2 to remain acyclic in a system that hosts almost twenty modules.

Cross-cutting modules. Four modules are imported by virtually every feature: `PrismaModule` exposes the singleton Prisma client; `AuthModule` provides the `AuthGuard` and the `@Roles()` decorator that gate every protected route; `NotificationModule` centralises in-app notifications dispatched through the `EventEmitter`; `SettingsModule` stores platform-wide configuration that administrators can update without redeploying.

Feature modules grouped by domain.

- **User and application:** `UserModule` and `SellerApplicationModule` handle profile management and the seller onboarding workflow.

- **Storefront:** `StoreModule`, `StoreStatusLogModule`, `ProductModule`, `ProductImageModule`, and `ProductTagModule` cover everything a seller owns.
- **Catalogue:** `CategoryModule` and `SubCategoryModule` maintain the taxonomy that the product grid filters by.
- **Commerce:** `OrderModule` and `OrderItemsModule` create orders and persist line items with the discounted unit price computed at checkout.
- **Discovery and analytics:** `HomeModule` powers the landing page (featured stores, featured products, tag-based recommendations); `AnalyticsModule` computes per-store revenue and visitor metrics.
- **AI integration:** `ChatModule` relays administrator messages to the database chat workflow; `N8nModule` centralises the webhook calls used by both the verification pipeline and the AI redesign feature.

This layout maps one-to-one onto the functional requirement domains of Section 2.2, which makes it easy to trace a requirement to a single module and vice versa.

Figure 3.2 visualises the resulting module catalogue. The cross-cutting providers are shown in blue at the top, the domain-specific feature modules are grouped into five coloured packages, and the AI integration package on the right collects the modules that exchange webhooks with n8n.

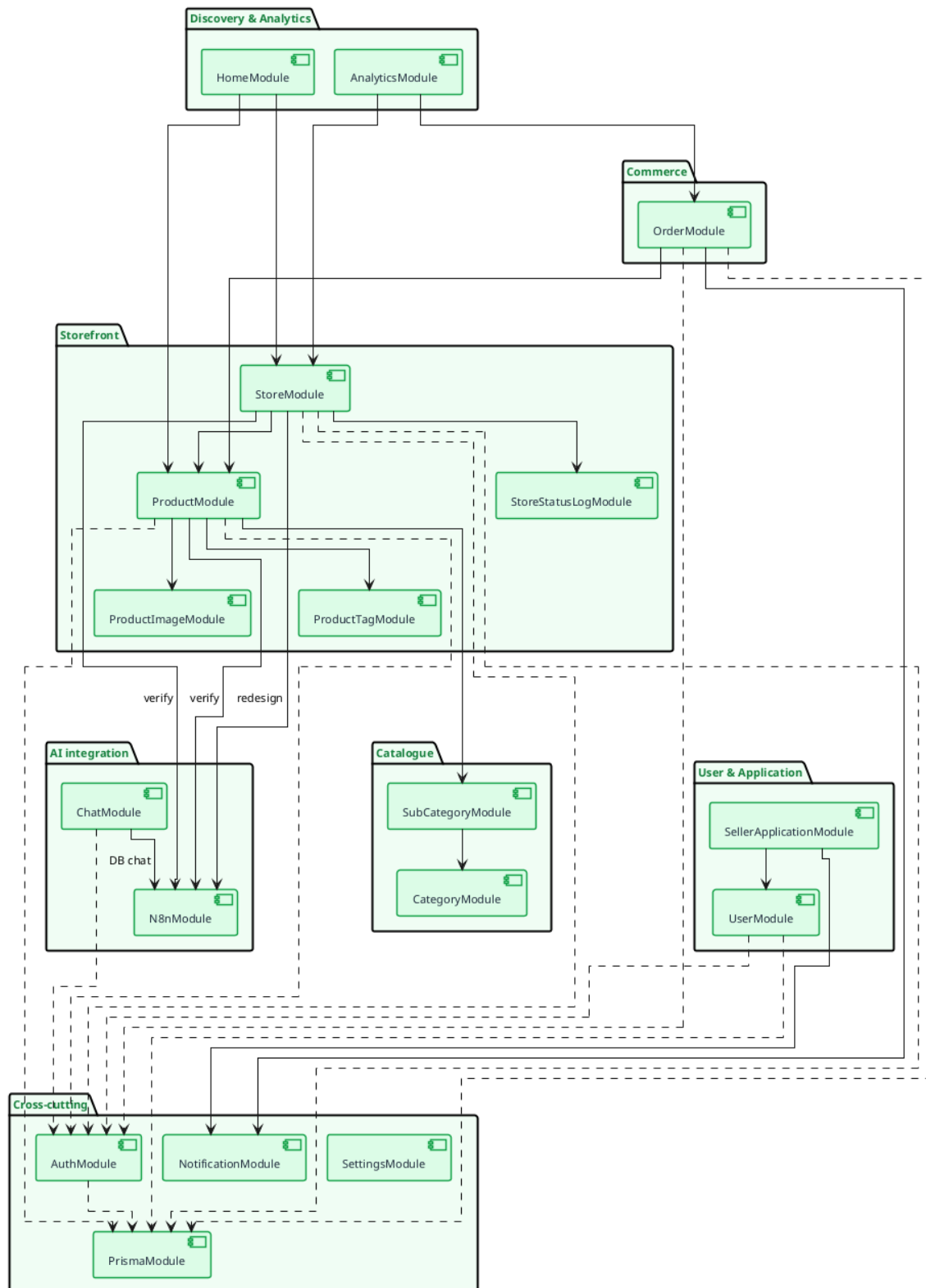


Figure 3.2: NestJS modular architecture: groups of feature modules and their dependencies

3.2.2 React SPA Architecture

The frontend is a **Single-Page Application** built with React 19 [7] and bundled by **Vite** [8]. The codebase under `frontend/src/` is split into seven top-level folders, each playing a clearly defined role:

- `pages/` — one file per route, including the public catalogue (`Home`, `ProductsPage`, `StorePage`, `ProductPage`), the checkout flow (`CartPage`, `CheckoutPage`, `OrderSuccessPage`), authentication (`Login`, `Register`, `EmailVerified`), and a nested `dashboard/` subtree split by role (seller, admin).
- `components/` — reusable building blocks (`ProductCard`, `StoreCard`, `SearchBar`, `AiChatFab`, and the `ui/` folder of `shadcn/ui` primitives).
- `api/` — one TypeScript file per backend module (`store.api.ts`, `product.api.ts`, ...) that wraps the typed Axios client and exposes a single object of named functions, mirroring the NestJS layout.
- `stores/` — Zustand stores for client-side state (`auth.store`, `cart.store`, `admin.store`, `category.store`, `customization.editor.store`).
- `hooks/` — TanStack React Query hooks that wrap the API layer, providing caching, deduplication, and background refetching.
- `lib/` — framework-agnostic utilities (Axios instance, customisation hydration, error formatter).
- `types/` and `constants/` — domain types shared with the backend DTOs and constant tables (roles, statuses, MIME lists).

State management follows a strict two-tier convention: **server state** (anything originating from the API) lives in **TanStack Query** caches keyed by the API path; **client-only state** (cart contents, theme preference, draft store customisation in the WYSIWYG editor) lives in **Zustand** stores. This division eliminates the classic React anti-pattern of duplicating server data into a Redux store and then fighting cache invalidation.

The storefront editor itself is a separate sub-architecture built on **Craft.js** [14]: the canvas, the section palette, and the inspector panel are wired around a single `<Editor>` provider, and a Zustand store mirrors the Craft editor state so that the *Save* button can submit a stable JSON payload to the backend.

3.2.3 Docker Compose Services Diagram

The full application stack is defined in a single `docker-compose.yml` file at the root of the monorepo. Five services are declared (Figure 3.3):

- **db** — official `mariadb:11` image with a named volume `db_data` and a health-check that gates the backend’s start-up.
- **backend** — the pre-built `sirvinny/cheebo-backend:latest` image, configured from environment variables (database credentials, Better-Auth secret, SMTP settings, n8n webhook URLs, premium-tier limits) and mounting an `uploads` volume for stored images.
- **frontend** — the pre-built `sirvinny/cheebo-frontend:latest` image (Nginx serving the React bundle). It exposes no host port and is reached only through the Caddy proxy.
- **caddy** — the official `caddy:2-alpine` image, the public entrypoint of the whole stack. It is the only service that publishes host ports (80 and 443), terminates HTTPS with an automatically issued Let’s Encrypt certificate, and reverse-proxies to the internal Nginx frontend. Its certificate and state persist in the `caddy_data` and `caddy_config` volumes.
- **n8n** — the official `n8nio/n8n:latest` image with a named volume `n8n_data` preserving workflows and credentials across restarts.

All services share a single Docker bridge network that is created implicitly by Compose; only Caddy’s ports are published. The frontend, backend, database, and n8n are never reachable directly from the public internet — the backend’s URL is `http://backend:3000` from inside the bridge network, and the database is reachable as `db:3306`. This single-host topology is intentional: the production droplet specifications (Section 5.4.1) size for it, and the architecture is straightforward to migrate to a managed database or a Kubernetes deployment later.

Figure 3.3 shows the resulting topology on the production host: the containers sit on a shared Docker bridge network, only Caddy publishes ports to the public internet, and each stateful service writes to its own named volume.

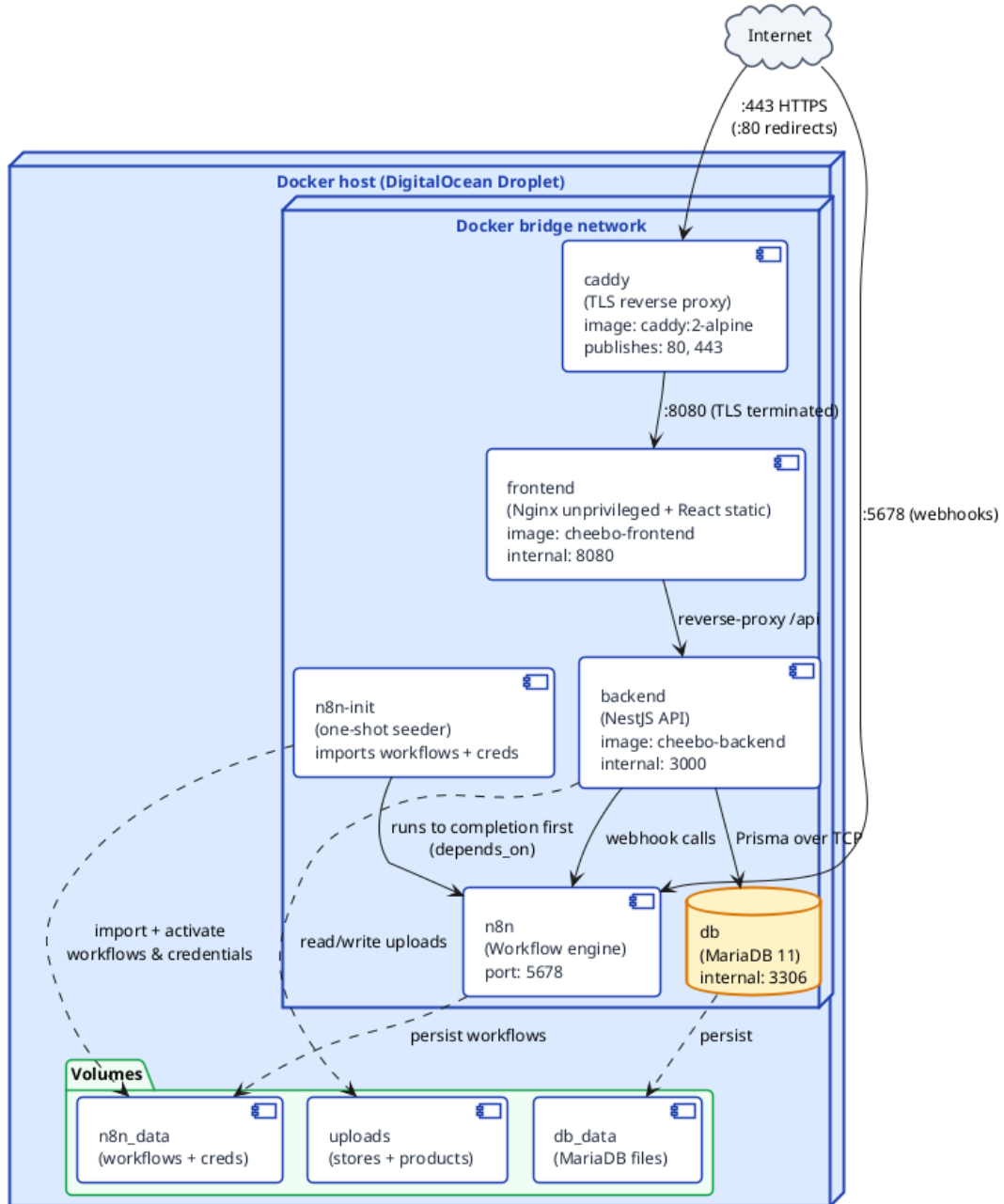


Figure 3.3: Docker Compose services on the production host

3.3 Database Design

3.3.1 Entity-Relationship Diagram

Figure 3.4 presents the entity-relationship diagram of the Cheebo database. The schema is organised around the **User** entity, which acts as the entry point for three independent branches: authentication (**Session**, **Account**, **Verification**), commerce (**Order** and through it **OrderItems**), and storefront ownership (**SellerApplication** and **Store**). Each **Store** in turn owns its own subtree of **Product**, **ProductImage**, **ProductTag** and **StoreStatusLog** records, while the **Category/Subcategory** hierar-

chy lives orthogonally and is referenced by every product.

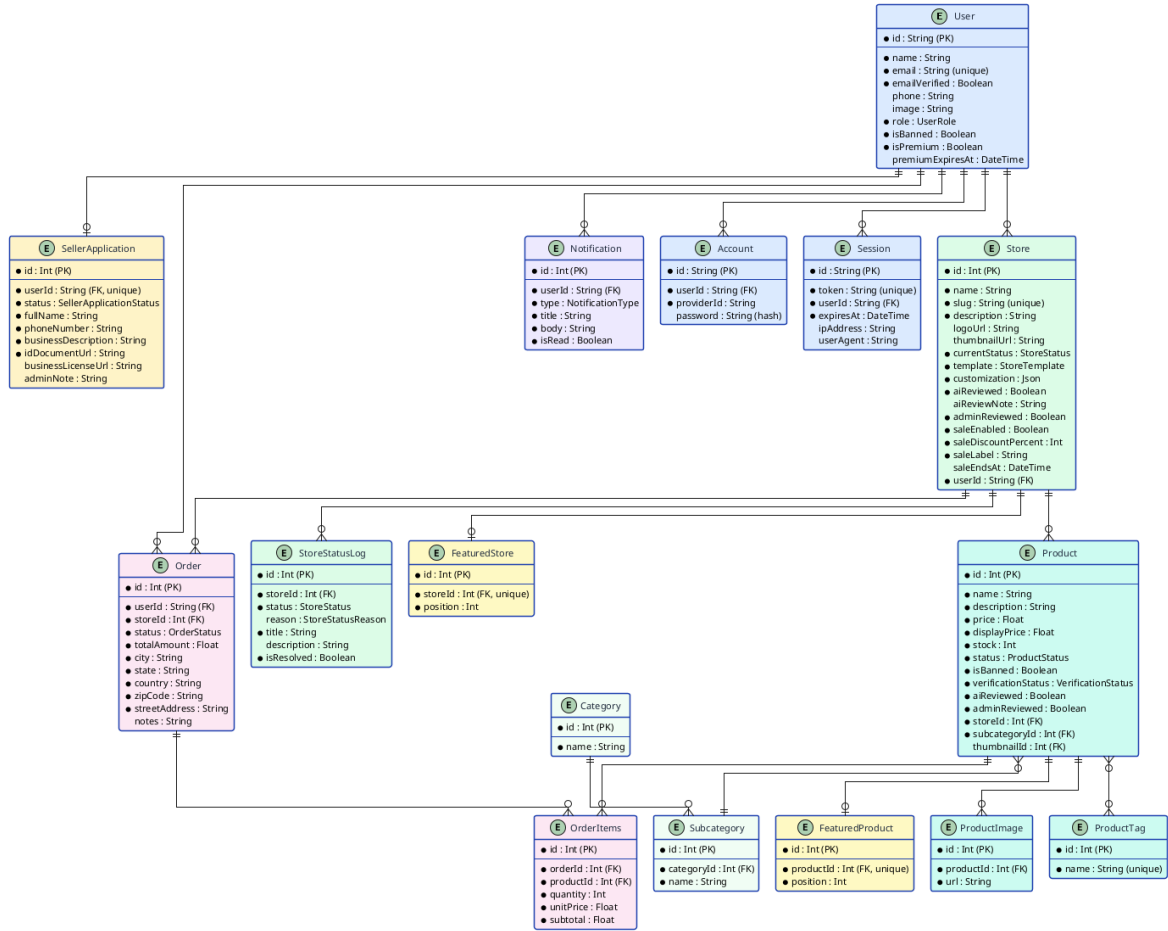


Figure 3.4: Entity-Relationship diagram of the Cheebo database

3.3.2 Prisma Schema Overview

The Prisma schema is split into eighteen files under `backend/prisma/schema/`, one per logical entity, plus an `enums/` folder gathering every enumeration in a single place. This split takes advantage of the `multi-file schema` preview feature introduced in Prisma 5 and keeps each file under one screen, which makes diff review on pull requests far easier than a single multi-thousand-line schema.

- **Authentication** (`user.prisma`, `auth.prisma`) — four models: `User`, `Session`, `Account`, `Verification`. The non-`User` tables are managed entirely by Better-Auth and are exposed to Prisma read-only.
- **Storefront** (`store.prisma`, `store-status-log.prisma`, `store-template.prisma`) — the `Store` model carries a JSON `customization` column that holds the Craft.js editor state, plus the four sale fields (`saleEnabled`, `saleDiscountPercent`, `saleLabel`, `saleEndsAt`).

- **Product catalogue** (`product.prisma`, `product-image.prisma`, `product-tag.prisma`, `category.prisma`, `subcategory.prisma`) — five models capturing the catalogue, with two-level category taxonomy and many-to-many tags via an implicit join table.
- **Commerce** (`order.prisma`, `order-items.prisma`) — two models with the unit price persisted on each line so that subsequent price changes never alter historical orders.
- **Curation** (`featured.prisma`) — two models (`FeaturedStore`, `FeaturedProduct`) with a `position` integer driving the landing-page ordering.
- **Workflow** (`seller-application.prisma`, `notification.prisma`, `setting.prisma`) — application reviews, in-app notifications, and platform-wide settings respectively.

The complete schema, including indexes and cascade rules, is reproduced in Appendix [A](#).

3.3.3 Explanation of Key Relationships

A handful of relationships carry most of the load and deserve a dedicated note.

User → Store → Product (1:N:N). A `User` with the `SELLER` role can own one store on the free tier and several on the premium tier; each store owns an unbounded number of products. The chain is materialised by two foreign keys (`Store.userId`, `Product.storeId`) both indexed. The cascading-delete rule on `Product` ensures that suspending or deleting a store cleanly removes the products it contained.

User ↔ SellerApplication (1:0..1). A user has at most one open seller application at any time. The `userId` column is `@unique`, which prevents duplicate submissions at the database level rather than at the service layer. The `Cascade` delete rule on the FK ensures that deleting a user automatically purges the application row.

Order → Store and Order → OrderItems. A single multi-store checkout creates **one Order per store** (so the seller has a clean per-store view) but a single shopping flow for the customer. Each `OrderItems` row carries the unit price that was visible at checkout time — this is the discounted price when the store had an active sale, computed by the `Product` service before the order is persisted. Subsequent price changes never rewrite history.

Product ↔ ProductTag (M:N). Prisma’s *implicit* many-to-many relation is used here: Prisma manages an internal join table `_ProductTags` that does not appear in the schema file, which keeps the model lean while still allowing efficient queries by tag for the recommendation engine.

Verification flags on Store and Product. Both entities carry two independent boolean flags: `aiReviewed` (set automatically by the n8n verification workflow) and `adminReviewed` (set when an administrator manually overrides the AI verdict). This dual-flag design preserves the audit trail of who — machine or human — approved a piece of content, and lets the moderation queue filter on `aiReviewed = false AND adminReviewed = false` to find genuinely pending items.

Sale fields on Store. The four sale fields live on **Store** rather than on a separate **Sale** entity. This denormalisation is deliberate: sales are always store-wide, only one is active at a time, and the fields are read on every product query. A separate join would have added a query without buying any expressive power.

Payment fields on Order. Because checkout is confirmed asynchronously by Stripe, the **Order** entity carries its own payment state rather than overloading the fulfilment `status`. A `PaymentStatus` enum (`UNPAID`, `PAID`, `FAILED`) records where the charge stands, `stripePaymentIntentId` links the order back to the Stripe `PaymentIntent` that covers it, and `paidAt` stamps the moment payment succeeded. A single intent can cover several orders of a multi-store cart, so that column is a *non-unique* index rather than a unique key. An order is created `UNPAID` and only a verified Stripe webhook — never the client — moves it to `PAID`, as detailed in Section 4.2.6.

3.4 API Design

3.4.1 REST API Design Principles

The Cheebo backend exposes a single **REST API** [4] over JSON that the React SPA consumes through a typed Axios client. Six principles guided every route declaration:

1. **Resource-oriented URLs.** Routes name nouns (`/store`, `/product`, `/order`) and use sub-paths for actions on a specific resource (`/store/:id/sale`, `/store/:id/ai-redesign`). Verbs in URLs are avoided.
2. **HTTP verb semantics.** `GET` for safe reads, `POST` for creation, `PATCH` for partial updates, `PUT` for full replacements, `DELETE` for removal. Status codes follow the same convention — `201 Created` on `POST`, `204 No Content` on `DELETE`, `400` for validation errors, `401` for unauthenticated access, `403` for role violations [5].
3. **Validated DTOs.** Every body- or query-bearing endpoint declares a `class-validator` DTO with `forbidNonWhitelisted: true`, so any extra field in the payload is rejected at the framework layer before the controller handler executes.
4. **Deny-by-default access control.** A single `AuthGuard` is registered globally (as `APP_GUARD`), so every route requires a valid session unless it is explicitly marked

`@Public()` (catalogue browsing, store pages). Role-restricted routes add the `@Roles(...)` decorator; the guard returns 401 for an unauthenticated caller and 403 for an authenticated caller who lacks the required role.

5. **Cursor- and page-based pagination.** List endpoints accept `page` and `limit` query parameters and always return a uniform `PaginatedResult<T>` envelope (`{ data, total, page, limit }`).
6. **Stable error contract.** Failures are serialised as `{ statusCode, message, error }` so that the frontend's `getApiError` helper can handle both single-string and array-of-strings messages from validation pipes without branching on the endpoint.

OpenAPI documentation is generated automatically by the `@nestjs/swagger` module and served at `/api/docs` when the `SWAGGER_PATH` environment variable is set, which is useful in development and during defence preparation but disabled in production.

3.4.2 Endpoint Structure

Table 3.1 lists representative endpoints grouped by module. The complete list of around one hundred routes is reproduced in Appendix B.

Table 3.1: Main REST API endpoints, grouped by module

Method	Route	Description
<i>Authentication (Better-Auth, mounted under /api/auth)</i>		
POST	/auth/sign-up	Register a new user, send verification email
POST	/auth/sign-in	Authenticate and issue session cookie
POST	/auth/sign-out	Invalidate the current session
GET	/auth/verify-email	Confirm an email verification token
<i>Seller application</i>		
POST	/seller-application	Submit a new application
GET	/seller-application/my	Read my own application
GET	/seller-application	(admin) List every application
PATCH	/seller-application/:id	(admin) Approve, reject, or request info
<i>Store</i>		
GET	/store	List public stores (paginated, searchable)
GET	/store/by-slug/:slug	Resolve a store by its public slug
POST	/store	Create a store (triggers AI verification)
PATCH	/store/:id/customization	Save Craft.js storefront configuration
PATCH	/store/:id/sale	Activate, edit or disable the store-wide sale
POST	/store/:id/ai-redesign	Request an AI-generated full redesign
PATCH	/store/:id/status	(admin) Suspend, reactivate or delete
<i>Product</i>		
GET	/product	List products (filters, sort, pagination)
GET	/product/by-store/:id/cards	Lightweight product cards for storefront
GET	/product/recommended	Tag-based recommendations
GET	/product/search	Full-text search across catalogue
POST	/product	Create a product (triggers AI verification)
PATCH	/product/:id/verify	(admin) Override AI verdict
<i>Order</i>		
POST	/order	Place an order (multi-store checkout)
GET	/order/my	Read the current user's order history
GET	/order	(admin) List every order
GET	/order/dashboard	⁵⁹ (seller) Orders containing my products (admin sees all)

3.4.3 Authentication Flow (Better-Auth)

Authentication is handled entirely by the **Better-Auth** library [12], integrated into NestJS through a thin adapter module. Better-Auth was preferred over rolling a custom Passport strategy because it ships with email/password, email verification, session persistence in the database, and cookie-based session transport out of the box — everything Cheebo needs without writing any cryptography. Sessions are opaque DB-backed tokens (not JWTs), which makes server-side revocation a one-line update on the `Session` table.

The interaction was already presented as a sequence diagram in Chapter 2 (Figure 2.5); from the design standpoint it is a three-stage flow: registration (creates the `User` row, sends the verification email, returns a session cookie marked *pending verification*), email verification (flips `emailVerified=true`), and login (validates credentials and issues a fresh session). Every subsequent protected request carries the `better-auth.session_token` cookie, which the NestJS `AuthGuard` validates against the `Session` table on each call.

3.5 n8n Workflow Design

Cheebo’s AI features are carried by three independent n8n workflows deployed on the same engine. Each one is exposed as an HTTP webhook that the NestJS backend invokes; their JSON definitions live in `n8n-workflows/` in the repository and are reproduced in Appendix C. The three workflows differ in their trigger, integration pattern, and downstream model:

- **AI verification** — fired once a seller has uploaded the images for a new store or product; screens every image with a multimodal model, asynchronous response through a callback endpoint.
- **Database chat assistant** — triggered by an administrator’s chat message, conversational request/response.
- **AI storefront redesign** — triggered explicitly by a seller from the Craft.js editor, synchronous response returning a `StoreCustomization` JSON object.

3.5.1 AI Verification Workflow

Figure 3.5 shows the n8n workflow responsible for store and product verification. Once the entity’s images have been uploaded, the backend fires the `cheebo-ai-verify` webhook; the workflow fans the image list out into one branch per image, downloads each file from the backend’s `/uploads` route, and submits it together with the listing text to the Gemini vision model. The per-image verdicts are then aggregated — the entity

is flagged if *any* image is inappropriate — and the combined decision is posted back to the `/ai-review` callback endpoint.

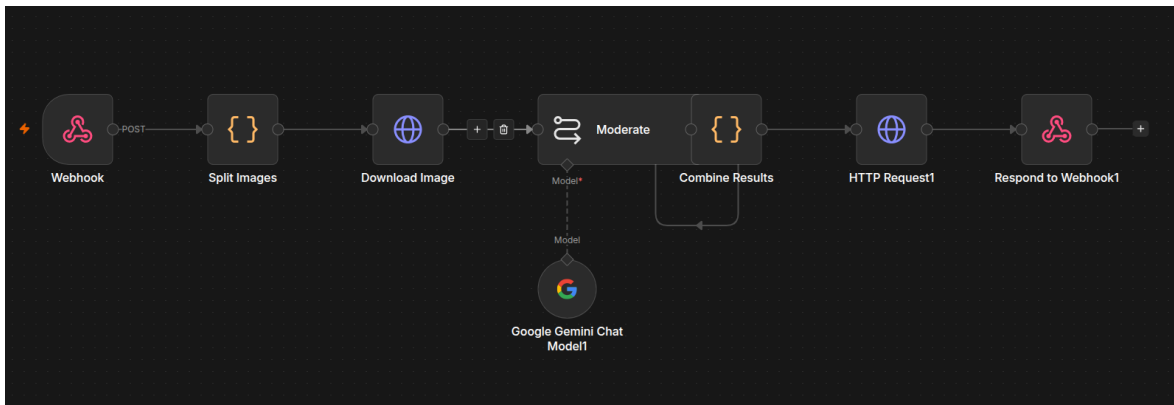


Figure 3.5: n8n workflow — AI verification

3.5.2 Database Chat Assistant Workflow

Figure 3.6 illustrates the database chat assistant workflow. Administrator messages are forwarded to n8n, which uses an LLM to translate the natural-language query into SQL, executes it against the MariaDB instance, and returns a formatted response.

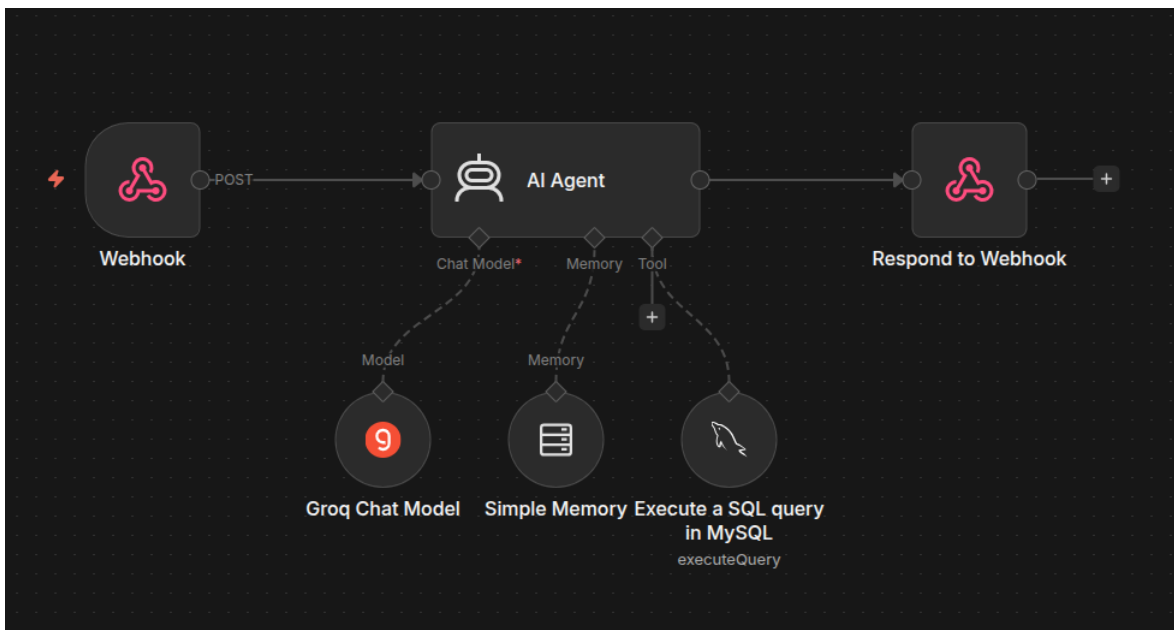


Figure 3.6: n8n workflow — Database chat assistant

3.5.3 AI Storefront Redesign Workflow

The third n8n workflow handles AI-assisted storefront redesign. Unlike the verification workflow, which is triggered automatically on entity creation, this workflow is initiated explicitly by the seller from the Craft.js editor. The seller provides a short prompt describing the desired aesthetic; the backend forwards it to the **cheebo-store-redesign**

webhook along with the store name and description as context.

The workflow is composed of three nodes: a **Build Prompt** Code node that assembles the system instructions and enforces the `StoreCustomization` JSON schema; an **AI Agent** node connected to the Groq llama-3.3-70b-versatile model that produces the design; and a **Parse & Sanitise** Code node that validates hex colour values, clamps numeric fields, and applies safe defaults for any missing properties. The sanitised object is returned synchronously to the backend, which persists it and streams it back to the editor.

Figure 3.7 shows the workflow as it appears in the n8n editor, with the webhook trigger on the left, the Build Prompt Code node, the AI Agent connected to the Groq chat model, the Parse & Sanitise Code node, and the Respond to Webhook node on the right.

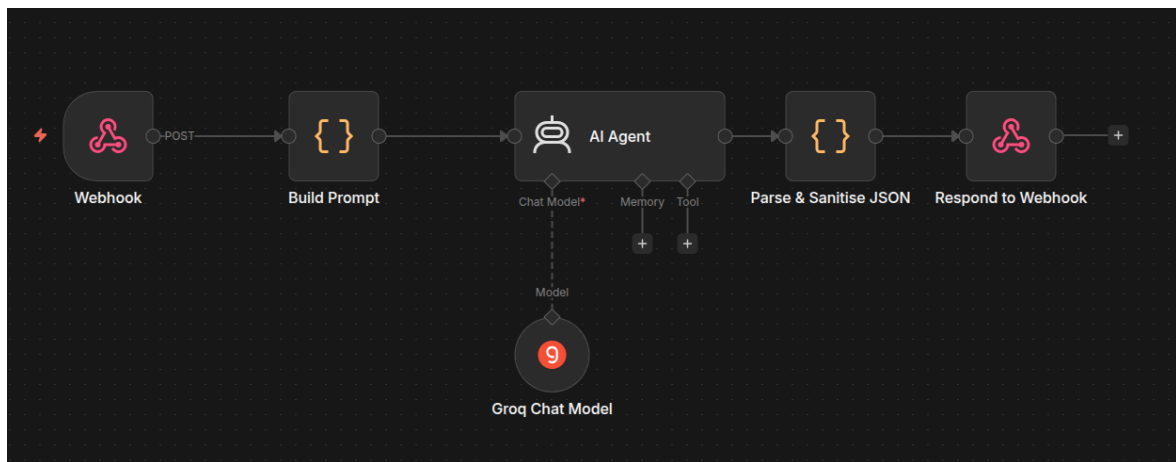


Figure 3.7: n8n workflow — AI storefront redesign

Figure 3.8 complements the workflow screenshot with the end-to-end interaction sequence between seller, backend, n8n and the LLM provider at the design level.

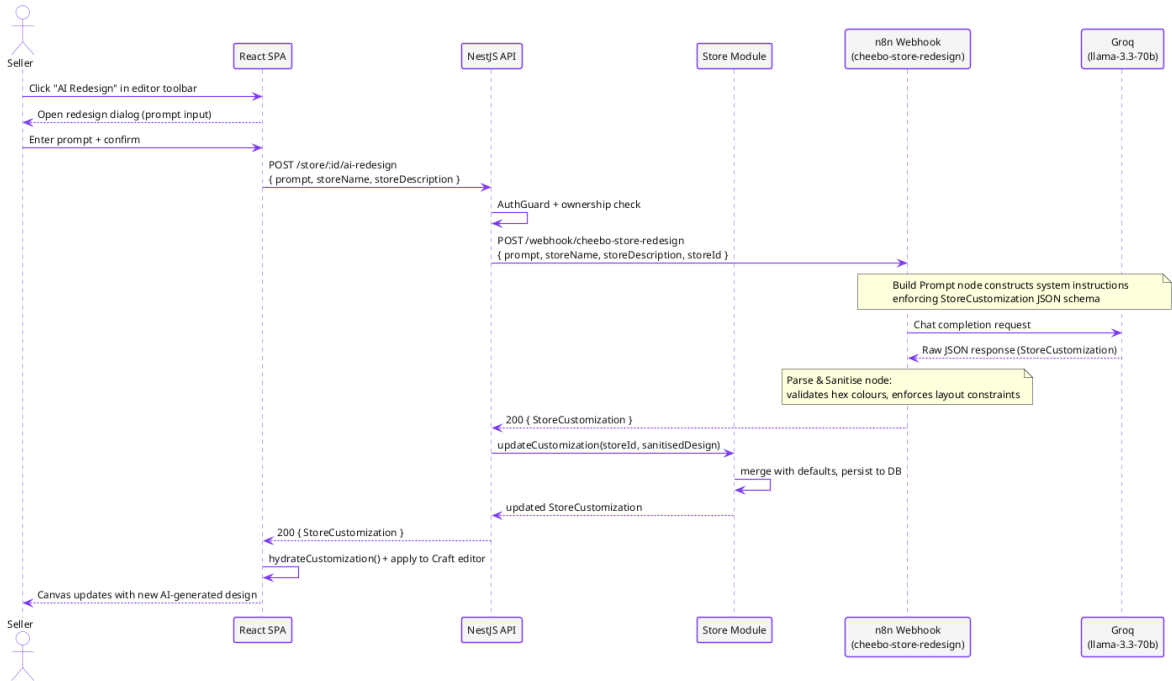


Figure 3.8: AI storefront redesign — interaction sequence

3.6 Class Diagram

Figure 3.9 presents the UML class diagram of the main domain entities. Where the ER diagram of Section 3.3.1 focused on tables, foreign keys and cardinalities, the class diagram emphasises the *behaviour* attached to each entity — the methods invoked by the service layer during use case execution — and the *enumerations* that constrain the state of every long-lived object.

Three structural relationships dominate the model:

- **User-driven aggregation.** The **User** class plays the role of the application's principal aggregate. It has a 1:0..1 association with **SellerApplication**, a 1:N composition with **Store** (one user, multiple stores on the premium tier), and a 1:N association with **Order** as a customer.
- **Store/Product composition.** **Store** composes **Product** (filled diamond): products cannot exist independently of their store, and cascading deletes are enforced at both the Prisma and database levels. The same composition links **Product** to its **ProductImage** children.
- **Order/OrderItems aggregation.** **Order** aggregates **OrderItems** (open diamond): order lines always belong to exactly one order, but the **Product** they reference has an independent lifecycle from the order. This is what allows historical orders to keep displaying a product that has since been deleted from a store.

Four enumerations (**UserRole**, **StoreStatus**, **OrderStatus**, **VerificationStatus**)

constrain the state machines of their owning entities. Methods shown on each class correspond directly to service-layer operations exposed by the matching NestJS module — `Store.suspend(reason)` maps to `StoreService.suspend()`, `Product.computeSalePrice()` maps to the helper used by every product query, and so on.

Figure 3.9 renders the resulting model. Aggregate roots (`User`, `Store`, `Order`) appear with their associations and the multiplicities that govern them; supporting classes (`ProductImage`, `ProductTag`, `OrderItems`) sit alongside the entity they belong to; and the four enumerations are linked to their owning classes through dashed dependency arrows.

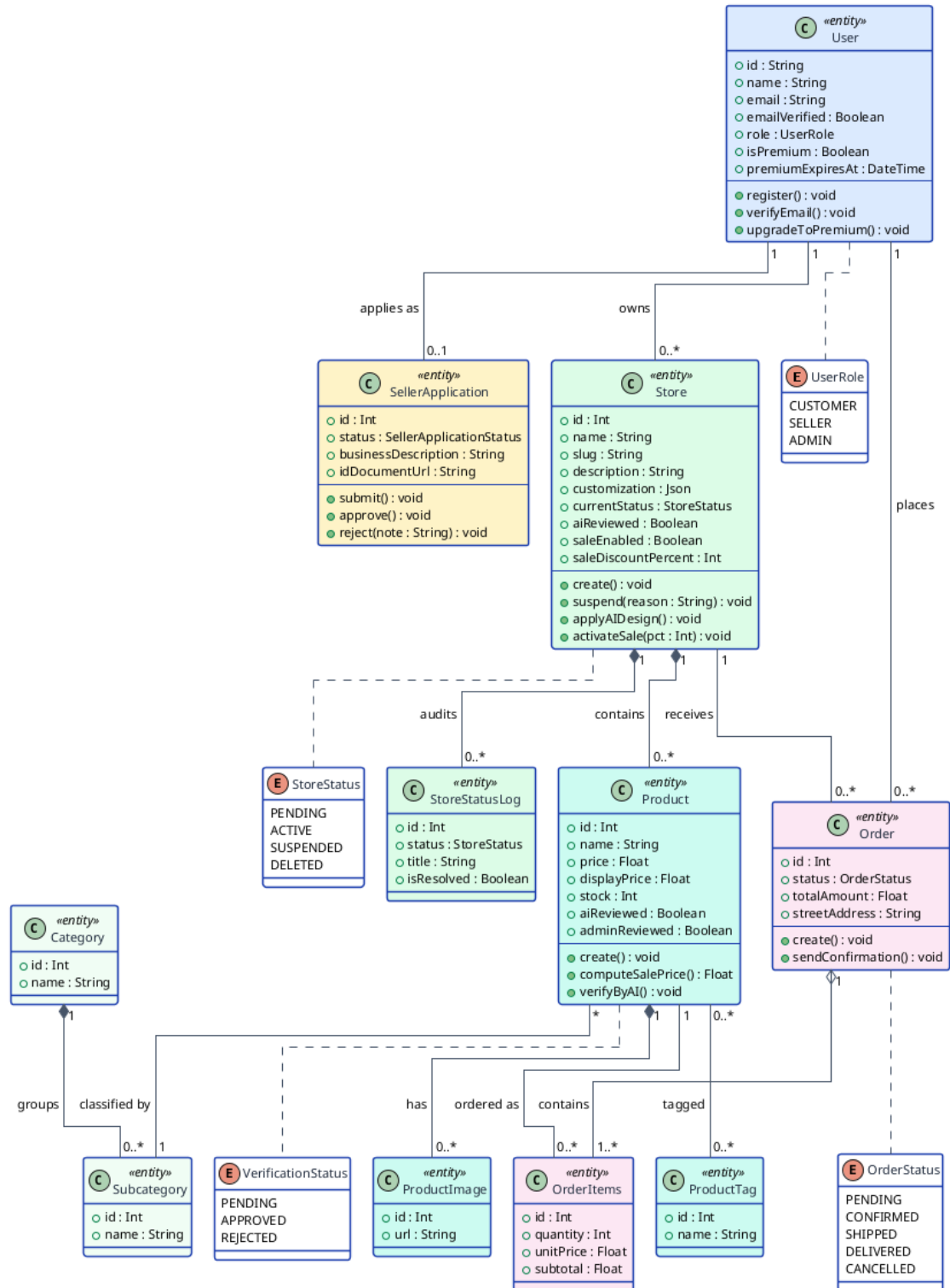


Figure 3.9: UML class diagram of the main domain entities

Key Takeaways

- The system is a three-tier architecture — React SPA, NestJS API, MariaDB —

with n8n as an external automation layer reached only through webhooks.

- The NestJS backend is composed of around twenty feature modules grouped into six functional clusters (cross-cutting, user, storefront, catalogue, commerce, AI), each mapping one-to-one to a functional requirement domain.
- The Prisma schema is split into eighteen files for reviewability, and uses the JSON `customization` column on `Store` to persist the Craft.js editor state without proliferating tables.
- The REST API follows resource-oriented design, validates every payload with `class-validator` DTOs and enforces RBAC through the `@Roles()` decorator.
- Three independent n8n workflows — verification, DB chat, storefront redesign — isolate prompt and provider choices from the backend.

Chapter Conclusion

This chapter translated the requirements of Chapter 2 into a concrete, implementable design. The three-tier layout established a clear boundary between presentation, business logic and data, while the n8n layer added an orthogonal AI dimension without polluting the core. The NestJS module catalogue, the React SPA layout, the Docker Compose topology and the Prisma schema were each presented at a level of detail that lets a reader *reconstruct* the system from the diagrams alone. The REST API design principles and the endpoint catalogue defined the contract between frontend and backend, and the three n8n workflows formalised the design of every AI feature. The class diagram in the final section bound all of these views together by showing the behavioural model that the next chapter actually implements.

Chapter 4 Development and Implementation

This chapter details the development environment, the backend and frontend implementation decisions, and the AI integration via n8n. It then illustrates the resulting platform through interface screenshots organised by role, and closes with the automated test suite — 445 tests across backend and frontend — that validates the implementation on every CI build.

4.1 Development Environment

4.1.1 Hardware and Software

Development was carried out on a single workstation running Ubuntu 22.04 LTS with 16 GB of RAM and an 8-core CPU. This configuration is comfortable for running the backend, frontend, and a local MariaDB container simultaneously, but is well under the requirements of the production droplet (Section 5.4.1). The toolchain pinned for the project is summarised in Table 4.1: `Node.js 22 LTS` as the runtime, `pnpm 10` as the package manager (chosen for its content-addressable store and workspace support), Docker Engine and Docker Compose for the local database and n8n containers, and Git backed by GitHub for version control.

Component	Version / role
Operating system	Ubuntu 22.04 LTS (development); the production droplet runs Ubuntu 22.04 as well, keeping behaviour consistent.
Node.js	22 LTS — JavaScript runtime for both the NestJS server and the frontend build tools.
pnpm	10 — package manager, used for both backend/ and frontend/ workspaces.
Docker / Docker Compose	24+ — local containerisation of MariaDB and n8n; same engine in production.
MariaDB	11 — relational database, run as a container locally and as a Compose service in production.
Git + GitHub	Version control and remote; the GitHub Actions runner executes the CI/CD pipeline.

Table 4.1: Development toolchain used throughout the project

4.1.2 VSCode and Extensions

Visual Studio Code is used as the primary editor on both the frontend and the backend codebases. A small set of extensions is relied upon to keep the inner development loop fast and consistent across the monorepo:

- **ESLint** and **Prettier** — linting and formatting on save, sharing the configuration committed to each package (the backend extends the NestJS preset, the frontend uses `typescript-eslint` + React plugins).
- **Prisma** — syntax highlighting and schema formatting for `backend/prisma/schema/`, plus click-through navigation between models and their usages.
- **Tailwind CSS IntelliSense** — class-name autocompletion against the project's `tailwindcss_v4` configuration [13]; particularly important given the volume of utility classes in the React components.
- **Docker** — inline visualisation of running containers and quick attach for the local MariaDB instance.
- **GitLens** — inline blame and history for tracing decisions back to the commit that introduced them.

The repository contains a `.vscode/settings.json` file committed to source control that pins the formatter, enables format-on-save, and configures ESLint to auto-fix on save. This guarantees that any contributor opening the project produces diffs that pass CI without local configuration.

4.1.3 pnpm Monorepo Structure

The project is organised as a **pnpm** workspace monorepo with three top-level packages. Figure 4.1 shows the directory tree: **backend/** contains the NestJS API, **frontend/** the React SPA, and **terraform/** the infrastructure-as-code definitions.

[IMAGE TO INSERT: Monorepo directory tree (backend/, frontend/, terraform/)]

Figure 4.1: Cheebo monorepo structure

4.2 Backend (NestJS)

4.2.1 Project Structure

The backend follows the conventional NestJS layout: a thin `main.ts` bootstrap that validates the required environment at start-up (fail-fast), applies the Helmet security-header middleware and the global `ValidationPipe`, and mounts the Swagger document only outside production, a root `AppModule` that imports every feature module, and one directory per domain under `src/`. Each feature directory is self-contained and groups its `*.module.ts`, `*.controller.ts`, `*.service.ts`, a `dto/` folder of request/response DTOs, and — as detailed in Section 4.6 — its co-located `*.spec.ts` tests. Cross-cutting concerns live under `src/common/` (guards, pagination DTOs, the Multer configuration, customization helpers) and `src/prisma/` (the database client wrapper). The Prisma client is code-generated into `src/generated/prisma/` and im-

ported as a normal TypeScript module.

This per-domain split means a change to, say, the order flow touches only the `order/` directory, and the NestJS dependency injection container resolves a service's collaborators (`PrismaService`, `NotificationService`) by their injection tokens rather than by file path — which is exactly what makes the services straightforward to unit-test with mocked collaborators.

4.2.2 Key Modules

The `AppModule` composes eighteen feature modules. The most load-bearing ones are described below; their dependency relationships were presented as the module-cluster diagram in Chapter 3.

- **AuthModule** — wraps Better-Auth, exposes the session endpoints, and provides the `AuthGuard` used by every protected route. Session tokens are database-backed rather than stateless JWTs.
- **StoreModule** — store CRUD, slug generation, premium-template gating, the store-wide sale feature, the Craft.js customization JSON, and the AI-redesign web-hook call. It is the largest single domain in the codebase.
- **ProductModule** — product CRUD, the free-tier product cap, sale-price computation (`applySalePrices`), AI/admin verification flags, and tag-based recommendations.
- **OrderModule** / **OrderItemsModule** — order creation, per-seller dashboard scoping, and transactional order-status emails.
- **SellerApplicationModule** — the seller-onboarding state machine that promotes an approved applicant to the `SELLER` role.
- **NotificationModule** — persists notifications, fans out to all admins, and streams live updates to connected clients over Server-Sent Events.
- **ChatModule** and **N8nModule** — the bridge to the n8n automation layer: the database chat assistant and the AI verification/redesign webhooks.
- **PaymentModule** — Stripe checkout, webhook-confirmed order payment, and the scheduled stale-checkout reconciliation sweep that keeps reserved stock and payment state consistent.
- **PrismaModule** — a global module exporting the single `PrismaService` instance injected everywhere else.

4.2.3 Authentication Guards and Role-Based Access Control

Access control follows a *deny-by-default* model. A single `AuthGuard` is registered globally as an `APP_GUARD` provider, so every route requires a valid session unless it is explicitly opted out with the `@Public()` decorator (the catalogue and store-page reads that anonymous visitors need). The guard short-circuits on `@Public()`, then validates the session and — when a handler declares `@Roles(...)` — checks the caller’s role, raising `401 Unauthorized` for a missing or invalid session and `403 Forbidden` for an authenticated caller who lacks the required role. Figure 4.2 shows a representative admin-only controller method annotated with `@Roles()`, illustrating how the framework enforces role-based access at the route level before the handler executes. Marking the public surface explicitly (rather than remembering to guard each new private route) means a newly added endpoint is secure by default.

[IMAGE TO INSERT: Code snippet — global AuthGuard (APP_GUARD), @Public() and an admin route with @Roles()]

Figure 4.2: Deny-by-default access control implementation

Role gating alone is not sufficient, because two sellers share the same `SELLER` role yet must not be able to edit each other’s content. Authorization is therefore enforced at two levels. The `AuthGuard` (and `@Roles()`) establishes *who* the caller is and *which role* they hold; the service layer then enforces *object-level ownership* before any mutation. Updating or deleting a product, uploading a store image, or reading and modifying an order all resolve the owning user (`Product → Store.userId`; an order’s customer or owning store) and reject the request with `403 Forbidden` when the caller is neither that owner nor an administrator. This closes the insecure-direct-object-reference gap that role checks by themselves leave open, and is pinned by the ownership and authorization unit tests of Section 4.6.

4.2.4 File Upload System (Multer)

Image uploads — store logos, store thumbnails, banner images, and product images — are handled by Multer through a single shared factory, `multerStorage(destination)`, defined in `src/common/multer/`. The factory returns a `diskStorage` configuration that writes files under the configured uploads directory, renaming each to a collision-proof `<timestamp>-<random><ext>` name so that two users uploading `logo.png` never overwrite one another.

Two guards are enforced at the Multer layer before a file ever reaches a controller:

- **MIME-type allow-list** — only the types in `ALLOWED_UPLOAD_MIME_TYPES` (default `jpeg, png, webp, gif`) are accepted; anything else is rejected with a `BadRequestException`.
- **Size cap** — a per-file limit of `MAX_UPLOAD_FILE_SIZE_MB` (default 5 MB), enforced by Multer's `limits` option.

Controllers consume the factory through NestJS's `FileInterceptor`, for example on `POST /product/:id/image`. The uploaded file's URL is then persisted (as a `ProductImage` row or on the store record) and the static file is served back by the Express `static-assets` middleware configured in `main.ts`. Because the destination directory is a Docker named volume, uploaded media survives container re-creation (Section 5.4.1).

4.2.5 Email System (Nodemailer)

Transactional email is sent through a single thin helper, `sendEmail({ to, subject, html })`, in `src/auth/mailer.ts`. It builds a Nodemailer SMTP transport from environment variables (`SMTP_HOST`, `SMTP_PORT`, `SMTP_SECURE`, `SMTP_USER`, `SMTP_PASS`, `SMTP_FROM`) with conservative connection, greeting, and socket timeouts so that a slow mail server cannot stall a request thread.

Two flows rely on it. First, Better-Auth uses it for **email-verification** links during registration. Second, the `OrderService` sends an **order-status email** whenever an order transitions to a new status (confirmed, shipped, delivered, cancelled, refunded), rendering a small HTML template with the order number, store name, and a status-coloured badge. Crucially, these emails are dispatched as fire-and-forget promises: a failure to send is logged but never propagated to the caller, so a downed SMTP server degrades gracefully (the order is still created) rather than failing the user's request. This is precisely the behaviour pinned by the `order.service` tests in Section 4.6.

4.2.6 Payment Processing (Stripe)

Checkout is handled by a dedicated `PaymentModule` built around two collaborators: a thin `StripeService` that owns the single Stripe client (created lazily, so the applica-

tion still boots without payment keys in development), and a `PaymentService` that orchestrates the flow. The design follows one rule end-to-end: the amount charged is always derived from the orders the server just priced, never from any figure the client sends.

A checkout proceeds in three steps:

- **Reserve and price.** `OrderService.createPendingForCart` runs inside a single transaction, decrements stock atomically, and creates one `UNPAID` order per store, returning the server-computed grand total.
- **Open a `PaymentIntent`.** `PaymentService` opens a single Stripe `PaymentIntent` for that total. Because a Stripe account cannot settle in Tunisian dinar, the TND total is converted to US-dollar minor units through a configurable `TND_TO_USD_RATE` (the helper `tndToStripeUsdMinor`); the interface keeps displaying TND while the charge is in USD. The order identifiers are written into the intent metadata, an `idempotencyKey` derived from them prevents a duplicate charge on retry, and the intent id is stamped back onto the orders. If the intent cannot be opened, the stock reserved a moment earlier is released so it is never stranded on a dead order.
- **Confirm by webhook.** The client confirms the intent with Stripe directly; the orders stay `UNPAID` until Stripe calls back. The `POST /payments/webhook` endpoint is unauthenticated by design — trust comes from verifying the Stripe signature against the *raw* request body (the `main.ts` bootstrap enables `rawBody` for exactly this), not from a session. On a verified `payment_intent.succeeded` it marks the orders `PAID` and `CONFIRMED`; a failure or cancellation releases the reserved stock instead.

Both state transitions (`markPaid` and `markFailedAndRestock`) are scoped to orders that are still `UNPAID`, which makes them idempotent: Stripe may redeliver the same event and the second delivery is a harmless no-op. The conversion helper and the full webhook decision table are pinned by the `payment.service` and `stripe-amount` unit tests of Section 4.6.

4.2.7 Rate Limiting

To blunt brute-force and abuse, the API applies a global rate limit through `@nestjs/throttler`. `ThrottlerModule` is configured in `AppModule` with a default budget of **100 requests per 60-second window** per client, and a `ThrottlerGuard` is registered as a global `APP_GUARD` so the limit covers every route without per-controller wiring. Two routes deliberately diverge from the default:

- **Checkout** (`POST /payments/checkout`) is tightened to **10 requests per minute**

with `@Throttle`, because each call reserves stock and opens a Stripe intent — operations far more expensive than a read.

- **The Stripe webhook** opts out entirely with `@SkipThrottle`: its call rate is dictated by Stripe, not by a client, and throttling it could drop legitimate payment-confirmation events.

4.2.8 Stale-Checkout Reconciliation

Confirming orders by webhook introduces two failure modes that a naive flow would leave unresolved: a customer who abandons checkout leaves an `UNPAID` order holding reserved stock indefinitely, and a webhook lost in transit leaves a genuinely paid order stuck as `UNPAID`. A scheduled reconciliation sweep closes both gaps and makes the system self-healing.

A small `PaymentCleanupService` runs every ten minutes via the `@Cron` scheduler of `@nestjs/schedule` (enabled with `ScheduleModule.forRoot()`) and delegates to `PaymentService.reconcileStaleCheckouts`. That method collects every order still `UNPAID` past a configurable staleness window (`CHECKOUT_STALE_MINUTES`, default 30), groups them by their `PaymentIntent`, retrieves each intent from Stripe, and acts on its real status:

- **succeeded** — the success webhook was lost; the orders are marked `PAID`, recovering the missed event.
- **requires_payment_method** or **canceled** — the intent is dead; the orders are cancelled and their stock released, and a not-yet-cancelled intent is cancelled on Stripe as best-effort cleanup.
- **processing**, **requires_action** or **requires_confirmation** — the payment is still in flight and is left untouched for a later sweep.

Orders that never received an intent are simply restocked. Each intent is reconciled inside its own `try/catch`, so a single Stripe error cannot abort the whole sweep; and because the sweep reuses the same idempotent `markPaid` / `markFailedAndRestock` transitions as the live webhook, the two can race without corrupting order state. This behaviour is covered by the `reconcileStaleCheckouts` unit tests of Section 4.6.

4.3 Frontend (React + Vite)

4.3.1 Project Structure

The frontend is a React 19 single-page application built with Vite. Source is organised by responsibility under `src/`: `pages/` holds route-level screens (further nested

into `dashboard/admin/` and `dashboard/seller/`); `components/` holds reusable presentational components and the `shaden/ui` primitives under `components/ui/`; `routes/` holds the route table and the `RoleRoute` guard; `hooks/` holds the data-fetching hooks that wrap TanStack Query; `stores/` holds the Zustand stores; `api/` holds the Axios client and typed request functions; and `lib/`, `constants/`, and `types/` hold shared utilities, enumerations, and TypeScript types. The `@/` path alias maps to `src/` in both the Vite config and `tsconfig`, so imports read `@/components/ProductCard` regardless of nesting depth.

4.3.2 Routing and Layouts

Routing uses `react-router-dom` 7. The application is wrapped in `main.tsx` by four providers, in order: a `HelmetProvider` for per-page document titles, the `TanStack QueryClientProvider`, a `BrowserRouter`, and the app's own `useAuthStoreSync` hook that hydrates the auth store from the active session on load.

The route table itself lives in `src/routes/index.tsx`. Public routes — home, store listing, store page, product listing, product page, cart, checkout, login, register — are declared directly. Protected routes are nested inside a `RoleRoute` element that takes an `allowedRoles` list and a `redirectTo` target: the `/dashboard` and Craft editor routes are gated to `ADMIN` and `SELLER`, while `/my-account` and the seller-application flow are gated to `CUSTOMER`. A user whose role is not in the allow-list is redirected rather than shown the screen, mirroring the backend's `@Roles()` enforcement on the API side so that authorisation is consistent end-to-end.

4.3.3 State Management (TanStack Query + Zustand)

The frontend deliberately separates *server state* from *client state*, using a different tool for each.

TanStack Query [10] owns all server state. Every read from the API goes through a custom hook in `src/hooks/` (`useProducts`, `useStorePage`, `useMyOrders`, `useFeatured`, `useAdminDashboard`, `useNotifications`, and others) that wraps `useQuery/useMutate`. The shared `QueryClient` (in `src/lib/queryClient.ts`) is configured with a one-minute `staleTime` and a single retry, which keeps the UI responsive (cached data is reused across navigations) without hammering the API. Mutations invalidate the relevant query keys so the cache stays coherent after writes.

Zustand [11] owns the small amount of genuine client state that must persist across routes and reloads. The cart store (`src/stores/cart.store.ts`) is the principal example: it holds the customer's purchase intent, enforces the per-item stock cap on add and update, and is wrapped in Zustand's `persist` middleware so the cart survives a page refresh via `localStorage`. The auth store holds the current user and role for the `RoleRoute` guard. This division — TanStack Query for anything that lives on the

server, Zustand for anything that is purely the client's — avoids the common pitfall of duplicating server data into a global store and then having to keep the two in sync.

4.3.4 Admin Dashboard Panels

Figure 4.3 shows the administrator dashboard, which centralises seller application reviews, store moderation, user management, and featured content curation in a single tabbed interface.



Figure 4.3: Admin dashboard

4.3.5 Store and Product Management Interface

Figure 4.4 presents the seller-facing store and product management panels, from which a seller can create and edit their store, manage their product catalogue, upload images, and monitor incoming orders.

[IMAGE TO INSERT: Screenshot — Store / product management (seller view)]

Figure 4.4: Store and product management interface

4.4 AI Integration with n8n

All AI features are implemented as n8n workflows triggered over webhooks rather than as in-process calls from NestJS. This keeps the LLM-provider credentials, prompt templates, and parsing logic outside the application code, where they can be edited visually and re-run against historical executions without redeploying the backend. The backend’s only responsibility is to fire the webhook with a compact payload and act on the structured response.

4.4.1 AI Product/Store Verification Pipeline

Because a product’s (or store’s) images are uploaded *after* the entity itself is created, verification is not fired at creation time — doing so would screen a listing that has no images yet. Instead, once the client has finished uploading the images it calls `POST /{type}/{id}/submit-verification`, and the corresponding service fires the **cheebo-ai-verify** webhook asynchronously (fire-and-forget, so the request never blocks on the AI). The payload carries the entity **type** (**product** or **store**), its **id**, **name**, **description**, and the list of image URLs. The workflow downloads each image from the backend’s `/uploads` route and screens it — together with the listing text — with the Gemini vision model, flagging the entity if *any* image violates the platform’s content policy. It then calls back into the API — `PATCH /product/{id}/ai-review` or the

equivalent store route, authenticated by the `x-api-key` header that the `ApiKeyGuard` validates — with an `approved` or `flagged` decision and a reason.

The backend records the outcome on two distinct flags: `aiReviewed` (set by this pipeline, with the reason stored in `aiReviewNote`) and `adminReviewed` (set only when a human administrator later overrides the decision). Separating the two means the admin moderation queue can show *why* the AI flagged a listing and still let a human have the final say — the override path is exactly what the `verify()` and `aiReview()` service tests in Section 4.6 pin down.

4.4.2 Database Chat Assistant

The database chat assistant is an administrator-only tool, surfaced as a floating button (`AiChatFab`) on the admin dashboard. The administrator asks operational questions in natural language — *"how many orders shipped this week?"*, *"which stores are still pending verification?"* — and receives an answer grounded in live data. The frontend posts the question to the NestJS `ChatModule`, which forwards it to the **cheebo-ai-chat** n8n workflow. There an AI Agent translates the question into a safe, read-only database query, executes it, and summarises the result set in prose. Because the assistant is mounted only inside the role-gated admin dashboard, it is unreachable by customers or sellers — a boundary verified both by the `RoleRoute` guard on the frontend and the `AuthGuard/@Roles` pairing on the backend.

4.4.3 n8n Workflow — AI Storefront Redesign

The AI Storefront Redesign workflow allows a seller to regenerate their entire store visual identity by providing a short natural-language prompt from inside the Craft.js editor. The end-to-end interaction sequence between seller, backend, n8n and the LLM provider was presented in the design chapter (Figure 3.8); this section describes its implementation.

The seller clicks the *AI Redesign* button in the editor toolbar, which opens a dialog prompting for a short description of the desired aesthetic (e.g. *"dark luxury jewellery brand with gold accents"*). The React frontend calls `POST /store/:id/ai-redesign`, passing the prompt alongside the store name and description for context.

On the backend, the NestJS Store Module forwards the request to the **cheebo-store-redesign** n8n webhook. The workflow consists of three nodes:

1. **Build Prompt** — a Code node that constructs a system-level instruction enforcing a strict JSON schema matching the `StoreCustomization` type. The schema covers every configurable section: theme colours and fonts, announcement bar, banner, header, product grid, sidebar, and footer.
2. **AI Agent** — an AI Agent node connected to the Groq `llama-3.3-70b-versatile`

model. The agent receives the assembled system prompt and the seller’s free-text request, then returns a JSON object conforming to the `StoreCustomization` schema.

3. **Parse & Sanitise** — a Code node that parses the raw LLM output, validates all hex colour values with a regex, clamps numeric fields to valid ranges, and falls back to safe defaults for any field that is missing or malformed.

The sanitised `StoreCustomization` object is returned to the NestJS backend, which merges it with the store defaults and persists it through the existing `updateCustomization` path. The frontend then calls `hydrateCustomization()` on the response and applies the result directly to the Craft.js editor, giving the seller an immediate live preview of the AI-generated design without a page reload.

4.4.4 Google Gemini / Groq Integration

The workflows are model-agnostic by design — the AI Agent node abstracts the provider — but in the deployed configuration two providers are used, chosen per task:

- **Verification** (`cheebo-ai-verify`) uses a Google Gemini [26] model, whose vision capability is required to moderate the uploaded images against the listing text. The **database chat assistant** (`cheebo-ai-chat`) uses a Groq `openai/gpt-oss-20b` agent with a Gemini chat model available as an alternate within the same workflow. These tasks are classification- and reasoning-oriented and do not need a very large model.
- **Storefront redesign** (`cheebo-store-redesign`) uses Groq’s [25] `llama-3.3-70b-versatile`. The larger model produces more coherent full-page design JSON, and Groq’s inference speed keeps the seller’s live-preview latency low.

Provider credentials are stored in n8n’s encrypted credential store (persisted to the `n8n_data` volume), never in the application’s environment or source. Swapping a provider, or A/B-testing two models, is a change inside n8n that requires no backend redeployment.

4.4.5 n8n Workflow Implementation

Each workflow follows the same skeleton: a **Webhook** trigger (secured with header authentication), an **AI Agent** bound to a chat model, one or more **Code** nodes for prompt assembly and output sanitisation, and a **Respond to Webhook** node that returns the structured result to NestJS. The three workflows — **Products/Stores verification**, **Cheebo DB Chat**, and `cheebo-store-redesign` — are exported as JSON and committed to the repository under `n8n-workflows/`, so the automation

layer is versioned alongside the application code and can be re-imported into a fresh n8n instance. The full JSON exports are reproduced in Appendix C.

The redesign workflow is the most elaborate of the three and was detailed above; the verification and chat workflows are simpler two-to-three-node graphs that the sanitisation Code node keeps defensive against malformed LLM output — the same robustness principle applied throughout the backend.

4.5 Interface Screenshots

This section presents screenshots of the deployed platform, grouped by the three user roles (customer, seller, administrator) and a final group covering the AI assistant.

4.5.1 Customer Experience

Figure 4.5 shows the Cheebo public landing page, which surfaces featured stores, featured products, and the tag-based recommendation section. The navigation bar provides direct access to the catalogue, login, and cart.



Figure 4.5: Landing page

Figure 4.6 shows the global stores listing page, with the search bar, store cards, and the active-sale badges displayed on stores currently running a promotion.

[IMAGE TO INSERT: Screenshot — Stores listing page with sale badges on cards]

Figure 4.6: Stores listing page

Figure 4.7 shows the category-filtered products browse page, with sidebar filters (category, sub-category, price range, sort) and the product grid displaying discounted prices on products belonging to stores that have activated a sale.

[IMAGE TO INSERT: Screenshot — Category browse with filters and product grid]

Figure 4.7: Product browse page

Figure 4.8 shows the product detail page, with the image carousel, description, tags, stock indicator, sale price (when applicable), and the *Add to cart* action.

[IMAGE TO INSERT: Screenshot — Product detail page with sale price and add-to-cart]

Figure 4.8: Product detail page

Figure 4.9 shows the global **Ctrl+K** search dialog (`cmdk`), which surfaces both products and stores in real time as the customer types.

[IMAGE TO INSERT: Screenshot — Ctrl+K command palette showing product and store results]

Figure 4.9: Global search dialog

Figure 4.10 shows the checkout page with the multi-store cart summary, shipping

form, per-store subtotal lines, and the order total reflecting active sale discounts.

[IMAGE TO INSERT: Screenshot — Checkout page with multi-store cart and shipping form]

Figure 4.10: Checkout page

4.5.2 Seller Dashboard

Figure 4.11 presents the seller store dashboard, from which a seller can monitor live store metrics, access the customisation editor, and review recent order activity.

[IMAGE TO INSERT: Screenshot — Seller store dashboard with metrics and quick actions]

Figure 4.11: Store dashboard

Figure 4.12 shows the Craft.js WYSIWYG storefront editor, with the sections panel on the left, the live canvas in the centre, and the settings panel on the right. Selecting any section on the canvas opens its inspector.

[IMAGE TO INSERT: Screenshot — Craft.js storefront editor (3-column layout)]

Figure 4.12: WYSIWYG storefront editor

Figure 4.13 shows the AI Redesign dialog, in which a seller submits a natural-language prompt to regenerate the storefront design end-to-end.

[IMAGE TO INSERT: Screenshot — AI Redesign dialog with prompt input]

Figure 4.13: AI Redesign dialog

Figure 4.14 shows the Sale configuration panel, where a seller toggles the store-wide sale, sets the discount percentage, custom label, and optional expiry date.

[IMAGE TO INSERT: Screenshot — Sale panel with percentage, label and expiry controls]

Figure 4.14: Store-wide sale configuration panel

Figure 4.15 shows the seller's product management panel with the list view, create/edit form, image upload, and tag selector.

[IMAGE TO INSERT: Screenshot — Seller product management (list + create/edit form)]

Figure 4.15: Product management

Figure 4.16 shows the per-store analytics page available to sellers, displaying revenue trends, top-selling products, order volumes, and visitor statistics.

[IMAGE TO INSERT: Screenshot — Seller analytics page (revenue chart, top products)]

Figure 4.16: Analytics page

4.5.3 Administrator Tools

Figure 4.17 shows the admin dashboard landing page, with platform-wide metrics, the navigation to every admin panel, and the recent activity feed.

[IMAGE TO INSERT: Screenshot — Admin dashboard overview with metrics and navigation]

Figure 4.17: Admin dashboard overview

Figure 4.18 shows the seller applications review panel, where the admin reviews each application's profile, store proposal, and approves or rejects with a moderation note.



[IMAGE TO INSERT: Screenshot — Seller applications review panel]

Figure 4.18: Seller applications panel

Figure 4.19 illustrates the AI verification panel available to administrators. Each entry displays the entity name, the AI verdict, the LLM rationale, and override controls allowing the administrator to confirm or reverse the automated decision.

[IMAGE TO INSERT: Screenshot — AI verification panel with verdict, rationale, override controls]

Figure 4.19: AI verification panel

Figure 4.20 shows the users management panel, where the admin views every registered user, filters by role, and changes role assignments.



[IMAGE TO INSERT: Screenshot — Users management panel (list + role assignment)]

Figure 4.20: Users panel

Figure 4.21 shows the stores moderation panel, where the admin can suspend, reactivate, or cascade-delete a store with an attached reason logged to `StoreStatusLog`.

[IMAGE TO INSERT: Screenshot — Stores moderation panel (suspend / reactivate / delete actions)]

Figure 4.21: Stores moderation panel

Figure 4.22 shows the categories and sub-categories management panel, with create, rename, reorder, and delete actions.



[IMAGE TO INSERT: Screenshot — Categories and sub-categories management panel]

Figure 4.22: Categories panel

Figure 4.23 shows the home-page curation panel, where the admin selects the featured stores and products that appear on the landing page hero.

[IMAGE TO INSERT: Screenshot — Home-page curation panel (featured stores and products)]

Figure 4.23: Featured content curation panel

4.5.4 AI Assistant

Figure 4.24 shows the floating AI Chat assistant (**AiChatFab**), a docked button on the administrator dashboard that opens a conversational panel where the administrator can query the database in natural language (orders, users, products, stores, verification queues) for operational insights.

[IMAGE TO INSERT: Screenshot — Floating AI chat assistant (FAB + open panel)]

Figure 4.24: AI chat assistant

4.6 Tests and Validation

Cheebo ships with an automated test suite that runs on every push to `main` as a gate before the Docker images are built and deployed. The suite follows a layered strategy: pure-logic unit tests at the bottom, service-level unit tests with a mocked Prisma client in the middle, and controller-level integration tests at the top that boot a real NestJS application and exercise the full HTTP pipeline (`ValidationPipe`, guards, decorators) through `supertest`. The frontend uses Vitest with React Testing Library [17] to cover Zustand stores and presentational components in a jsdom environment.

The whole suite runs in under five seconds on commodity hardware, which keeps the feedback loop short enough to be useful during development and cheap enough to run on every CI build. No production database is required: services are tested against in-memory mocks of `PrismaService`, and HTTP-layer tests stub the guards that transitively import the ESM-only `better-auth` package.

4.6.1 Testing Stack and Tooling

Table 4.2 summarises the libraries used and the responsibility of each. The backend stack is Jest 30 [15] with `ts-jest` for TypeScript compilation; the frontend uses Vitest [16] to reuse the same Vite resolver, plugin chain (`@vitejs/plugin-react`, Tail-

wind), and path alias configuration as the development server, removing the need to maintain a separate test build pipeline.

Layer	Tool	Responsibility
Backend test runner	Jest 30 + ts-jest	Runs all <code>*.spec.ts</code> files, transforms TypeScript on the fly.
Backend HTTP integration	<code>@nestjs/testing</code> + <code>supertest</code>	Boots a real Nest application around individual controllers; <code>supertest</code> drives it over an in-process HTTP transport.
Backend mocking	<code>jest.fn()</code> , <code>jest.mock()</code>	Replaces <code>PrismaService</code> , <code>NotificationService</code> , the SMTP mailer, and the auth guards with deterministic stand-ins.
Frontend test runner	Vitest 4	Runs all <code>*.test.ts(x)</code> files using the same Vite plugin chain as the development server.
Frontend DOM environment	jsdom 29	Provides a synthetic browser <code>window</code> so React components can be mounted and queried.
Frontend component testing	React Testing Library + <code>@testing-library/jest-dom</code>	Mounts components, queries the DOM by accessible role/text, asserts on rendered output.

Table 4.2: Testing stack used in Cheebo

4.6.2 Test Pyramid for Cheebo

The tests are structured along the classical pyramid: a wide base of fast unit tests, a thinner middle of service-level tests that combine multiple collaborators, and a narrow top of integration tests that exercise the wired-up HTTP stack. Figure 4.25 illustrates how the existing tests distribute across these layers.

Integration (83 tests)

Nest app + ValidationPipe + supertest + global guard
 controllers across the modules; deny-by-default guard wiring

Service unit tests (219 tests)

Real service code, mocked Prisma
 catalogue taxonomy, Product, Store, Order, Payment, User,
 Settings, Notification, Analytics, Home, Chat

Pure-logic + frontend (143 tests)

No I/O, no framework wiring
 validate-env, tndToStripeUsdMinor, ApiKeyGuard; Zustand stores, hooks, components

Figure 4.25: Test pyramid — 445 tests total across backend (Jest, 337) and frontend (Vitest, 108)

4.6.3 Backend Unit Tests

Backend unit tests live next to the code they exercise as `*.spec.ts` files. Each test suite injects an in-memory mock of `PrismaService` into the real service under test via the NestJS `TestingModule`, allowing the test to drive arbitrary return values and observe the exact arguments passed to Prisma. Tables 4.3 and 4.4 list the modules covered and the business rules each suite validates.

Suite	Tests	Behaviour under test
limits	11	Premium customization gating: free-palette colours allowed, premium-only fields rejected, equal values pass (existing premium customizations preserved on plan downgrade).
product.service	12	Sale price computation in <code>applySalePrices()</code> : 2-decimal rounding, <code>salePrice = null</code> when sale inactive, expired <code>saleEndsAt</code> ignored, per-store discount across mixed-store result sets, store-ID deduplication. Ownership enforcement: a non-owner seller is rejected with 403 on update/delete, while the owning seller and an admin are allowed.
store.service	9	Slug generation (base, -2 on collision, multi-probe, empty-string fallback, <code>excludeId</code> on rename); store creation conflict; sale update ownership and admin override.
order.service	26	Status-change email (fires only on a real status change; 'Customer' fallback for nameless users) and view/manage authorization (non-owners rejected with 403). Server-authoritative checkout: every line priced and the total computed server-side, a single store enforced per order, and stock decremented atomically. Multi-store <code>createPendingForCart</code> splits a cart into one UNPAID order per store. Idempotent <code>markPaid</code> / <code>markFailedAndRestock</code> transitions (scoped to still-UNPAID orders, restocking on failure), plus the reconciliation helpers <code>setPaymentIntent</code> and <code>findStaleUnpaid</code> .
payment.service	19	Checkout charges the server-computed total only — never a client figure —

Suite	Tests	Behaviour under test
<code>notification.service</code>	10	SSE subject lifecycle, fan-out across admins, <code>markRead</code> ownership guard (scoped by <i>both</i> <code>id</code> and <code>userId</code>), <code>markAllRead</code> targets only unread rows.
<code>analytics.service</code>	8	GroupBy joins with product/store names, 'Unknown' fallback for orphaned IDs (deleted product still in <code>OrderItems</code>), <code>null _sum</code> zero-fill, empty-store seller short-circuit.
<code>home.service</code>	9	Featured fallback (latest products / latest <code>ACTIVE</code> stores), non- <code>ACTIVE</code> stores filtered from curated list, <code>MAX_PRODUCTS</code> / <code>MAX_STORES</code> caps, transactional deletes-then-inserts.
<code>api-key.guard</code>	5	n8n webhook authentication: matching key passes, mismatched/missing rejected, server with no configured secret rejects all (fail-closed).
<code>stripe-amount</code>	11	Currency conversion in <code>tndToStripeUsdMinor</code> : TND→USD minor units at the configured rate, rounding to whole cents, and rejection of non-finite or negative amounts and of a non-positive rate.

Table 4.4: Backend unit test suites — read paths, cross-cutting concerns and guards

These tests target the parts of the codebase where a regression would be most expensive: money math (sale prices, order totals), authorisation (ownership checks, role gating), state machines (seller application status, store status), and validation boundaries. Tables 4.3 and 4.4 list the highest-value suites; the backend suite has since grown to **337 tests** across 38 `*.spec.ts` files. Beyond the money and authorisation core, characterisation specs now cover the previously thin layers — the catalogue-taxonomy services (category, sub-category, product-tag, product-image), `user`, `settings` and `chat`, the read-side query and recommendation paths of `store.service` and `product.service`, and the security-relevant `validate-env` / `database-url` utilities — so the parts of

the codebase exercised in production are not left unverified.

4.6.4 Backend Integration Tests

A second tier of tests boots a real NestJS application around a single controller. The global `ValidationPipe` is enabled with the same options used in production (`whitelist`, `forbidNonWhitelisted`, `transform`), so DTO-level validation is exercised end-to-end. The service the controller depends on is replaced with a Jest mock, and the `AuthGuard` and `ApiKeyGuard` are stubbed at the module level. Requests are driven through `supertest`. Table 4.5 shows three representative suites; the integration tier now spans **83 tests** across the controllers, each asserting the authorization *decision* (allowed versus blocked, and whether the service was invoked) through a shared `@Public/@Roles`-aware test guard. A separate full-application smoke test boots the whole `AppModule` with the real guard wiring to confirm the production status codes (401 for no session, 403 for a role mismatch).

Suite	Tests	Behaviour under test
<code>product.controller</code>	12	Pagination pass-through; 403 on unauthenticated POST; 400 on empty body, extra field, wrong-type field; 404 propagation; <code>ApiKeyGuard</code> wiring on <code>/ai-review</code> ; search query parsing.
<code>store.controller</code>	14	Creation validation (empty body, malformed URL); <code>isAdmin</code> flag flips between <code>SELLER</code> and <code>ADMIN</code> ; <code>UpdateSaleDto</code> bounds enforced (1–90%, 60-char label); <code>ForbiddenException</code> surfaces as 403.
<code>order.controller</code>	14	Missing address fields rejected; non-numeric <code>totalAmount</code> rejected; <code>/my</code> requires auth; 403 on unauthenticated GET/PATCH <code>/order/:id</code> ; dashboard scoping by role; route parameter parsed to <code>number</code> .

Table 4.5: Backend controller integration tests

These tests prove that DTO validation, guard wiring, and exception mapping behave correctly when the framework is in the loop — bugs that would not surface in pure service unit tests because Nest is not exercised there.

4.6.5 Frontend Tests (Vitest)

The frontend test suite covers the surfaces with the highest business value per line of test code and has grown to **108 tests** across 18 files: the Zustand stores (cart, auth, category, admin, and the undo/redo customization editor) that hold client state; the data and premium hooks (product/store queries, infinite-scroll pagination, the session → store sync, and the premium-unlock rule) exercised through a **QueryClientProvider** harness with mocked API modules; the presentational components (**ProductCard**, **StoreCard**, **NotificationBell**) and the checkout page; and the pure customization and error-handling libraries.

Suite	Tests	Behaviour under test
<code>cart.store</code>	9	<code>addItem</code> default and explicit quantity; merge on re-add; <i>stock cap on merge and update</i> ; <code>updateQuantity(0)</code> removes the line; <code>clearCart</code> ; multiple stores coexist in a single cart.
<code>auth / category / admin / customization.editor</code> stores	31	Session set/clear and <code>isAuthenticated</code> ; lazy category load with already-loaded guard and error swallow; admin tab switching; the customization editor's undo/redo stacks (with no-op guards), <code>setSection/replaceAll/applyPreset</code> , dirty-check, and 50-entry history cap.
premium + data hooks	23	<code>useCustomizationUnlocked</code> (unlock via session <i>or</i> the premium-status API); <code>useIsPremium</code> ; <code>useProducts</code> routing across the multi-select vs. legacy single-select paths; <code>useStores</code> search-vs-list branch and <code>getNextPageParam</code> pagination; <code>useAuthStoreSync</code> ; <code>usePlatformSettings</code> fallbacks.
<code>ProductCard</code>	11	Name and price rendered; no sale badge when <code>salePrice</code> is <code>null</code> or equals <code>displayPrice</code> ; discount percentage correctly rounded (19.99 → 15.99 displays "-20%"); dual-price layout when on sale; Out-of-Stock overlay; OOS hides the sale badge; default and custom <code>href</code> .
<code>StoreCard + NotificationBell</code>	24	Sale-active rule (enabled, positive discount, not expired), image-URL resolution and banner fallback chain, custom/default sale label; the unread-badge cap (hidden at 0, exact count, "99+"), loading/empty/list states, and mark-read-only-when-unread.
<code>CheckoutPage</code>	1	Merges the cart to <code>{productId, quantity}</code> pairs, posts a single checkout request, and swaps the

4.6.6 Continuous Integration

All checks run as gating jobs in the GitHub Actions workflow before the Docker images are built. Each gate job runs *lint*, *build*, and *tests* — `test-backend` (ESLint + `nest build` + Jest) and `test-frontend` (ESLint + `tsc` + `vite build` + Vitest) — and the `build-backend/build-frontend` jobs declare `needs: test-backend` and `needs: test-frontend` respectively. A failing lint rule, type error, or test therefore prevents any Docker image from being pushed to Docker Hub, and by extension prevents deployment to the DigitalOcean droplet. Building in CI catches the class of type error that the test transform skips (a `tsc`-only failure), and the lint gate is scoped to hand-written code (the generated Prisma client is excluded). The mechanics of this gate are detailed in Section 5.3.

4.6.7 What is Not Covered

The suite deliberately stops short of full end-to-end testing. There are no Playwright or Cypress tests that drive a real browser against the deployed application, and no integration tests against a real MariaDB instance. These were considered out of scope for a six-month PFE: a meaningful E2E suite requires fixtures, seeded data, and a running stack, which would have consumed time better spent on the core feature set. The current strategy — tight unit coverage on business rules plus thin HTTP-layer integration tests — catches the majority of regressions in the parts of the codebase where they would do the most damage, at a fraction of the engineering cost.

Key Takeaways

- Cheebo ships 445 tests (337 backend, 108 frontend) running in a few seconds and gating every CI build.
- Backend tests use a three-tier pyramid: pure logic (`validate-env`, `tndToStripeUsdMinor`, `ApiKeyGuard`), service-level unit tests with a mocked `PrismaService`, and controller-level integration tests with the real Nest pipeline, including a full-application smoke test of the deny-by-default guard wiring.
- Frontend tests use Vitest + React Testing Library to cover the Zustand stores, the data and premium hooks (via a `QueryClientProvider` harness), the card and notification components, and the Stripe checkout step.
- Each CI gate runs lint, build, and tests: a failing lint rule, type error, or test blocks the Docker image push and deployment, providing a hard regression gate without manual review.

Chapter Conclusion

This chapter walked through the implementation of Cheebo across the backend, frontend, and AI-integration layers, and then through the test suite that validates them. The development environment was set up as a **pnpm** monorepo with NestJS, React + Vite, and three n8n workflows orchestrated over webhooks. Authentication and role-based access control were enforced by a global **AuthGuard** plus a **@Roles** decorator; file uploads were handled by Multer; transactional emails were sent through Nodemailer. The administrator, seller, and customer interfaces were illustrated through annotated screenshots covering the principal flows. Finally, the test suite was presented as a layered pyramid running on every CI build, gating the Docker image push. The next chapter turns to the infrastructure that hosts this code in production.

Chapter 5 Infrastructure and Deployment

This chapter covers Docker containerisation, infrastructure as code with Terraform, the GitHub Actions CI/CD pipeline, DNS management, and the production environment.

5.1 Containerisation with Docker

5.1.1 Dockerfiles (Frontend and Backend)

Both the backend and the frontend ship as multi-stage Docker [19] images, which keeps the final runtime image small by discarding build-time dependencies. Both Dockerfiles are reproduced in Appendix D.

The **backend** image uses a two-stage `node:20-alpine` build. The *builder* stage enables `pnpm` through Corepack — pinned to a fixed version, since the floating `latest` tag moved to a release that requires a newer Node and broke the build — installs dependencies from the frozen lockfile, runs `prisma generate`, compiles the TypeScript to `dist/`, and then prunes dev dependencies with `pnpm prune -prod`. The *production* stage copies only the compiled output, the generated Prisma client, the *production node_modules*, and the schema — not the source tree. (The Prisma CLI is treated as a production dependency because `migrate deploy` runs at start-up.) The container runs as the image’s unprivileged `node` user rather than `root`, with only the `uploads` directory made writable. Its start command first runs `prisma migrate deploy` (applying any pending migrations against the live database) and then launches the compiled server, so a fresh deployment self-migrates with no manual step.

The **frontend** image is also two-stage: a `node:20-alpine` builder runs `pnpm run build` to emit the static Vite bundle, and the production stage serves it from the unprivileged `nginxinc/nginx-unprivileged` image, which runs as a non-root user (uid 101) and listens on port 8080 (Caddy proxies to it there). Because the API URL is only known at deploy time (it depends on the domain), the build bakes in a placeholder token and an `entrypoint.sh` script rewrites it to the real `VITE_API_URL` on container start — a single image that can target any environment without rebuilding. The bundled Nginx config serves the SPA with an `index.html` fallback, reverse-proxies `/api/` to the backend, and gives the `/notification/stream` SSE endpoint special handling (buffering and gzip disabled, long read timeout) so live notifications are not

held back by the proxy.

5.1.2 Docker Compose Configuration

The full stack is orchestrated by a single `docker-compose.yml` (Appendix E) declaring five services and five named volumes:

- **db** — `mariadb:11` with a health-check (`mariadb-admin ping`) so dependants can wait until the database is genuinely ready, persisted to the `db_data` volume. A dedicated least-privilege application user (`DB_APP_USER`) is created on first boot and used by the backend, so the application never connects as `root`.
- **backend** — the NestJS image, which runs with `NODE_ENV=production` (which, among other things, disables Swagger), `depends_on` the database *being healthy*, reads all configuration from environment variables, and mounts the `uploads` volume for user-uploaded media.
- **frontend** — the Nginx image serving the React bundle; it exposes no host port and is reached only through the Caddy proxy.
- **caddy** — the public entrypoint, the only service that publishes host ports (80 and 443). It terminates HTTPS and reverse-proxies to the frontend (Section 5.1.3).
- **n8n** — the automation engine, publishing 5678 for inbound webhooks and persisting workflows and credentials to `n8n_data`.

Every service is set to `restart: always`, so the stack recovers automatically after a host reboot. Configuration is injected through a `.env` file written by the deploy job (Section 5.3), keeping secrets out of the committed Compose file.

5.1.3 TLS Termination with Caddy

Public traffic does not reach the application containers directly: it is fronted by **Caddy** [20], a modern reverse proxy whose defining feature is *automatic HTTPS*. On first start, Caddy reads the domain from its environment, requests a TLS certificate from Let's Encrypt over the ACME protocol (the HTTP-01 / TLS-ALPN-01 challenge, served on the ports it already owns), installs it, and renews it before expiry — with no certbot cron job, no manual key handling, and no application involvement.

The configuration is a short, env-driven `Caddyfile` (Appendix E) with two site blocks: the `www` subdomain issues a permanent redirect to the apex so that the platform has a single canonical HTTPS origin, and the apex block reverse-proxies the decrypted traffic to the internal Nginx frontend on `frontend:8080`. The apex block also sets a baseline of security response headers — HSTS (`Strict-Transport-Security` with a one-year max-age), `X-Content-Type-Options: nosniff`, `X-Frame-Options`, and

Referrer-Policy — and strips the **Server** banner, so every browser response carries them with no change to application code. Keeping one canonical origin matters beyond aesthetics: it must match the backend's **BETTER_AUTH_URL** and **trustedOrigins** so that session cookies — now issued with the **Secure** attribute because the origin is **https** — are accepted consistently. The certificate and ACME account state are persisted to the **caddy_data** volume, so redeployments reuse the existing certificate and never risk hitting Let's Encrypt's issuance rate limits.

Introducing Caddy required no change to the application code. Because Better-Auth derives the **Secure** cookie flag from its **baseURL**, the cutover to HTTPS was achieved simply by setting **APP_URL** to the **https** origin in the deploy job; this value cascades to **BETTER_AUTH_URL**, **FRONTEND_URL** (the CORS and trusted origin), and the frontend's **VITE_API_URL**.

5.1.4 Multi-Service Networking

All services communicate over a private Docker bridge network, meaning the frontend, backend, database, and n8n are never directly exposed to the public internet. Only the Caddy proxy publishes ports (80 and 443). Figure 5.1 shows the network topology: Caddy terminates HTTPS and forwards to the internal Nginx frontend, which in turn proxies all API paths to the backend service over the internal network.

[IMAGE TO INSERT: Docker Compose bridge network diagram]

Figure 5.1: Docker Compose network architecture

5.2 Infrastructure as Code with Terraform

5.2.1 DigitalOcean Provider

The entire production environment is described declaratively with Terraform [21], using the official `digitalocean/digitalocean` provider [24] (~> 2.0). A single `main.tf` holds the provider block — authenticated by a DigitalOcean API token passed as the `do_token` variable — and all resource declarations. Describing the infrastructure as code means the droplet, network, and DNS can be recreated identically from scratch with one `terraform apply`, and any change is reviewable as a diff rather than a series of clicks in a web console.

5.2.2 VPC, Droplet and Firewall Resources

Three resources define the compute environment:

- **`digitalocean_vpc`** — a private network (192.168.1.0/24) in the target region, isolating the droplet’s private interface.
- **`digitalocean_droplet`** — an `ubuntu-24-04-x64` droplet of the configured size, attached to the VPC, with the operator’s SSH key injected for access.
- **Firewall (UFW)** — configured through the droplet’s `user_data` cloud-init script rather than a separate resource.

The `user_data` script is the key to a zero-touch first boot: on creation, the droplet installs Docker Engine and the Compose plugin from Docker’s official APT repository, enables the service, and then configures UFW to *deny all inbound by default* while allowing only SSH (22), HTTP (80), HTTPS (443), and the n8n webhook port (5678). Because this runs as part of provisioning, a freshly created droplet is ready to receive the Compose stack without any manual server setup — the CI/CD deploy job only has to copy the Compose file and bring the stack up.

5.2.3 DNS Management with DigitalOcean

Rather than managing DNS records at the domain registrar (name.com) through a separate API, the project delegates DNS entirely to DigitalOcean using the same Terraform provider that manages the droplet. Two resources are declared in `main.tf`:

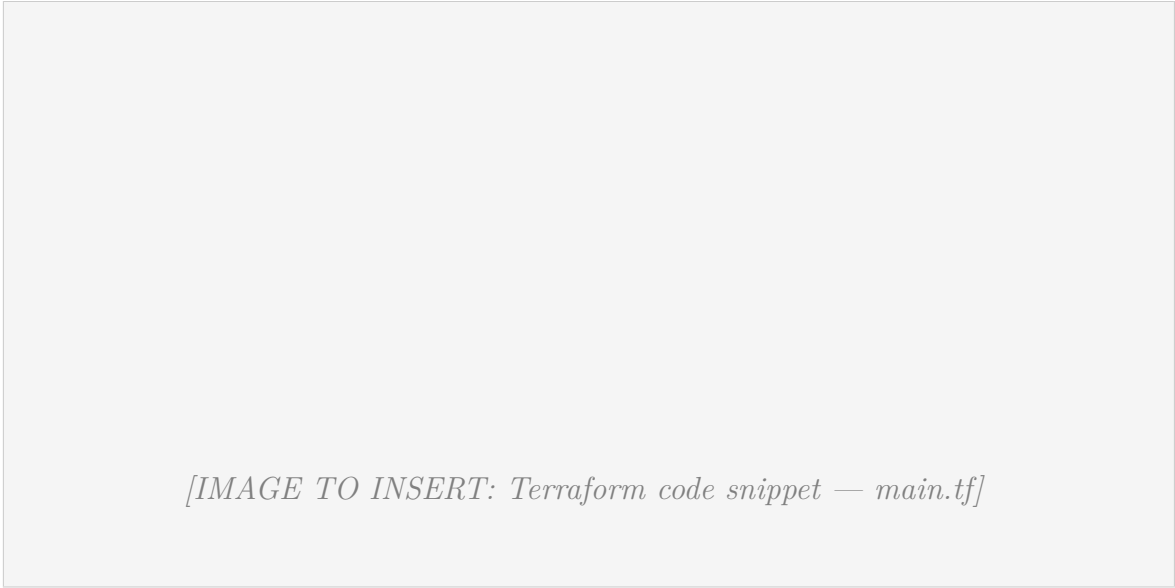
- **`digitalocean_domain`** — creates the DNS zone for `nadimjebali.engineer` on DigitalOcean’s authoritative nameservers and automatically adds the apex (`@`) A record pointing to the droplet’s IPv4 address.
- **`digitalocean_record`** — adds a second A record for the `www` subdomain, also pointing to the droplet.

Both records reference `digitalocean_droplet.cheebo.ipv4_address` directly. This means that if the droplet is ever replaced (e.g. after a destructive Terraform change), Terraform updates both DNS records in the same `apply` run that creates the new droplet, with no manual intervention required.

The domain's nameservers are delegated to DigitalOcean (`ns1-ns3.digitalocean.com`) from the name.com registrar panel, which is a one-time configuration step. After that, A-record updates propagate in under five minutes thanks to a 300-second TTL.

5.2.4 Remote State Management with DigitalOcean Spaces

Terraform state is stored remotely in a DigitalOcean Spaces bucket configured as an S3-compatible backend. This ensures that every CI/CD run reads from and writes to a single shared state file, preventing conflicts if the workflow is triggered concurrently. Figure 5.2 shows the key resource declarations in `main.tf`, including the VPC, the droplet, and the DNS records.



[IMAGE TO INSERT: Terraform code snippet — main.tf]

Figure 5.2: Terraform resources

5.3 CI/CD Pipeline with GitHub Actions

5.3.1 Workflow Overview

The CI/CD pipeline is defined as a single GitHub Actions [23] workflow file that runs on every push to the `main` branch. Figure 5.3 presents the topology: two check jobs — *test-backend* (ESLint, `nest build`, Jest) and *test-frontend* (ESLint, `tsc`, `vite build`, Vitest) — run in parallel and gate the corresponding image-build jobs, *build-backend* and *build-frontend*, via the `needs:` dependency. A failing lint rule, type error, or test therefore short-circuits the entire pipeline before any Docker image is pushed to Docker

Hub. The *provision* job (Terraform) runs in parallel; before applying, it imports any pre-existing DigitalOcean resources (the VPC, droplet, and DNS domain) into the Terraform state, so **apply** reconciles them in place rather than failing on a name collision when the account already holds them. The *deploy* job runs last and SSH-deploys the composed stack to the droplet once the two builds and the provisioning step all complete. The full test catalogue gating this pipeline is presented in Section 4.6.

[IMAGE TO INSERT: CI/CD pipeline diagram (lint + build + test gates → image push → provision → deploy)]

Figure 5.3: GitHub Actions CI/CD pipeline

5.3.2 Build Stage (Docker Build and Push to Docker Hub)

The **build-backend** and **build-frontend** jobs each run only after their respective test job passes. Both use Docker Buildx with the GitHub Actions cache backend (**cache-from/ cache-to** with **type=gha**), so unchanged layers — notably the **pnpm install** layer — are reused across runs, cutting build times substantially. Each job logs in to Docker Hub with credentials drawn from repository secrets, builds the multi-stage image from its package directory, and pushes it to the **sirvinny/cheebo-backend** and **sirvinny/cheebo-frontend** repositories under two tags: **:latest** and an immutable commit-SHA tag. The deploy step pins the Compose stack to the SHA tag (via an **IMAGE_TAG** variable), so every deployment runs an exact, identifiable build and a roll-back is simply a redeploy of an earlier commit’s tag.

5.3.3 Deployment Stage (SSH and Docker Compose)

The `deploy` job runs last, gated on `needs: [provision, build-backend, build-frontend]` so it only fires once the infrastructure exists and both images are published. It performs two actions over SSH to the droplet (whose IP comes from the `provision` job's Terraform output):

1. **Copy** the `docker-compose.yml`, the `Caddyfile`, and the version-controlled `n8n-workflows/` and `n8n-credentials/` template directories to `/app` on the droplet via `scp`.
2. **Run** a remote script that waits for cloud-init to finish, writes the `.env` file from the workflow's environment, then executes `docker compose pull` followed by `docker compose up -d -force-recreate`.

Because the images are pulled fresh and the backend self-applies migrations on start, a push to `main` results in a fully updated, migrated production stack with no manual intervention — the deployment is idempotent and repeatable.

5.3.4 Automated n8n Provisioning

The same deploy step also provisions the n8n instance, so the AI features work on a freshly created droplet with no manual clicking in the n8n editor. The workflow definitions and credential *templates* are version-controlled under `n8n-workflows/` and `n8n-credentials/`; the remote script renders the templates with `envsubst`, injecting the provider API keys and the database/webhook secrets from the environment (an explicit variable allow-list leaves n8n's own `$json` expressions untouched). A dedicated one-shot `n8n-init` container then imports the credentials and workflows and activates them, running to completion *before* the main n8n service starts (`depends_on` with `service_completed_successfully`), which avoids two processes writing n8n's database simultaneously. Because the imports upsert by identifier, editing a workflow in the repository and redeploying updates the live instance — a GitOps-style flow that keeps the entire AI layer reproducible.

5.3.5 Environment Secrets Management

No secret is ever committed to the repository. Sensitive values (database root password, the least-privilege `DB_APP_PASSWORD`, `BETTER_AUTH_SECRET`, admin password, SMTP password, n8n webhook secret and encryption key, the Gemini and Groq API keys, DigitalOcean and Spaces tokens, the SSH private key) are stored as GitHub Actions **secrets**; non-sensitive configuration (domain, ports, feature limits, SMTP host, the `DB_APP_USER` name) is stored as GitHub Actions **variables**. The deploy job interpolates both groups into the `.env` file it writes on the droplet at deploy time. Terraform secrets reach the `provision` job the same way, including the Spaces credentials used

to read and write the remote state backend. This keeps the single source of truth for every credential inside GitHub’s encrypted store, with the droplet’s `.env` as the only materialised copy — created at deploy time and never leaving the host.

5.4 Production Environment

5.4.1 DigitalOcean Droplet Specifications

The production workload runs on a single DigitalOcean droplet provisioned by Terraform with the following specifications:

Property	Value
Region	Frankfurt (fra1)
Size	s-2vcpu-2gb (2 vCPUs, 2 GB RAM)
Image	Ubuntu 24.04 LTS
VPC	cheebo-vpc (192.168.1.0/24)
Public URL	https://nadimjebali.engineer
DNS	Managed by DigitalOcean (Terraform)

The application is accessed exclusively through the domain name `nadimjebali.engineer`. The raw droplet IP is reserved for SSH access by the CI/CD pipeline and is never exposed to end users. CORS on the backend is configured with the domain as the single trusted origin, so any attempt to reach the API directly from the IP is rejected by the browser’s same-origin policy.

5.4.2 Production Service Architecture

Figure 5.4 depicts the production environment as deployed on the DigitalOcean droplet. All five Docker Compose services run on the same host inside a private bridge network; only the Caddy proxy is reachable from the public internet, serving the platform over HTTPS at the domain `https://nadimjebali.engineer`.

[IMAGE TO INSERT: Production environment diagram (Droplet + services)]

Figure 5.4: Production architecture

5.4.3 n8n Deployment Alongside the Application

n8n runs as a fifth container in the same Compose stack rather than as an external SaaS dependency. This co-location is deliberate: the backend reaches the workflows over the private bridge network at `http://n8n:5678/webhook/...`, so verification and chat calls never leave the host, and the only n8n port exposed publicly (5678) is for *inbound* webhook delivery and the editor UI. Workflow definitions and provider credentials are encrypted with `N8N_ENCRYPTION_KEY` and persisted to the `n8n_data` volume, so they survive container re-creation across deployments.

Hosting the automation engine on the same droplet keeps the entire platform — application, database, and AI orchestration — within a single, reproducible Compose deployment and a single monthly hosting cost, which suits the scale and budget of a graduation project. The trade-off is that n8n shares the droplet’s 2 vCPU/2 GB with the rest of the stack; for a production launch at scale it would be moved to its own instance, but at current load the shared host is comfortable.

Key Takeaways

- Both applications ship as multi-stage Docker images; the five-service Compose stack exposes only the Caddy proxy, which terminates HTTPS with automatically renewed Let’s Encrypt certificates.
- The entire production environment — VPC, droplet, firewall and DNS — is declared

in Terraform with remote state in DigitalOcean Spaces; the DNS records follow the droplet IP automatically, so a full re-provision converges in under ten minutes end-to-end.

- The GitHub Actions pipeline gates every deployment on the test suite, pins deployments to immutable commit-SHA image tags, and provisions the n8n workflows and credentials on the droplet automatically.
- No secret is ever committed: credentials live in GitHub's encrypted store and materialise only as the droplet's `.env` file at deploy time.

Chapter Conclusion

This chapter presented the infrastructure that carries Cheebo in production. The five services were containerised with multi-stage Docker builds and orchestrated by a single Compose file, fronted by a Caddy proxy that provides automatic HTTPS. Terraform describes the entire DigitalOcean environment — droplet, VPC, firewall rules and DNS — as version-controlled code with shared remote state, and the GitHub Actions pipeline chains testing, image builds, provisioning and SSH deployment into a single push-to-deploy workflow, including the automated provisioning of the n8n AI layer. The platform is thereby reproducible from an empty cloud account to a running, TLS-secured marketplace with no manual step. The general conclusion that follows takes stock of the project as a whole.

General Conclusion

This project set out to design and build Cheebo, a multi-vendor marketplace for the Tunisian market with AI-assisted moderation, as a final-year project at TEK-UP in partnership with NeuralBey. The preceding chapters traced the work from market context and requirements, through system design, to implementation, testing, and deployment. This conclusion summarises what was achieved, measures it against the original plan, reflects on the challenges met along the way, states the limitations that remain, and outlines the directions in which the platform could grow.

Summary of Achievements

The project delivered a complete, deployed, three-actor marketplace. Customers can browse stores and products, search the catalogue, build a multi-store cart, and place orders; sellers can apply for an account, open a store, manage a product catalogue, run store-wide sales, and redesign their storefront visually through a Craft.js editor; administrators can moderate stores and products, manage users, curate featured content, and query the platform in natural language. On top of the functional surface, three cross-cutting capabilities set the project apart from a textbook CRUD application:

- **AI integration** — product and store verification, a database chat assistant, and AI storefront redesign, all implemented as versioned n8n workflows behind webhooks.
- **A real test suite** — 445 automated tests across backend and frontend, gating every CI build.
- **A full DevOps pipeline** — containerised services, infrastructure as code with Terraform, and a GitHub Actions pipeline that tests, builds, provisions, and deploys to a live domain with no manual step.

Implemented Features vs Initially Planned Features

The large majority of the Product Backlog defined in Chapter 2 was implemented. All *Must-have* and *Should-have* stories — authentication, store and product management, the order system, the admin dashboard, AI verification, and featured-content curation — are present in the deployed platform. Two *Could-have* items added mid-project, the store-wide sale feature and AI storefront redesign, were also completed.

The principal gap against the original vision is **online payment**: orders are currently placed on a cash-on-delivery basis rather than through an integrated payment gateway. This was a conscious scoping decision — integrating and testing a payment provider reliably was judged a poor use of the remaining time relative to strengthening the core marketplace and its DevOps and test foundations. It is the first item on the future-work list below.

Challenges Encountered and Solutions Provided

Several non-trivial problems were solved during development:

- **Structured output from an LLM.** The AI storefront redesign needs the model to return JSON conforming exactly to the `StoreCustomization` schema. Raw model output is not reliably valid, so a sanitisation step parses the response, validates every colour with a regex, clamps numeric fields, and falls back to safe defaults — turning a best-effort model into a dependable component.
- **Premium gating without data loss on downgrade.** Free accounts must be prevented from editing premium customization fields, yet a seller whose subscription lapses must not lose their existing design. The diff-based `findViolation` check allows a field to remain at its current value while blocking changes — behaviour pinned by dedicated unit tests.
- **Zero-touch, repeatable deployment.** Coordinating Terraform provisioning, image builds, database migrations, and SSH deployment into one idempotent pipeline required the droplet to self-configure via cloud-init and the backend to self-migrate on start, so a push to `main` converges to a fully updated production stack unattended.
- **Testing a codebase wired to ESM-only and native dependencies.** Better-Auth (ESM-only) and the Prisma 7 client broke the default Jest setup; module-name mappers and module-level guard stubs were introduced so the suite runs without a live database.

Current Implementation Limitations

The platform is a complete prototype, not yet a production launch. The main limitations are:

- **No online payment** — orders are cash-on-delivery only.
- **Single-droplet, shared-host deployment** — the application, database, and n8n

share one 2 vCPU/2 GB droplet, which suits the project's scale but is not horizontally scalable as-is.

- **No end-to-end test layer** — the test suite covers units and HTTP-layer integration, but not full browser-driven flows against the deployed stack (Section 4.6).

Future Improvements

Natural next steps, roughly in order of value:

- **Online payment** — integrate a Tunisian payment gateway such as Konnect to support card and e-wallet checkout alongside cash-on-delivery.
- **Mobile application** — a React Native client reusing the existing REST API and authentication.
- **Self-hosted local AI** — run the moderation and chat models locally (e.g. via LM Studio / Ollama) to remove the dependency on external LLM providers and their per-call cost.
- **A dedicated recommendation engine** — evolve the current tag-overlap recommendations into a collaborative- or content-based model trained on order history.
- **Advanced analytics** — richer seller and platform dashboards (cohorts, conversion funnels, revenue forecasting) building on the existing analytics service.
- **Production hardening** — an end-to-end test suite and a path to multi-host scaling (the application, database, and n8n currently share a single droplet).

Bibliography and Webography

- [1] K. Schwaber and J. Sutherland, *The Scrum Guide*, 2020. <https://scrumguides.org>
- [2] K. Beck et al., *Manifesto for Agile Software Development*, 2001. <https://agilemanifesto.org>
- [3] C. Larman and V. R. Basili, “Iterative and Incremental Development: A Brief History,” *IEEE Computer*, vol. 36, no. 6, pp. 47–56, 2003.
- [4] R. T. Fielding, *Architectural Styles and the Design of Network-based Software Architectures*, PhD dissertation, University of California, Irvine, 2000 (REST).
- [5] Mozilla Developer Network — HTTP, REST and web platform reference. <https://developer.mozilla.org>
- [6] NestJS Official Documentation — <https://docs.nestjs.com>
- [7] React Official Documentation — <https://react.dev>
- [8] Vite Documentation — <https://vite.dev>
- [9] Prisma ORM Documentation — <https://www.prisma.io/docs>
- [10] TanStack Query Documentation — <https://tanstack.com/query>
- [11] Zustand Documentation — <https://zustand.docs.pmnd.rs>
- [12] Better-Auth Documentation — <https://www.better-auth.com/docs>
- [13] Tailwind CSS Documentation — <https://tailwindcss.com/docs>
- [14] Craft.js Documentation — <https://craft.js.org>
- [15] Jest Documentation — <https://jestjs.io/docs>
- [16] Vitest Documentation — <https://vitest.dev>
- [17] Testing Library Documentation — <https://testing-library.com/docs>
- [18] MariaDB Documentation — <https://mariadb.com/kb/en>

- [19] Docker Documentation — <https://docs.docker.com>
- [20] Caddy Server Documentation — <https://caddyserver.com/docs>
- [21] Terraform Documentation — <https://developer.hashicorp.com/terraform>
- [22] n8n Documentation — <https://docs.n8n.io>
- [23] GitHub Actions Documentation — <https://docs.github.com/en/actions>
- [24] DigitalOcean Developer Docs — <https://docs.digitalocean.com>
- [25] Groq API Documentation — <https://console.groq.com/docs>
- [26] Google Gemini API Documentation — <https://ai.google.dev/gemini-api/docs>

Chapter A Complete Prisma Schema

The data model is split across one file per domain under `backend/prisma/schema/`; the files are concatenated below.

Listing A.1: `backend/prisma/schema/` — concatenated

```
model Session {
  id          String    @id
  expiresAt   DateTime
  token       String    @unique
  createdAt   DateTime
  updatedAt   DateTime
  ipAddress   String?
  userAgent   String?
  userId      String

  user User @relation(fields: [userId], references: [id], onDelete: Cascade)

  @@map("session")
}

model Account {
  id          String    @id
  accountId   String
  providerId   String
  userId      String
  accessToken  String?   @db.Text
  refreshToken String?   @db.Text
  idToken     String?   @db.Text
  accessTokenExpiresAt DateTime?
  refreshTokenExpiresAt DateTime?
  scope       String?
  password    String?
  createdAt   DateTime
  updatedAt   DateTime

  user User @relation(fields: [userId], references: [id], onDelete: Cascade)

  @@map("account")
}

model Verification {
  id          String    @id
  identifier   String
  value       String    @db.Text
  expiresAt   DateTime
  createdAt   DateTime?
  updatedAt   DateTime?

  @@map("verification")
}
```

```

}
datasource db {
  provider = "mysql"
}

generator client {
  provider      = "prisma-client"
  output        = "../../src/generated/prisma"
  moduleFormat  = "cjs"
}

model Category {
  id          Int      @id @default(autoincrement())
  name        String
  createdAt   DateTime @default(now())
  updatedAt   DateTime @updatedAt

  subcategories Subcategory[]
}

model FeaturedProduct {
  id          Int      @id @default(autoincrement())
  productId   Int      @unique
  position    Int      @default(0)

  product Product @relation(fields: [productId], references: [id], onDelete: Cascade)
}

model FeaturedStore {
  id          Int      @id @default(autoincrement())
  storeId     Int      @unique
  position    Int      @default(0)

  store Store @relation(fields: [storeId], references: [id], onDelete: Cascade)
}

model Notification {
  id          Int      @id @default(autoincrement())
  userId      String
  type        String
  title       String
  message     String
  read        Boolean  @default(false)
  metadata    Json?
  createdAt   DateTime @default(now())

  user User @relation(fields: [userId], references: [id], onDelete: Cascade)
}

model OrderItems {
  id          Int      @id @default(autoincrement())
  orderId     Int
  productId   Int
  quantity    Int
  unitPrice   Float
  subtotal    Float

  createdAt   DateTime @default(now())
  updatedAt   DateTime @updatedAt

  order Order @relation(fields: [orderId], references: [id])
  product Product @relation(fields: [productId], references: [id])
}
model Order {

```

```

    id          Int          @id @default(autoincrement())
    city         String
    state        String
    country      String
    zipCode      String
    streetAddress String
    notes        String?
    userId       String
    storeId      Int
    status       OrderStatus @default(PENDING)
    totalAmount  Float
    createdAt    DateTime @default(now())
    updatedAt    DateTime @updatedAt

    user      User          @relation(fields: [userId], references: [id])
    store     Store         @relation(fields: [storeId], references: [id])
    orderItems OrderItems[]

}model ProductImage {
  id          Int          @id @default(autoincrement())
  url         String
  alt         String?
  productId   Int
  createdAt   DateTime @default(now())

  product      Product @relation("ProductImages", fields: [productId],
    references: [id], onDelete: Cascade)
  thumbnailOfProduct Product? @relation("ProductThumbnail")
}
model Product {
  id          Int          @id @default(autoincrement())
  name        String
  description  String
  price       Float
  displayPrice Float
  stock       Int
  status      ProductStatus @default(AVAILABLE)
  isBanned    Boolean      @default(false)
  verificationStatus VerificationStatus @default(PENDING)
  verificationNote String?
  aiReviewed  Boolean      @default(false)
  aiReviewNote String?
  adminReviewed Boolean    @default(false)
  subcategoryId Int
  thumbnailId  Int?        @unique
  createdAt    DateTime @default(now())
  updatedAt    DateTime @updatedAt
  storeId      Int

  subcategory Subcategory @relation(fields: [subcategoryId], references: [id])
  thumbnail   ProductImage? @relation("ProductThumbnail", fields: [thumbnailId],
    references: [id])
  images      ProductImage[] @relation("ProductImages")
  tags        ProductTag[] @relation("ProductTags")

  store Store @relation(fields: [storeId], references: [id])

  orderItems OrderItems[]
  featuredProduct FeaturedProduct?
}

```

```

model ProductTag {
  id          Int          @id @default(autoincrement())
  name        String        @unique
  products    Product[]    @relation("ProductTags")
}

enum SellerApplicationStatus {
  PENDING
  APPROVED
  REJECTED
  MORE_INFO_REQUESTED
}

model SellerApplication {
  id          Int          @id @default(autoincrement())
  userId       String        @unique
  status       SellerApplicationStatus @default(PENDING)
  fullName     String
  phoneNumber   String
  homeAddress   String
  businessDescription String
  websiteUrl    String?
  idDocumentUrl String
  businessLicenseUrl String?
  adminNote     String?
  createdAt     DateTime     @default(now())
  updatedAt     DateTime     @updatedAt

  user User @relation(fields: [userId], references: [id], onDelete: Cascade)
}

model Setting {
  key   String @id
  value String @db.Text
}

model Store {
  id          Int          @id @default(autoincrement())
  name        String
  slug         String        @unique
  description  String
  logoUrl     String?
  thumbnailUrl String?
  currentStatus StoreStatus @default(PENDING)
  template     StoreTemplate @default(CLASSIC)
  customization Json         @default("{}")
  aiReviewed    Boolean       @default(false)
  aiReviewNote  String?
  adminReviewed Boolean       @default(false)
  saleEnabled   Boolean       @default(false)
  saleDiscountPercent Int      @default(0)
  saleLabel     String        @default("")
  saleEndsAt    DateTime?
  createdAt     DateTime     @default(now())
  updatedAt     DateTime     @updatedAt
  userId        String

  products    Product[]
  orders      Order[]
  statusLogs  StoreStatusLog[]
  featuredStore FeaturedStore?
}

```

```

    user User @relation(fields: [userId], references: [id])
}model StoreStatusLog {
  id          Int          @id @default(autoincrement())
  status      StoreStatus   @default(PENDING)
  reason      StoreStatusReason?
  title       String
  description  String?
  isResolved  Boolean        @default(false)
  resolvedAt  DateTime?
  createdAt   DateTime       @default(now())

  storeId     Int
  store       Store          @relation(fields: [storeId], references: [id])
}enum StoreTemplate {
  DEFAULT
  MINIMAL
  MODERN
  CLASSIC
}
model Subcategory {
  id          Int          @id @default(autoincrement())
  name        String
  categoryId  Int
  createdAt   DateTime @default(now())
  updatedAt   DateTime @updatedAt

  category Category @relation(fields: [categoryId], references: [id])

  products Product[]
}
model User{
  id          String      @id
  name        String
  email       String      @unique
  emailVerified Boolean
  phone       String?
  image       String?
  role        UserRole    @default(CUSTOMER)
  isBanned    Boolean     @default(false)
  isPremium   Boolean     @default(false)
  premiumExpiresAt DateTime?
  createdAt   DateTime    @default(now())
  updatedAt   DateTime    @updatedAt

  stores      Store[]
  orders      Order[]
  accounts    Account[]
  sessions    Session[]
  notifications Notification[]
  sellerApplication SellerApplication?
}enum OrderStatus {
  PENDING
  CONFIRMED
  PROCESSING
  SHIPPED
  DELIVERED
  CANCELLED
  REFUNDED

```

```
}enum ProductStatus {  
  AVAILABLE  
  UNAVAILABLE  
}  
enum StoreStatus {  
  PENDING  
  ACTIVE  
  SUSPENDED  
  REJECTED  
}  
enum StoreStatusReason {  
  VIOLATION_OF_TERMS  
  EMAIL_VERIFICATION  
  LEGAL_DOCUMENTS  
  PAYMENT_ISSUES  
  SCAM_SUSPICION  
  STORE_ACTIVATION  
  OTHER  
}  
enum UserRole {  
  CUSTOMER  
  SELLER  
  ADMIN  
}  
enum VerificationStatus {  
  PENDING  
  APPROVED  
  REJECTED  
}  
}
```

Chapter B API Endpoints Reference

The REST API exposes the routes below, grouped by resource. Routes under a dashboard or administrative scope are protected by the `AuthGuard`; the `/*/ai-review` routes are protected by the `ApiKeyGuard` (n8n callback).

Method	Endpoint
POST	/store
GET	/store
GET	/store/dashboard
GET	/store/search
GET	/store/store-names
GET	/store/by-slug/:slug
GET	/store/by-slug/:slug/page
GET	/store/by-slug/:slug/customization
GET	/store/:id
GET	/store/:id/page
PATCH	/store/:id
PATCH	/store/:id/sale
PATCH	/store/:id/customization
PATCH	/store/:id/status
PATCH	/store/:id/ai-review
POST	/store/:id/ai-redesign
POST	/store/:id/logo
POST	/store/:id/thumbnail
POST	/store/:id/banner
DELETE	/store/:id
POST	/product
GET	/product
GET	/product/dashboard
GET	/product/search
GET	/product/recommended
GET	/product/by-categories

Method	Endpoint
GET	/product/by-category/:categoryId
GET	/product/by-category/:categoryId/subcategory/:subcategoryId
GET	/product/by-store/:storeId
GET	/product/by-store/:storeId/cards
GET	/product/store-categories/:storeId
GET	/product/:id
PATCH	/product/:id
PATCH	/product/:id/ban
PATCH	/product/:id/unban
PATCH	/product/:id/verify
PATCH	/product/:id/ai-review
POST	/product/:id/image
DELETE	/product/:id
POST	/order
GET	/order
GET	/order/my
GET	/order/dashboard
GET	/order/:id
PATCH	/order/:id
DELETE	/order/:id
POST	/seller-application
GET	/seller-application
GET	/seller-application/my
PATCH	/seller-application/:id/status
GET	/home/featured
GET	/home/featured/ids
PUT	/home/featured/products
PUT	/home/featured/stores
GET	/analytics
GET	/analytics/store
GET	/notification
GET	/notification/unread-count
PATCH	/notification/:id/read
PATCH	/notification/read-all
POST	/chat
GET	/user

Method	Endpoint
GET	/user/display
GET	/user/premium-status
GET	/user/users-with-emails
GET	/user/:id
POST	/user
POST	/user/upgrade-premium
POST	/user/:id/avatar
PATCH	/user/:id
PATCH	/user/:id/ban
PATCH	/user/:id/unban
DELETE	/user/:id
CRUD	/category, /sub-category, /product-tag, /product-image, /store-status-log, /order-items (full POST/GET/PATCH/DELETE CRUD)
GET	/settings PUT /settings/name POST /settings/logo

Table B.1: Cheebo REST API endpoint reference

Chapter C n8n Workflow JSON Exports

The three workflows are committed under `n8n-workflows/` and can be re-imported into any n8n instance.

Listing C.1: Products/Stores verification workflow

```
{
  "name": "Products/Stores verification",
  "nodes": [
    {
      "parameters": {
        "httpMethod": "POST",
        "path": "cheebo-ai-verify",
        "authentication": "headerAuth",
        "responseMode": "responseNode",
        "options": {}
      },
      "type": "n8n-nodes-base.webhook",
      "typeVersion": 2.1,
      "position": [
        -400,
        200
      ],
      "id": "0ed38928-c624-4cbc-95dd-47789c76a264",
      "name": "Webhook",
      "webhookId": "39dde4c0-bac9-4541-ba35-4ce07eddeff8",
      "credentials": {
        "httpHeaderAuth": {
          "id": "m0GIyhphvAjucASz",
          "name": "Header Auth account"
        }
      }
    },
    {
      "parameters": {
        "jsCode": "// Turn the images array into one item per image so each is screened.\nconst b = $json.body ??\n{};\nconst images = Array.isArray(b.images) ? b.images : [];\nreturn images.map((path) => ({ json: {\n  imagePath: path }, pairedItem: { item: 0 } }));",
        "type": "n8n-nodes-base.code",
        "typeVersion": 2,
        "position": [
          -180,
          200
        ],
        "id": "a0000000-1111-2222-3333-444455556666",
        "name": "Split Images"
      },
      "type": "n8n-nodes-base.httpRequest",
      "typeVersion": 4.4,
      "position": [
        40,
        200
      ],
    }
  ]
}
```

```

    "id": "b1a2c3d4-1111-2222-3333-444455556666",
    "name": "Download Image"
  },
  {
    "parameters": {
      "promptType": "define",
      "text": "=Decide whether this marketplace submission is appropriate for a general-audience e-commerce platform. Judge BOTH the attached image and the text below.\nType: {{ $('Webhook').item.json.body.type }}\nName: {{ $('Webhook').item.json.body.name }}\nDescription: {{ $('Webhook').item.json.body.description }}",
      "messages": {
        "messageValues": [
          {
            "message": "You are a strict marketplace content moderator. Flag the submission if the IMAGE or the text shows nudity or sexual content, weapons, illegal drugs, hate symbols, graphic violence, or anything else inappropriate for a general-audience e-commerce marketplace -- even when the name and description look innocent. Base your decision primarily on what the image actually shows. Reply ONLY with valid minified JSON in exactly this shape: {\"decision\": \"approved\"|\"flagged\", \"reason\": \"short explanation\"}. No markdown, no code fences, no extra text."
          },
          {
            "type": "HumanMessagePromptTemplate",
            "messageType": "imageBinary"
          }
        ]
      }
    },
    "type": "@n8n/n8n-nodes-langchain.chainLlm",
    "typeVersion": 1.6,
    "position": [
      260,
      200
    ],
    "id": "c2b3d4e5-2222-3333-4444-555566667777",
    "name": "Moderate"
  },
  {
    "parameters": {
      "options": {}
    },
    "type": "@n8n/n8n-nodes-langchain.lmChatGoogleGemini",
    "typeVersion": 1.1,
    "position": [
      260,
      420
    ],
    "id": "fbfda46b-af43-45f3-9382-7e1fb0114023",
    "name": "Google Gemini Chat Model1",
    "credentials": {
      "googlePalmApi": {
        "id": "Lgn8GB0iIQdPIrUF",
        "name": "Google Gemini(PaLM) Api account"
      }
    }
  },
  {
    "parameters": {
      "jsCode": "// Aggregate the per-image decisions: flag the submission if ANY image is flagged.\nconst items = $input.all();\nlet decision = \"approved\";\nlet reasons = [];\nfor (const it of items) {\n  const raw = it.json.output ?? it.json.text ?? \"\";\n  let parsed;\n  try {\n    const cleaned = raw.replace(/'\"'\"'/g, '\"');\n    parsed = JSON.parse(cleaned);\n  } catch {\n    parsed = {\n      decision: \"flagged\", reason: \"AI response could not be parsed.\";\n    }\n    if (![\"approved\", \"flagged\"].includes(parsed.decision)) {\n      parsed.decision = \"flagged\";\n      parsed.reason = parsed.reason ?? \"Unexpected AI response.\";\n    }\n    if (parsed.decision === \"flagged\") {\n      decision = \"flagged\";\n      if (parsed.reason) reasons.push(parsed.reason);\n    }\n    const reason = decision === \"flagged\" ? reasons.join(\" | \") : \"All images passed AI screening.\";\n    return [{\n      json: { decision, reason }, pairedItem: { item: 0 } }];\n  }\n},\n    "type": "n8n-nodes-base.code",
    "typeVersion": 2,
    "position": [
      480,
      200
    ],
    "id": "1e7b8874-d3e9-4055-a9d2-9abf6a08e074",
    "name": "Combine Results"
  },
  {
    "parameters": {
      "method": "PATCH",

```

```

    "url": "=http://backend:3000/{{ $('Webhook').item.json.body.type }}/{{ $('Webhook').item.json.body.id }}/ai-review",
    "sendHeaders": true,
    "headerParameters": {
      "parameters": [
        {
          "name": "x-api-key",
          "value": "${N8N_WEBHOOK_SECRET}"
        }
      ]
    },
    "sendBody": true,
    "specifyBody": "json",
    "jsonBody": "={\n  \"decision\": \"{{ $json.decision }}\", \n  \"reason\": \"{{ $json.reason }}\"\n}",
    "options": {}
  },
  "type": "n8n-nodes-base.httpRequest",
  "typeVersion": 4.4,
  "position": [
    700,
    200
  ],
  "id": "8d787d86-9f59-4e9a-a88b-572da11087e4",
  "name": "HTTP Request1"
},
{
  "parameters": {
    "respondWith": "json",
    "responseBody": "={ \"ok\": true }",
    "options": {}
  },
  "type": "n8n-nodes-base.respondToWebhook",
  "typeVersion": 1.5,
  "position": [
    920,
    200
  ],
  "id": "71c95f21-32f0-4073-80dc-5a8b1d0c364e",
  "name": "Respond to Webhook1"
}
],
"pinData": {},
"connections": {
  "Webhook": {
    "main": [
      [
        {
          "node": "Split Images",
          "type": "main",
          "index": 0
        }
      ]
    ]
  },
  "Split Images": {
    "main": [
      [
        {
          "node": "Download Image",
          "type": "main",
          "index": 0
        }
      ]
    ]
  },
  "Download Image": {
    "main": [
      [
        {
          "node": "Moderate",
          "type": "main",
          "index": 0
        }
      ]
    ]
  },
  "Google Gemini Chat Model1": {
    "ai_languageModel": [
      [
        {

```

```

        "node": "Moderate",
        "type": "ai_languageModel",
        "index": 0
      }
    ]
  },
  "Moderate": {
    "main": [
      [
        {
          "node": "Combine Results",
          "type": "main",
          "index": 0
        }
      ]
    ]
  },
  "Combine Results": {
    "main": [
      [
        {
          "node": "HTTP Request1",
          "type": "main",
          "index": 0
        }
      ]
    ]
  },
  "HTTP Request1": {
    "main": [
      [
        {
          "node": "Respond to Webhook1",
          "type": "main",
          "index": 0
        }
      ]
    ]
  },
  "active": true,
  "settings": {
    "executionOrder": "v1",
    "binaryMode": "separate",
    "timeSavedMode": "fixed",
    "callerPolicy": "workflowsFromSameOwner",
    "availableInMCP": false
  },
  "versionId": "6a40a963-0657-4280-aced-681dd26c2b18",
  "meta": {
    "templateCredsSetupCompleted": true,
    "instanceId": "0e6bfd841957965bed16e456aa118e29333bc95f3cbf7916a02862ee9c4c58cd1"
  },
  "id": "ecbBP3nJYa4YPf6S",
  "tags": []
}

```

Listing C.2: Cheebo DB chat assistant workflow

```

{
  "name": "Cheebo DB Chat",
  "nodes": [
    {
      "parameters": {
        "promptType": "define",
        "text": "=>text: {{ $json.body.message }}",
        "options": {
          "systemMessage": "You are a helpful shopping assistant for Cheebo -- a multi-vendor e-commerce marketplace. You have read-only access to the Cheebo database and can answer questions about products, stores, categories, and orders.\n\n## Database Schema\n\n### User\n- id (String PK), name, email (unique), role (CUSTOMER | SELLER | ADMIN), isBanned (Boolean), isPremium (Boolean), premiumExpiresAt (DateTime?)\n\n### Store\n- id (Int PK), name, description, logoUrl (String?), thumbnailUrl (String?), currentStatus (PENDING | ACTIVE | SUSPENDED | REJECTED), template (DEFAULT | MINIMAL | MODERN | CLASSIC), userId (FK -> User.id)\n\n### Product\n- id (Int PK), name, description, price (Float), displayPrice (String), stock (Int), status (AVAILABLE | UNAVAILABLE), isBanned (Boolean), verificationStatus (PENDING | APPROVED | REJECTED), verificationNote (String?), subcategoryId (FK -> Subcategory.id), thumbnailId (FK -> ProductImage.id, nullable), storeId (FK -> Store.id)\n\n### ProductImage\n- id (Int PK), url (String), alt (String?), productId (FK -> Product."

```

```

id)\n- Note: Product.thumbnailId references this table. To get a product's thumbnail URL: JOIN
ProductImage pi ON pi.id = p.thumbnailId\n\n### Order\n- id (Int PK), userId (FK -> User.id),
storeId (FK -> Store.id), status (PENDING | CONFIRMED | PROCESSING | SHIPPED | DELIVERED | CANCELLED
| REFUNDED), totalAmount (Float), city, state, country, zipCode, streetAddress, notes (String?)\n\n
### OrderItems\n- id (Int PK), orderId (FK -> Order.id), productId (FK -> Product.id), quantity (Int
), unitPrice (Float), subtotal (Float)\n\n### Category\n- id (Int PK), name\n\n### Subcategory\n- id
(Int PK), name, categoryId (FK -> Category.id)\n\n### ProductTag\n- id (Int PK), name (unique) --
linked to Product via _ProductToProductTag (productId, tagId)\n\n### FeaturedProduct\n- id (Int PK),
productId (unique FK -> Product.id), position (Int)\n\n### FeaturedStore\n- id (Int PK), storeId (
unique FK -> Store.id), position (Int)\n\n### Setting\n- key (String PK), value (Text)\n\n### Rules\
n1. ONLY run SELECT queries -- never INSERT, UPDATE, DELETE, DROP, or any DDL.\n2. Never query the
Session, Account, or Verification tables.\n3. Always filter public-facing product queries with:
status = 'AVAILABLE' AND isBanned = false AND verificationStatus = 'APPROVED'\n4. Always filter
public-facing store queries with: currentStatus = 'ACTIVE'\n5. Use JOINS when related data is needed
(e.g. store name on a product).\n6. Add LIMIT 50 to queries that could return many rows, unless the
user asks for more.\n7. If the question is ambiguous, ask a clarifying question before querying.\n8
. Return results in a clean format -- use tables or bullet points where helpful.\n9. If no results
are found, say so clearly.\n"

}
},
"id": "c6f7cd4c-8213-4561-bc6d-9eea18298ed5",
"name": "AI Agent",
"type": "@n8n/n8n-nodes-langchain.agent",
"typeVersion": 1.7,
"position": [
112,
-160
]
},
{
"parameters": {
"options": {}
},
"type": "@n8n/n8n-nodes-langchain.lmChatGoogleGemini",
"typeVersion": 1.1,
"position": [
-128,
64
],
"id": "a74cf87e-0c6b-4fd9-be04-97409ffc4b54",
"name": "Google Gemini Chat Model",
"credentials": {
"googlePalmApi": {
"id": "Lgn8GB0iIQdPIrUF",
"name": "Google Gemini(PaLM) Api account"
}
}
},
{
"parameters": {
"operation": "executeQuery",
"query": "{{ $fromAI('query', 'A valid MySQL SELECT query for the cheebo database. Only SELECT statements
are allowed.')}}",
"options": {}
},
"type": "n8n-nodes-base.mySqlTool",
"typeVersion": 2.5,
"position": [
320,
64
],
"id": "310ef9c8-64f1-4ffe-90ca-a73b795fa0aa",
"name": "Execute a SQL query in MySQL",
"credentials": {
"mysql": {
"id": "M4JqIk34rqJM7514",
"name": "MySQL account"
}
}
},
{
"parameters": {
"sessionIdType": "customKey",
"sessionKey": "={{ $json.body.sessionId }}"
},
"type": "@n8n/n8n-nodes-langchain.memoryBufferWindow",
"typeVersion": 1.3,
"position": [
176,
64
]
}
}

```

```

    ],
    "id": "13e66af7-8397-4a5d-9d45-6a4274e3d02f",
    "name": "Simple Memory"
  },
  {
    "parameters": {
      "httpMethod": "POST",
      "path": "cheebo-ai-chat",
      "authentication": "headerAuth",
      "responseMode": "responseNode",
      "options": {}
    },
    "type": "n8n-nodes-base.webhook",
    "typeVersion": 2.1,
    "position": [
      -176,
      -160
    ],
    "id": "5de1b970-b714-43e7-8a72-be056e052991",
    "name": "Webhook",
    "webhookId": "39dde4c0-bac9-4541-ba35-4ce07eddeff8",
    "credentials": {
      "httpHeaderAuth": {
        "id": "m0GIyhphvAjucASz",
        "name": "Header Auth account"
      }
    }
  },
  {
    "parameters": {
      "respondWith": "json",
      "responseBody": "={{ { \"output\": $json.output } }}",
      "options": {}
    },
    "type": "n8n-nodes-base.respondToWebhook",
    "typeVersion": 1.5,
    "position": [
      512,
      -160
    ],
    "id": "e5a2ff56-7e59-4722-8fb3-4d27c13f88bf",
    "name": "Respond to Webhook"
  },
  {
    "parameters": {
      "model": "openai/gpt-oss-20b",
      "options": {}
    },
    "type": "@n8n/n8n-nodes-langchain.lmChatGroq",
    "typeVersion": 1,
    "position": [
      32,
      64
    ],
    "id": "68330415-43c4-4c05-a8b4-306659334684",
    "name": "Groq Chat Model",
    "credentials": {
      "groqApi": {
        "id": "dJlv99vepslhXXeQ",
        "name": "Groq account"
      }
    }
  },
  ],
  "pinData": {},
  "connections": {
    "AI Agent": {
      "main": [
        [
          {
            "node": "Respond to Webhook",
            "type": "main",
            "index": 0
          }
        ]
      ]
    }
  },
  "Google Gemini Chat Model": {
    "ai_languageModel": [
  ]

```

```

    ]
  },
  "Execute a SQL query in MySQL": {
    "ai_tool": [
      [
        {
          "node": "AI Agent",
          "type": "ai_tool",
          "index": 0
        }
      ]
    ]
  },
  "Simple Memory": {
    "ai_memory": [
      [
        {
          "node": "AI Agent",
          "type": "ai_memory",
          "index": 0
        }
      ]
    ]
  },
  "Webhook": {
    "main": [
      [
        {
          "node": "AI Agent",
          "type": "main",
          "index": 0
        }
      ]
    ]
  },
  "Groq Chat Model": {
    "ai_languageModel": [
      [
        {
          "node": "AI Agent",
          "type": "ai_languageModel",
          "index": 0
        }
      ]
    ]
  },
  },
  "active": true,
  "settings": {
    "executionOrder": "v1",
    "binaryMode": "separate",
    "timeSavedMode": "fixed",
    "callerPolicy": "workflowsFromSameOwner",
    "availableInMCP": false
  },
  "versionId": "db4d7048-e590-4c8e-bbfa-7464d8278e5e",
  "meta": {
    "templateCredsSetupCompleted": true,
    "instanceId": "0e6bfd841957965bed16e456aa118e2933bc95f3cbf7916a02862ee9c4c58cd1"
  },
  },
  "id": "ziQZbFxx2wPLEfOU",
  "tags": []
}

```

Listing C.3: AI storefront redesign workflow

```

{
  "name": "Cheebo - Store AI Redesign",
  "nodes": [
    {
      "parameters": {
        "httpMethod": "POST",
        "path": "cheebo-store-redesign",
        "responseMode": "responseNode",
        "options": {}
      },
      "id": "9496737f-e59a-4a1a-b55f-ed2d64f50be6",
      "name": "Webhook1",
      "type": "n8n-nodes-base.webhook",
    }
  ]
}

```

```

"typeVersion": 2,
"position": [
  32,
  -48
],
"webhookId": "cheebo-store-redesign"
},
{
  "parameters": {
    "jsCode": "const body = $input.first().json.body ?? $input.first().json;\n\nconst storeName      = body.storeName\n      ?? 'My Store';\nconst storeDescription = body.storeDescription ?? '';\nconst\n      userPrompt      = body.prompt\n      ?? 'modern and clean';\n\nreturn [{\n  json: {\n    storeName\n      ,\n    storeDescription,\n    userPrompt,\n    systemPrompt: 'You are an expert e-commerce visual\n      designer.\nYour only job is to output a single valid JSON object that configures the visual design of\n      an online store.\n\nSTRICT OUTPUT RULES:\n- Return ONLY the raw JSON object -- no markdown, no\n      backticks, no code fences, no explanation\n- Every field listed below must be present\n- Use only the\n      exact allowed values listed for each field\n- All colors must be 6-digit hex codes (#RRGGBB)\n- image\n      Url must always be null\n- socialLinks must always be []\n- announcementBar.link must always be\n      null\n\nSCHEMA:\n\n  \"version\": 1,\n  \"announcementBar\": {\n    \"enabled\": true | false,\n    \"text\": \"<short promo line max 80 chars, empty string if disabled>\",\n    \"background\": \"<#RRGGBB>\",\n    \"textColor\": \"<#RRGGBB>\",\n    \"link\": null\n  },\n  \"theme\": {\n    \"primaryColor\": \"<#RRGGBB -- the store accent color>\",\n    \"radius\": \"sharp\" | \"soft\" | \"round\",\n    \"fontHeading\": \"inter\" | \"playfair\" | \"lora\" | \"space-grotesk\" | \"system\",\n    \"fontBody\": \"inter\" | \"playfair\" | \"lora\" | \"space-grotesk\" | \"system\",\n    \"header\": {\n      \"showLogo\": true | false,\n      \"logoSize\": \"sm\" | \"md\" | \"lg\",\n      \"sticky\": true | false,\n      \"background\": \"<#RRGGBB or the exact string transparent>\",\n      \"showBreadcrumbs\": true | false\n    },\n    \"banner\": {\n      \"enabled\": true | false,\n      \"imageUrl\": null,\n      \"overlay\": \"none\" | \"dark\" | \"light\",\n      \"height\": \"short\" | \"medium\" | \"tall\",\n      \"heading\": \"<a short catchy store headline, max 60 characters>\",\n      \"headingFont\": \"inter\" | \"playfair\" | \"lora\" | \"space-grotesk\" | \"system\",\n      \"headingColor\": \"<#RRGGBB>\",\n      \"align\": \"left\" | \"center\" | \"right\",\n      \"sidebar\": {\n        \"enabled\": true | false,\n        \"width\": \"narrow\" | \"medium\" | \"wide\",\n        \"background\": \"<#RRGGBB>\",\n        \"innerBackground\": \"<#RRGGBB>\",\n        \"textColor\": \"<#RRGGBB>\",\n        \"filterMode\": \"checkbox\" | \"radio\" | \"pills\",\n        \"showCategoryCounts\": true | false,\n        \"showPriceRange\": true | false\n      },\n      \"productGrid\": {\n        \"background\": \"<#RRGGBB or the exact string transparent>\",\n        \"columns\": 2 | 3 | 4,\n        \"cardStyle\": \"flat\" | \"shadow\" | \"border\",\n        \"aspectRatio\": \"1:1\" | \"4:5\" | \"16:9\"\n      },\n      \"footer\": {\n        \"enabled\": true | false,\n        \"background\": \"<#RRGGBB or the exact string transparent>\",\n        \"contentMd\": \"<1-2 sentence footer blurb in plain markdown>\",\n        \"socialLinks\": []\n      }\n    }\n  }\n}\n\nDESIGN GUIDELINES:\n- Make the design coherent -- colors, fonts and shapes should feel like one brand\n- Match the style request: luxury -> dark backgrounds, serif fonts, sharp/soft radius;\n  playful -> bright colors, round radius, inter/space-grotesk;\n  minimal -> transparent backgrounds, clean sans-serif fonts\n- The primary color should appear on buttons and links -- pick something bold and readable\n- Heading fonts: playfair and lora suit fashion/luxury; space-grotesk suits tech; inter suits everything else\n- Ensure textColor has good contrast against background and innerBackground in the sidebar\n- Banner heading: write a real one-line store slogan (do not leave it empty unless ultra-minimal style)\n\n`)\n\n}\n\n},\n{\n  \"id\": \"806eb898-14fe-4973-bcdc-91e8300a57f8\",\n  \"name\": \"Build Prompt1\",\n  \"type\": \"n8n-nodes-base.code\",\n  \"typeVersion\": 2,\n  \"position\": [\n    272,\n    -48\n  ]\n},\n{\n  \"parameters\": {\n    \"promptType\": \"define\",\n    \"text\": \"=Store name: {{ $json.storeName }}\\nStore description: {{ $json.storeDescription }}\\nStyle request: {{ $json.userPrompt }}\\n\\nGenerate the full store customization JSON now.\",\n    \"options\": {\n      \"systemMessage\": \"={{ $json.systemPrompt }}\"\n    }\n  },\n  \"id\": \"398d2176-5885-4c33-9455-089f43904f84\",\n  \"name\": \"AI Agent1\",\n  \"type\": \"n8n/n8n-nodes-langchain.agent\",\n  \"typeVersion\": 1.7,\n  \"position\": [\n    512,\n    -48\n  ]\n},\n{\n  \"parameters\": {\n    \"model\": \"llama-3.3-70b-versatile\",\n    \"options\": {\n      \"temperature\": 0.8

```

```

    }
  },
  "type": "@n8n/n8n-nodes-langchain.lmChatGroq",
  "typeVersion": 1,
  "position": [
    512,
    192
  ],
  "id": "394f920b-5f09-40cb-a761-7ba7884be5fd",
  "name": "Groq Chat Model1",
  "credentials": {
    "groqApi": {
      "id": "dJiv99vepslhXXeQ",
      "name": "Groq account"
    }
  }
},
{
  "parameters": {
    "jsCode": "const raw = $input.first().json?.output\n          ?? $input.first().json?.text\n          ?? $input.first().json?.message?.content\n          ?? '';\n\n// Strip markdown code fences if the model\nadded them\nconst cleaned = raw\n  .replace(/`(`(?:json)?\\s*/i, '')\n  .replace(/\\s*`$/, '')\n  .trim();\n\nlet design;\ntry {\n  design = JSON.parse(cleaned);\n} catch (e) {\n  throw new Error('LLM\nreturned invalid JSON: ' + cleaned.slice(0, 300));\n}\n\n// Enforce hard constraints\ndesign.version\n  = 1;\ndesign.banner.imageUrl\n  = null;\ndesign.footer.socialLinks\n  = [];\nif (design.announcementBar) design.announcementBar.link = null;\n\n// Clamp columns\nif (![2, 3, 4].includes(design.productGrid?.columns)) {\n  design.productGrid.columns = 3;\n}\n\n// Validate\nhex colors -- fallback to safe default if invalid\nconst hexRe = /^[0-9A-Fa-f]{6}$/;\nconst fix = (c)\n=> hexRe.test(c) ? c : '#1E40AF';\nconst orTransparent = (c) => c === 'transparent' ? 'transparent' :\n  fix(c);\n\nif (design.announcementBar) {\n  design.announcementBar.background = fix(design.\nannouncementBar.background);\n  design.announcementBar.textColor = fix(design.announcementBar.\ntextColor);\n}\n\ndesign.theme.primaryColor\n  = fix(design.theme.primaryColor);\ndesign.header.\nbackground\n  = orTransparent(design.header.background);\ndesign.banner.headingColor\n  = fix(\ndesign.banner.headingColor);\ndesign.sidebar.background\n  = fix(design.sidebar.background);\n\ndesign.sidebar.innerBackground\n  = fix(design.sidebar.innerBackground);\ndesign.sidebar.textColor\n  = fix(design.sidebar.textColor);\ndesign.productGrid.background\n  = orTransparent(design.\nproductGrid.background);\ndesign.footer.background\n  = orTransparent(design.footer.background);\n\nreturn [{ json: design }];\n",
    "id": "0e956c0f-367d-4037-b95c-4db6c70617ba",
    "name": "Parse & Sanitise JSON1",
    "type": "n8n-nodes-base.code",
    "typeVersion": 2,
    "position": [
      752,
      -48
    ]
  },
  "id": "9e56f1f1-edf6-4ccb-b5d8-6c80829falad",
  "name": "Respond to Webhook1",
  "type": "n8n-nodes-base.respondToWebhook",
  "typeVersion": 1,
  "position": [
    992,
    -48
  ]
}
},
{
  "id": "cheeboRedesign01",
  "pinData": {},
  "connections": {
    "Webhook1": {
      "main": [
        [
          {
            "node": "Build Prompt1",
            "type": "main",
            "index": 0
          }
        ]
      ]
    }
  }
}
},

```

```
"Build Prompt1": {
  "main": [
    [
      {
        "node": "AI Agent1",
        "type": "main",
        "index": 0
      }
    ]
  ],
},
"Groq Chat Model1": {
  "ai_languageModel": [
    [
      {
        "node": "AI Agent1",
        "type": "ai_languageModel",
        "index": 0
      }
    ]
  ],
},
"AI Agent1": {
  "main": [
    [
      {
        "node": "Parse & Sanitise JSON1",
        "type": "main",
        "index": 0
      }
    ]
  ],
},
"Parse & Sanitise JSON1": {
  "main": [
    [
      {
        "node": "Respond to Webhook1",
        "type": "main",
        "index": 0
      }
    ]
  ],
},
},
"active": false,
"settings": {
  "executionOrder": "v1"
}
}
```

Chapter D Dockerfiles

Listing D.1: backend/Dockerfile

```
# -- Build stage -----
FROM node:20-alpine AS builder

# Pin pnpm to a version compatible with this Node (pnpm@latest is now 11.x,
# which requires Node >= 22) and matching the CI / lockfile (pnpm 10).
RUN corepack enable && corepack prepare pnpm@10.34.3 --activate

WORKDIR /app

COPY package.json pnpm-lock.yaml pnpm-workspace.yaml .npmrc ./
RUN pnpm install --frozen-lockfile

COPY . .
RUN npx prisma generate && pnpm run build

# Drop dev dependencies so the runtime image ships only production deps. The
# prisma CLI stays (it is a runtime dependency -- 'prisma migrate deploy' runs
# on container start), as do @prisma/client and the generated client.
RUN pnpm prune --prod

# -- Production stage -----
FROM node:20-alpine

WORKDIR /app

COPY --from=builder /app/node_modules ./node_modules
COPY --from=builder /app/dist ./dist
COPY --from=builder /app/src/generated ./src/generated
COPY --from=builder /app/prisma ./prisma
COPY --from=builder /app/package.json ./package.json
COPY --from=builder /app/prisma.config.ts ./prisma.config.ts
COPY --from=builder /app/src/common/database-url.ts ./src/common/database-url.ts

# Run as the unprivileged 'node' user that ships with the base image. The
# copied app stays root-owned (read-only to the process, which is fine); only
# the uploads tree needs to be writable, so it is owned by 'node'. A fresh
# named volume mounted at /app/uploads inherits this ownership on first use.
RUN mkdir -p uploads/products uploads/stores uploads/users \
    && chown -R node:node uploads

USER node

EXPOSE 3000

CMD ["sh", "-c", "npx prisma migrate deploy && node dist/src/main"]
```

Listing D.2: frontend/Dockerfile

```
# -- Build stage -----
FROM node:20-alpine AS builder

# Pin pnpm to a version compatible with this Node (pnpm@latest is now 11.x,
# which requires Node >= 22) and matching the CI / lockfile (pnpm 10).
RUN corepack enable && corepack prepare pnpm@10.34.3 --activate

WORKDIR /app

COPY package.json pnpm-lock.yaml pnpm-workspace.yaml ./
RUN pnpm install --frozen-lockfile

COPY . .

ENV VITE_API_URL=__VITE_API_URL_PLACEHOLDER__
ENV VITE_STRIPE_PUBLISHABLE_KEY=__VITE_STRIPE_PUBLISHABLE_KEY_PLACEHOLDER__

RUN pnpm run build

# -- Production stage -----
# Unprivileged nginx: runs as uid 101 and listens on 8080 (no root, no
# privileged port). Caddy reaches it on :8080 over the internal network.
FROM nginxinc/nginx-unprivileged:alpine

# Setup needs root (chmod the entrypoint, make the SPA assets writable so the
# entrypoint can substitute the runtime VITE_* placeholders); then drop back.
USER root
COPY --from=builder /app/dist /usr/share/nginx/html
COPY nginx.conf /etc/nginx/conf.d/default.conf
COPY entrypoint.sh /entrypoint.sh
RUN chmod +x /entrypoint.sh \
    && chown -R 101:101 /usr/share/nginx/html
USER 101

ENTRYPOINT ["/entrypoint.sh"]
CMD ["nginx", "-g", "daemon off;"]

EXPOSE 8080
```

Chapter E Docker Compose File and Cad-dyfile

Listing E.1: docker-compose.yml

```
services:
  db:
    image: mariadb:11
    restart: always
    environment:
      MARIADB_ROOT_PASSWORD: ${DB_PASSWORD}
      MARIADB_DATABASE: ${DB_NAME}
      # Least-privilege application user (granted ALL on MARIADB_DATABASE only,
      # which still covers Prisma migrations). The app connects as this user
      # instead of root. Both vars must be set for the user to be created.
      MARIADB_USER: ${DB_APP_USER}
      MARIADB_PASSWORD: ${DB_APP_PASSWORD}
    volumes:
      - db_data:/var/lib/mysql
    healthcheck:
      test:
        [
          "CMD-SHELL",
          "mariadb-admin ping -h localhost -p${MARIADB_ROOT_PASSWORD}",
        ]
      interval: 10s
      timeout: 5s
      retries: 5

  backend:
    image: sirvinny/cheebo-backend:${IMAGE_TAG:-latest}
    restart: always
    depends_on:
      db:
        condition: service_healthy
    environment:
      # Database -- connect as the least-privilege app user, not root.
      DB_HOST: db
      DB_PORT: 3306
      DB_USER: ${DB_APP_USER}
      DB_PASSWORD: ${DB_APP_PASSWORD}
      DB_NAME: ${DB_NAME}
      # App
      NODE_ENV: production
      PORT: ${PORT}
      BETTER_AUTH_SECRET: ${BETTER_AUTH_SECRET}
      BETTER_AUTH_URL: ${APP_URL}
      FRONTEND_URL: ${APP_URL}
```

```

# Stripe payments (required in production -- the backend fail-fasts without them
)
STRIPE_SECRET_KEY: ${STRIPE_SECRET_KEY}
STRIPE_WEBHOOK_SECRET: ${STRIPE_WEBHOOK_SECRET}
# Admin (auto-created on first startup)
ADMIN_NAME: ${ADMIN_NAME}
ADMIN_EMAIL: ${ADMIN_EMAIL}
ADMIN_PASSWORD: ${ADMIN_PASSWORD}
# Upload
UPLOAD_DIR: ./uploads
MAX_UPLOAD_FILE_SIZE_MB: ${MAX_UPLOAD_FILE_SIZE_MB}
ALLOWED_UPLOAD_MIME_TYPES: ${ALLOWED_UPLOAD_MIME_TYPES}
# Auth / Session
SESSION_EXPIRES_IN: ${SESSION_EXPIRES_IN}
SESSION_UPDATE_AGE: ${SESSION_UPDATE_AGE}
MIN_PASSWORD_LENGTH: ${MIN_PASSWORD_LENGTH}
EMAIL_VERIFICATION_EXPIRES_IN: ${EMAIL_VERIFICATION_EXPIRES_IN}
# Swagger (set to empty to disable in prod)
SWAGGER_PATH: ${SWAGGER_PATH}
# SMTP
SMTP_HOST: ${SMTP_HOST}
SMTP_USER: ${SMTP_USER}
SMTP_PORT: ${SMTP_PORT}
SMTP_SECURE: ${SMTP_SECURE}
SMTP_PASS: ${SMTP_PASS}
SMTP_FROM: ${SMTP_FROM}
# Premium feature limits
FREE_TIER_MAX_PRODUCTS: ${FREE_TIER_MAX_PRODUCTS}
FREE_TIER_MAX_STORES: ${FREE_TIER_MAX_STORES}
PREMIUM_TEMPLATES: ${PREMIUM_TEMPLATES}
PREMIUM_PRICE_TND: ${PREMIUM_PRICE_TND}
PREMIUM_DURATION_DAYS: ${PREMIUM_DURATION_DAYS}
# Home page limits
MAX_FEATURED_PRODUCTS: ${MAX_FEATURED_PRODUCTS}
MAX_FEATURED_STORES: ${MAX_FEATURED_STORES}
# AI Chat (n8n webhook)
N8N_WEBHOOK_URL: http://n8n:5678/webhook/cheebo-ai-chat
N8N_WEBHOOK_SECRET: ${N8N_WEBHOOK_SECRET}
# AI Verification (n8n verify webhook)
N8N_VERIFY_WEBHOOK_URL: http://n8n:5678/webhook/cheebo-ai-verify
# AI Store Redesign (n8n redesign webhook)
N8N_REDESIGN_WEBHOOK_URL: http://n8n:5678/webhook/cheebo-store-redesign
volumes:
  - uploads:/app/uploads

frontend:
  image: sirvinny/cheebo-frontend:${IMAGE_TAG:-latest}
  restart: always
  depends_on:
    - backend
  environment:
    VITE_API_URL: ${APP_URL}
    VITE_PREMIUM_PRICE_TND: ${PREMIUM_PRICE_TND}
    VITE_PREMIUM_DURATION_DAYS: ${PREMIUM_DURATION_DAYS}
    # Stripe publishable key (safe to expose; substituted into the JS bundle at
    runtime)
    VITE_STRIPE_PUBLISHABLE_KEY: ${VITE_STRIPE_PUBLISHABLE_KEY}
  # No host port: the frontend is reached only through the Caddy proxy.

```

```

caddy:
  image: caddy:2-alpine
  restart: always
  depends_on:
    - frontend
  ports:
    - "80:80"
    - "443:443"
  environment:
    DOMAIN_NAME: ${DOMAIN_NAME}
    ACME_EMAIL: ${ADMIN_EMAIL}
  volumes:
    - ./Caddyfile:/etc/caddy/Caddyfile:ro
    - caddy_data:/data
    - caddy_config:/config

# One-shot bootstrapper: imports the version-controlled credentials and
# workflows into n8n's data volume and activates them, then exits. Runs to
# completion *before* the main n8n service starts, so there is never a second
# process writing n8n's SQLite database at the same time. Re-runs on every
# deploy and upserts by ID, so editing a workflow/credential in the repo and
# redeploying updates the live instance (GitOps-style).
n8n-init:
  image: n8nio/n8n:latest
  restart: "no"
  environment:
    # MUST match the main n8n service, or imported credentials won't decrypt.
    N8N_ENCRYPTION_KEY: ${N8N_ENCRYPTION_KEY}
  volumes:
    - n8n_data:/home/node/.n8n
    # Rendered (secrets substituted) by the deploy job before 'compose up'.
    - ./n8n-import/credentials:/credentials:ro
    - ./n8n-import/workflows:/workflows:ro
  entrypoint: ["/bin/sh", "-c"]
  command: >
    "n8n import:credentials --separate --input=/credentials &&
    n8n import:workflow --separate --input=/workflows &&
    n8n update:workflow --all --active=true"

n8n:
  image: n8nio/n8n:latest
  restart: always
  depends_on:
    n8n-init:
      condition: service_completed_successfully
  ports:
    - "5678:5678"
  environment:
    N8N_ENCRYPTION_KEY: ${N8N_ENCRYPTION_KEY}
    WEBHOOK_URL: http://${DOMAIN_NAME}:5678
    GENERIC_TIMEZONE: Africa/Tunis
    N8N_LOG_LEVEL: info
    N8N_SECURE_COOKIE: "false"
  volumes:
    - n8n_data:/home/node/.n8n

volumes:
  db_data:
  uploads:

```

```
n8n_data:
caddy_data:
caddy_config:
```

Listing E.2: Caddyfile (TLS reverse proxy)

```
# Global options -- ACME account email for Let's Encrypt certificate notices.
{
    email {$ACME_EMAIL}
}

# Canonicalise www -> apex so there is a single HTTPS origin, which matches
# the backend's BETTER_AUTH_URL / trustedOrigins and keeps cookies consistent.
www.{$DOMAIN_NAME} {
    redirect https://{$DOMAIN_NAME}{uri} permanent
}

# Public endpoint. Caddy obtains and renews the TLS certificate
# automatically (HTTP-01 / TLS-ALPN-01) and terminates HTTPS here, then
# reverse-proxies to the internal Nginx frontend container, which serves the
# SPA and forwards /api and the SSE stream to the backend.
{$DOMAIN_NAME} {
    encode gzip

    # Security response headers. Conservative baseline that does not break the
    # SPA, the /api proxy, the SSE stream, or Stripe checkout (no CSP -- a strict
    # policy would need per-asset auditing first).
    header {
        # HSTS -- force HTTPS for a year, including subdomains (www is HTTPS).
        # No 'preload' so we keep the option to roll back.
        Strict-Transport-Security "max-age=31536000; includeSubDomains"
        # Stop MIME sniffing.
        X-Content-Type-Options "nosniff"
        # We embed Stripe's iframe (outbound); this only restricts who may frame
        # us, so SAMEORIGIN is safe.
        X-Frame-Options "SAMEORIGIN"
        # Send origin only on cross-origin navigations.
        Referrer-Policy "strict-origin-when-cross-origin"
        # Don't advertise the server software.
        -Server
    }

    reverse_proxy frontend:8080
}
```

Chapter F GitHub Actions Workflow

Listing F.1: .github/workflows/deploy.yml

```
name: Build, Push & Deploy

# -- Secrets (Settings > Secrets and variables > Actions > Secrets) -----
# DOCKERHUB_TOKEN -- Docker Hub access token
# DO_SSH_PRIVATE_KEY -- Private SSH key with root access to the droplet
# DO_TOKEN -- DigitalOcean API token (used by Terraform)
# DO_SPACES_ACCESS_KEY -- DigitalOcean Spaces access key (Terraform state
  backend)
# DO_SPACES_SECRET_KEY -- DigitalOcean Spaces secret key (Terraform state
  backend)
# DB_PASSWORD -- MariaDB root password
# BETTER_AUTH_SECRET -- Strong random string for auth
# ADMIN_PASSWORD -- Initial admin account password
# STRIPE_SECRET_KEY -- Stripe secret API key (sk_test_... / sk_live_...)
# STRIPE_WEBHOOK_SECRET -- Stripe webhook signing secret (whsec_...)
# SMTP_PASS -- SMTP app password
# N8N_WEBHOOK_SECRET -- Secret key for n8n webhook header auth
# N8N_ENCRYPTION_KEY -- n8n data encryption key (generate with: openssl
  rand -hex 32)
# GEMINI_API_KEY -- Google Gemini (PaLM) API key for n8n AI nodes
# GROQ_API_KEY -- Groq API key for n8n AI nodes
#
# -- Variables (Settings > Secrets and variables > Actions > Variables) -----
# DOCKERHUB_USERNAME -- Docker Hub username
# DO_SSH_KEY_FINGERPRINT -- Fingerprint of the SSH key added to your DO account
# DB_NAME -- Database name (e.g. cheebo)
# PORT -- Backend port (e.g. 3000)
# ADMIN_NAME / ADMIN_EMAIL
# MAX_UPLOAD_FILE_SIZE_MB
# ALLOWED_UPLOAD_MIME_TYPES -- e.g. image/jpeg,image/png,image/webp,image/gif
# SESSION_EXPIRES_IN / SESSION_UPDATE_AGE / MIN_PASSWORD_LENGTH /
  EMAIL_VERIFICATION_EXPIRES_IN
# SWAGGER_PATH -- Set to empty string to disable in prod
# SMTP_HOST / SMTP_USER / SMTP_PORT / SMTP_SECURE / SMTP_FROM
# FREE_TIER_MAX_PRODUCTS / PREMIUM_TEMPLATES / PREMIUM_PRICE_TND /
  PREMIUM_DURATION_DAYS
# MAX_FEATURED_PRODUCTS / MAX_FEATURED_STORES
# STRIPE_PUBLISHABLE_KEY -- Stripe publishable key (pk_test_... / pk_live_...),
  baked into the frontend bundle
# DOMAIN_NAME -- your domain (e.g. nadimjebali.engineer) -- DNS
  managed via DigitalOcean

on:
  push:
    branches:
      - main
  workflow_dispatch:
```

```

jobs:
  test-backend:
    name: Backend Checks (lint, build, Jest)
    runs-on: ubuntu-latest
    defaults:
      run:
        working-directory: ./backend
    steps:
      - name: Checkout
        uses: actions/checkout@v4

      - name: Setup pnpm
        uses: pnpm/action-setup@v4
        with:
          version: 10

      - name: Setup Node
        uses: actions/setup-node@v4
        with:
          # Match the runtime Node version used by the Docker image.
          node-version: 20
          cache: pnpm
          cache-dependency-path: backend/pnpm-lock.yaml

      - name: Install dependencies
        run: pnpm install --frozen-lockfile

      - name: Generate Prisma client
        run: pnpm exec prisma generate

      - name: Lint
        run: pnpm run lint:ci

      - name: Build
        run: pnpm run build

      - name: Run tests
        id: test
        run: pnpm test

      - name: Job summary
        if: always()
        run: |
          {
            echo "## Backend Checks (lint, build, Jest)"
            echo ""
            echo "| Field | Value |"
            echo "| --- | --- |"
            echo "| Result | ${ steps.test.outcome == 'success' && '✓ passed' || '✗ failed' } |"
            echo "| Commit | \`${ github.sha }\` |"
          } >> "$GITHUB_STEP_SUMMARY"

  test-frontend:
    name: Frontend Checks (lint, build, Vitest)
    runs-on: ubuntu-latest
    defaults:
      run:

```

```

    working-directory: ./frontend
  steps:
    - name: Checkout
      uses: actions/checkout@v4

    - name: Setup pnpm
      uses: pnpm/action-setup@v4
      with:
        version: 10

    - name: Setup Node
      uses: actions/setup-node@v4
      with:
        # Match the runtime Node version used by the Docker image.
        node-version: 20
        cache: pnpm
        cache-dependency-path: frontend/pnpm-lock.yaml

    - name: Install dependencies
      run: pnpm install --frozen-lockfile

    - name: Lint
      run: pnpm run lint

    - name: Build (typecheck + bundle)
      run: pnpm run build

    - name: Run tests
      id: test
      run: pnpm test

    - name: Job summary
      if: always()
      run: |
        {
          echo "## Frontend Checks (lint, build, Vitest)"
          echo ""
          echo "| Field | Value |"
          echo "| --- | --- |"
          echo "| Result | ${ steps.test.outcome == 'success' && '✓ passed' || '✗ failed' } |"
          echo "| Commit | \`${ github.sha }\` |"
        } >> "$GITHUB_STEP_SUMMARY"

  provision:
    name: Provision Droplet (Terraform)
    runs-on: ubuntu-latest
    outputs:
      droplet_ip: ${ steps.ip.outputs.ip }
    steps:
      - name: Checkout
        uses: actions/checkout@v4

      - name: Setup Terraform
        uses: hashicorp/setup-terraform@v3
        with:
          terraform_wrapper: false

      - name: Terraform Init

```

```

working-directory: terraform
env:
  AWS_ACCESS_KEY_ID: ${ secrets.DO_SPACES_ACCESS_KEY }}
  AWS_SECRET_ACCESS_KEY: ${ secrets.DO_SPACES_SECRET_KEY }}
run: terraform init

- name: Auto-import existing resources
  working-directory: terraform
  env:
    TF_VAR_do_token: ${ secrets.DO_TOKEN }}
    TF_VAR_ssh_key_fingerprint: ${ vars.DO_SSH_KEY_FINGERPRINT }}
    # All required TF variables must be set or 'terraform import' aborts
    # with "No value for required variable" before importing -- which left
    # the existing VPC out of state, so apply then tried to recreate it
    # and DigitalOcean rejected it with 422 (already exists). Mirror the
    # apply step's variables here.
    TF_VAR_droplet_name: ${ vars.DROPLET_NAME || 'cheebo' }}
    TF_VAR_region: ${ vars.DO_REGION || 'fra1' }}
    TF_VAR_droplet_size: ${ vars.DROPLET_SIZE || 's-2vcpu-2gb' }}
    TF_VAR_domain_name: ${ vars.DOMAIN_NAME }}
    DO_TOKEN: ${ secrets.DO_TOKEN }}
    DROPLET_NAME: ${ vars.DROPLET_NAME || 'cheebo' }}
    AWS_ACCESS_KEY_ID: ${ secrets.DO_SPACES_ACCESS_KEY }}
    AWS_SECRET_ACCESS_KEY: ${ secrets.DO_SPACES_SECRET_KEY }}
  run: |
    query() { curl -sf -H "Authorization: Bearer $DO_TOKEN" "$1"; }

    VPC_ID=$(query "https://api.digitalocean.com/v2/vpcs?per_page=200" \
      | python3 -c "import sys,json; v=[x['id'] for x in json.load(sys.stdin).
        get('vpcs',[[]] if x['name']=='cheebo-vpc']; print(v[0] if v else '')")
    [ -n "$VPC_ID" ] && terraform import -input=false digitalocean_vpc.cheebo "
      $VPC_ID" || true

    DROPLET_ID=$(query "https://api.digitalocean.com/v2/droplets?per_page=200" \
      | python3 -c "import sys,json; d=[x['id'] for x in json.load(sys.stdin).
        get('droplets',[[]] if x['name']=='$DROPLET_NAME']; print(d[0] if d
        else '')")
    [ -n "$DROPLET_ID" ] && terraform import -input=false digitalocean_droplet.
      cheebo "$DROPLET_ID" || true

    DOMAIN_NAME="${ vars.DOMAIN_NAME }}"
    [ -n "$DOMAIN_NAME" ] && terraform import -input=false 'digitalocean_domain.
      cheebo[0]' "$DOMAIN_NAME" 2>/dev/null || true

- name: Terraform Apply
  id: apply
  working-directory: terraform
  env:
    TF_VAR_do_token: ${ secrets.DO_TOKEN }}
    TF_VAR_ssh_key_fingerprint: ${ vars.DO_SSH_KEY_FINGERPRINT }}
    TF_VAR_droplet_name: ${ vars.DROPLET_NAME || 'cheebo' }}
    TF_VAR_region: ${ vars.DO_REGION || 'fra1' }}
    TF_VAR_droplet_size: ${ vars.DROPLET_SIZE || 's-2vcpu-2gb' }}
    TF_VAR_domain_name: ${ vars.DOMAIN_NAME }}
    AWS_ACCESS_KEY_ID: ${ secrets.DO_SPACES_ACCESS_KEY }}
    AWS_SECRET_ACCESS_KEY: ${ secrets.DO_SPACES_SECRET_KEY }}
  run: terraform apply -auto-approve

- name: Export droplet IP

```

```

    id: ip
    working-directory: terraform
    env:
      AWS_ACCESS_KEY_ID: ${ secrets.DO_SPACES_ACCESS_KEY }
      AWS_SECRET_ACCESS_KEY: ${ secrets.DO_SPACES_SECRET_KEY }
    run: echo "ip=$(terraform output -raw droplet_ip)" >> $GITHUB_OUTPUT

- name: Job summary
  if: always()
  run: |
    {
      echo "## Provision Droplet (Terraform)"
      echo ""
      echo "| Field | Value |"
      echo "| --- | --- |"
      echo "| Result | ${ steps.apply.outcome == 'success' && '✓ applied' || '✗ failed' } |"
      echo "| Droplet IP | \`${ steps.ip.outputs.ip }\` |"
      echo "| Region | ${ vars.DO_REGION || 'fra1' } |"
      echo "| Size | ${ vars.DROPLET_SIZE || 's-2vcpu-2gb' } |"
    } >> "$GITHUB_STEP_SUMMARY"

build-backend:
  name: Build & Push Backend
  runs-on: ubuntu-latest
  needs: test-backend
  steps:
    - name: Checkout
      uses: actions/checkout@v4

    - name: Set up Docker Buildx
      uses: docker/setup-buildx-action@v3

    - name: Log in to Docker Hub
      uses: docker/login-action@v3
      with:
        username: ${ vars.DOCKERHUB_USERNAME }
        password: ${ secrets.DOCKERHUB_TOKEN }

    - name: Build & push backend image
      id: build
      uses: docker/build-push-action@v6
      with:
        context: ./backend
        push: true
        tags: |
          ${ vars.DOCKERHUB_USERNAME }/cheebo-backend:latest
          ${ vars.DOCKERHUB_USERNAME }/cheebo-backend:${ github.sha }
        cache-from: type=gha,scope=backend
        cache-to: type=gha,mode=max,scope=backend

    - name: Job summary
      if: always()
      run: |
        {
          echo "## Build & Push Backend"
          echo ""
          echo "| Field | Value |"
          echo "| --- | --- |"

```

```

        echo "| Result | ${ steps.build.outcome == 'success' && '✓ pushed' || '✗
        failed' }} |"
        echo "| Image | \"${ vars.DOCKERHUB_USERNAME }}/cheebo-backend:latest\"
        |"
        echo "| Digest | \"${ steps.build.outputs.digest }}\" |"
        echo "| Commit | \"${ github.sha }}\" |"
    } >> "$GITHUB_STEP_SUMMARY"

build-frontend:
  name: Build & Push Frontend
  runs-on: ubuntu-latest
  needs: test-frontend
  steps:
    - name: Checkout
      uses: actions/checkout@v4

    - name: Set up Docker Buildx
      uses: docker/setup-buildx-action@v3

    - name: Log in to Docker Hub
      uses: docker/login-action@v3
      with:
        username: ${ vars.DOCKERHUB_USERNAME }
        password: ${ secrets.DOCKERHUB_TOKEN }

    - name: Build & push frontend image
      id: build
      uses: docker/build-push-action@v6
      with:
        context: ./frontend
        push: true
        tags: |
          ${ vars.DOCKERHUB_USERNAME }}/cheebo-frontend:latest
          ${ vars.DOCKERHUB_USERNAME }}/cheebo-frontend:${ github.sha }
        cache-from: type=gha,scope=frontend
        cache-to: type=gha,mode=max,scope=frontend

    - name: Job summary
      if: always()
      run: |
        {
          echo "## Build & Push Frontend"
          echo ""
          echo "| Field | Value |"
          echo "| --- | --- |"
          echo "| Result | ${ steps.build.outcome == 'success' && '✓ pushed' || '✗
          failed' }} |"
          echo "| Image | \"${ vars.DOCKERHUB_USERNAME }}/cheebo-frontend:latest\"
          |"
          echo "| Digest | \"${ steps.build.outputs.digest }}\" |"
          echo "| Commit | \"${ github.sha }}\" |"
        } >> "$GITHUB_STEP_SUMMARY"

deploy:
  name: Deploy to DigitalOcean
  runs-on: ubuntu-latest
  needs: [provision, build-backend, build-frontend]
  steps:
    - name: Checkout

```

```

uses: actions/checkout@v4

- name: Copy docker-compose.yml and Caddyfile to droplet
  uses: appleboy/scp-action@v0.1.7
  with:
    host: ${ needs.provision.outputs.droplet_ip }}
    username: root
    key: ${ secrets.DO_SSH_PRIVATE_KEY }}
    source: "docker-compose.yml,Caddyfile,n8n-workflows,n8n-credentials"
    target: /app

- name: Write .env, shut down & redeploy
  id: deploy
  uses: appleboy/ssh-action@v1.0.3
  env:
    DOMAIN_NAME: ${ vars.DOMAIN_NAME }}
    DB_NAME: ${ vars.DB_NAME }}
    PORT: ${ vars.PORT }}
    ADMIN_NAME: ${ vars.ADMIN_NAME }}
    ADMIN_EMAIL: ${ vars.ADMIN_EMAIL }}
    MAX_UPLOAD_FILE_SIZE_MB: ${ vars.MAX_UPLOAD_FILE_SIZE_MB }}
    ALLOWED_UPLOAD_MIME_TYPES: ${ vars.ALLOWED_UPLOAD_MIME_TYPES }}
    SESSION_EXPIRES_IN: ${ vars.SESSION_EXPIRES_IN }}
    SESSION_UPDATE_AGE: ${ vars.SESSION_UPDATE_AGE }}
    MIN_PASSWORD_LENGTH: ${ vars.MIN_PASSWORD_LENGTH }}
    EMAIL_VERIFICATION_EXPIRES_IN: ${ vars.EMAIL_VERIFICATION_EXPIRES_IN }}
    SWAGGER_PATH: ${ vars.SWAGGER_PATH }}
    SMTP_HOST: ${ vars.SMTP_HOST }}
    SMTP_USER: ${ vars.SMTP_USER }}
    SMTP_PORT: ${ vars.SMTP_PORT }}
    SMTP_SECURE: ${ vars.SMTP_SECURE }}
    SMTP_FROM: ${ vars.SMTP_FROM }}
    FREE_TIER_MAX_PRODUCTS: ${ vars.FREE_TIER_MAX_PRODUCTS }}
    FREE_TIER_MAX_STORES: ${ vars.FREE_TIER_MAX_STORES }}
    PREMIUM_TEMPLATES: ${ vars.PREMIUM_TEMPLATES }}
    PREMIUM_PRICE_TND: ${ vars.PREMIUM_PRICE_TND }}
    PREMIUM_DURATION_DAYS: ${ vars.PREMIUM_DURATION_DAYS }}
    MAX_FEATURED_PRODUCTS: ${ vars.MAX_FEATURED_PRODUCTS }}
    MAX_FEATURED_STORES: ${ vars.MAX_FEATURED_STORES }}
    N8N_WEBHOOK_URL: ${ vars.N8N_WEBHOOK_URL }}
    # Pin the deployed images to this commit so a rollback is just a
    # redeploy with an older IMAGE_TAG. Defaults to latest if unset.
    IMAGE_TAG: ${ github.sha }}
    # Least-privilege DB app user (see docker-compose.yml).
    DB_APP_USER: ${ vars.DB_APP_USER }}
    DB_APP_PASSWORD: ${ secrets.DB_APP_PASSWORD }}
    DB_PASSWORD: ${ secrets.DB_PASSWORD }}
    BETTER_AUTH_SECRET: ${ secrets.BETTER_AUTH_SECRET }}
    ADMIN_PASSWORD: ${ secrets.ADMIN_PASSWORD }}
    STRIPE_SECRET_KEY: ${ secrets.STRIPE_SECRET_KEY }}
    STRIPE_WEBHOOK_SECRET: ${ secrets.STRIPE_WEBHOOK_SECRET }}
    VITE_STRIPE_PUBLISHABLE_KEY: ${ vars.STRIPE_PUBLISHABLE_KEY }}
    SMTP_PASS: ${ secrets.SMTP_PASS }}
    N8N_WEBHOOK_SECRET: ${ secrets.N8N_WEBHOOK_SECRET }}
    N8N_ENCRYPTION_KEY: ${ secrets.N8N_ENCRYPTION_KEY }}
    GEMINI_API_KEY: ${ secrets.GEMINI_API_KEY }}
    GROQ_API_KEY: ${ secrets.GROQ_API_KEY }}
  with:
    host: ${ needs.provision.outputs.droplet_ip }}

```

```

username: root
key: ${ secrets.DO_SSH_PRIVATE_KEY }}
envs: DOMAIN_NAME,DB_NAME,PORT,ADMIN_NAME,ADMIN_EMAIL,
      MAX_UPLOAD_FILE_SIZE_MB,ALLOWED_UPLOAD_MIME_TYPES,SESSION_EXPIRES_IN,
      SESSION_UPDATE_AGE,MIN_PASSWORD_LENGTH,EMAIL_VERIFICATION_EXPIRES_IN,
      SWAGGER_PATH,SMTP_HOST,SMTP_USER,SMTP_PORT,SMTP_SECURE,SMTP_FROM,
      FREE_TIER_MAX_PRODUCTS,FREE_TIER_MAX_STORES,PREMIUM_TEMPLATES,
      PREMIUM_PRICE_TND,PREMIUM_DURATION_DAYS,MAX_FEATURED_PRODUCTS,
      MAX_FEATURED_STORES,DB_PASSWORD,BETTER_AUTH_SECRET,ADMIN_PASSWORD,
      SMTP_PASS,N8N_WEBHOOK_SECRET,N8N_ENCRYPTION_KEY,GEMINI_API_KEY,
      GROQ_API_KEY,IMAGE_TAG,DB_APP_USER,DB_APP_PASSWORD,STRIPE_SECRET_KEY,
      STRIPE_WEBHOOK_SECRET,VITE_STRIPE_PUBLISHABLE_KEY
script: |
  # -- Wait for cloud-init to finish (avoids apt lock on new droplets) --
  cloud-init status --wait 2>/dev/null || true

  # -- Open n8n port in firewall -----
  ufw allow 5678/tcp || true

  # -- Install Docker if not present -----
  if ! command -v docker &>/dev/null; then
    apt-get update -y
    apt-get install -y ca-certificates curl gnupg lsb-release
    install -m 0755 -d /etc/apt/keyrings
    curl -fsSL https://download.docker.com/linux/ubuntu/gpg -o /etc/apt/
      keyrings/docker.asc
    chmod a+r /etc/apt/keyrings/docker.asc
    echo "deb [arch=$(dpkg --print-architecture) signed-by=/etc/apt/keyrings
      /docker.asc] https://download.docker.com/linux/ubuntu $(lsb_release
      -cs) stable" \
      | tee /etc/apt/sources.list.d/docker.list > /dev/null
    apt-get update -y
    apt-get install -y docker-ce docker-ce-cli containerd.io docker-buildx-
      plugin docker-compose-plugin
    systemctl enable docker
    systemctl start docker
  fi

  # -- Write .env -----
  mkdir -p /app
  cat > /app/.env << EOF
  IMAGE_TAG=$IMAGE_TAG
  DB_PASSWORD=$DB_PASSWORD
  DB_APP_USER=$DB_APP_USER
  DB_APP_PASSWORD=$DB_APP_PASSWORD
  DB_NAME=$DB_NAME
  PORT=$PORT
  BETTER_AUTH_SECRET=$BETTER_AUTH_SECRET
  STRIPE_SECRET_KEY=$STRIPE_SECRET_KEY
  STRIPE_WEBHOOK_SECRET=$STRIPE_WEBHOOK_SECRET
  VITE_STRIPE_PUBLISHABLE_KEY=$VITE_STRIPE_PUBLISHABLE_KEY
  APP_URL=https://$DOMAIN_NAME
  ADMIN_NAME=$ADMIN_NAME
  ADMIN_EMAIL=$ADMIN_EMAIL
  ADMIN_PASSWORD=$ADMIN_PASSWORD
  MAX_UPLOAD_FILE_SIZE_MB=$MAX_UPLOAD_FILE_SIZE_MB
  ALLOWED_UPLOAD_MIME_TYPES=$ALLOWED_UPLOAD_MIME_TYPES
  SESSION_EXPIRES_IN=$SESSION_EXPIRES_IN
  SESSION_UPDATE_AGE=$SESSION_UPDATE_AGE

```

```

MIN_PASSWORD_LENGTH=$MIN_PASSWORD_LENGTH
EMAIL_VERIFICATION_EXPIRES_IN=$EMAIL_VERIFICATION_EXPIRES_IN
SWAGGER_PATH=$SWAGGER_PATH
SMTP_HOST=$SMTP_HOST
SMTP_USER=$SMTP_USER
SMTP_PORT=$SMTP_PORT
SMTP_SECURE=$SMTP_SECURE
SMTP_PASS=$SMTP_PASS
SMTP_FROM=$SMTP_FROM
FREE_TIER_MAX_PRODUCTS=$FREE_TIER_MAX_PRODUCTS
FREE_TIER_MAX_STORES=$FREE_TIER_MAX_STORES
PREMIUM_TEMPLATES=$PREMIUM_TEMPLATES
PREMIUM_PRICE_TND=$PREMIUM_PRICE_TND
PREMIUM_DURATION_DAYS=$PREMIUM_DURATION_DAYS
MAX_FEATURED_PRODUCTS=$MAX_FEATURED_PRODUCTS
MAX_FEATURED_STORES=$MAX_FEATURED_STORES
N8N_WEBHOOK_URL=$N8N_WEBHOOK_URL
N8N_WEBHOOK_SECRET=$N8N_WEBHOOK_SECRET
N8N_ENCRYPTION_KEY=$N8N_ENCRYPTION_KEY
DOMAIN_NAME=$DOMAIN_NAME
EOF

# -- Render n8n credential & workflow templates -----
# Injects secrets into the committed templates. envsubst is given an
# explicit variable allow-list so n8n expressions (${json, $fromAI,
# $('Webhook'), ...) inside the workflows are left untouched.
command -v envsubst >/dev/null 2>&1 || { apt-get update -y && apt-get
    install -y gettext-base; }
N8N_SUBST_VARS='${GEMINI_API_KEY} ${GROQ_API_KEY} ${DB_NAME} ${DB_PASSWORD}
    ${N8N_WEBHOOK_SECRET}'
rm -rf /app/.n8n-import
mkdir -p /app/.n8n-import/credentials /app/.n8n-import/workflows
for f in /app/n8n-credentials/*.json; do
    envsubst "$N8N_SUBST_VARS" < "$f" > "/app/.n8n-import/credentials/${
        basename "$f"}"
done
for f in /app/n8n-workflows/*.json; do
    envsubst "$N8N_SUBST_VARS" < "$f" > "/app/.n8n-import/workflows/${
        basename "$f"}"
done

cd /app
docker compose down --remove-orphans || true
docker compose pull
docker compose up -d --force-recreate

- name: Job summary
  if: always()
  run: |
    {
      echo "## Deploy to DigitalOcean"
      echo ""
      echo "| Field | Value |"
      echo "| --- | --- |"
      echo "| Result | ${ steps.deploy.outcome == 'success' && '✓ deployed' ||
        '✗ failed' } |"
      echo "| Droplet IP | \`${ steps.provision.outputs.droplet_ip }\` |"
      echo "| URL | https://${ vars.DOMAIN_NAME } |"
    } >> "$GITHUB_STEP_SUMMARY"

```